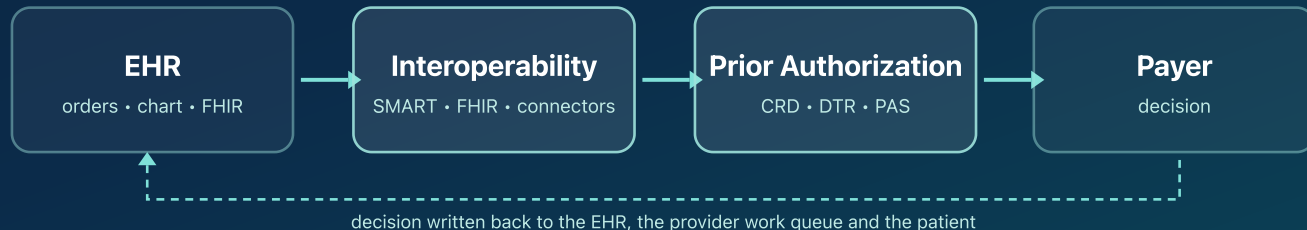


ARCHITECTURE & BUSINESS BLUEPRINT

Healthcare Interoperability & Prior Authorization Platform

Architecture, Business Model, Technical Design & Implementation Roadmap

Medblocks-Inspired Interoperability Architecture for Automated Prior Authorization



Version 2.0 (draft for discussion) · **Evidence as of** 30 September 2026

Prepared for CTO, CEO, engineering & product leadership, architects, healthcare business stakeholders, technical partners and client stakeholders

Independent proposal with a temporary working name. Not affiliated with or endorsed by Medblocks; Medblocks is studied only through its public documentation. U.S. regulatory and standards status is as verified on the evidence date. Proposed rules are labeled as such. Contains no PHI.

Document control

Title	Healthcare Interoperability & Prior Authorization Platform: Architecture, Business Model, Technical Design & Implementation Roadmap
Subtitle	Medblocks-Inspired Interoperability Architecture for Automated Prior Authorization
Version / status	2.0 (draft for discussion). For architecture, product and executive review. Not approved for implementation.
Evidence date	All sources retrieved 30 September 2026. Regulatory status reflects that date.
Supersedes	Earlier internal draft "Healthcare-Interoperability-Prior-Authorization-Blueprint.pdf" (v1.0, 30 Sep 2026). This version re-verifies sources, redraws all architecture and sequence diagrams, and expands the domain, technical and delivery sections.
Intended readers	CEO, CTO, engineering and product leadership, architects, healthcare business stakeholders, potential technical partners, client stakeholders
Affiliation	Independent proposal. The working name is temporary. Not affiliated with, endorsed by, or derived from Medblocks' proprietary implementation. Medblocks is referenced only through public documentation.
Data	Contains no PHI. All examples are synthetic.
Method	Desk research of primary sources (CMS, HHS/CFR, HL7/Da Vinci, ONC/ASTP, vendor and payer documentation), reconciliation, then design. No sandbox, payer, conformance or load tests were executed.
Open decisions	Design partner and pilot payer; second EHR; workflow engine (Temporal vs Step Functions); identity provider; clearinghouse partner; pricing (see §31 unknowns).

Label legend (quick reference)

Verified Industry-standard Recommended Inferred Needs validation Estimate Proposed rule Historical

Contents

How to read this document	6	19 API Architecture	68
2 Executive Summary	00	20 Connector Architecture	72
3 Business Problem	10	21 Security & Compliance	00
4 Healthcare Ecosystem	00	22 Cloud Architecture	78
5 What Medblocks Is	16	23 Multi-Tenancy	00
6 Medblocks Publicly Documented Architecture	19	24 Reliability & Observability	00
7 Lessons from Medblocks	00	25 Admin / Developer Platform	00
8 Proposed Platform Vision	25	26 Testing Strategy	86
9 Target Business Architecture	27	27 Build vs Buy	88
10 Target Technical Architecture	00	28 MVP	00
11 EHR Connectivity	00	29 Implementation Roadmap	00
12 Payer Connectivity	00	30 Team Structure	94
13 FHIR / SMART Architecture	43	31 Risks	00
14 Data Architecture	47	32 Cost / Effort Estimates	00
15 Terminology Architecture	00	33 Future-State Architecture	98
16 Prior Authorization Business Workflow	00	34 Conclusion	00
17 CRD / DTR / PAS	00	35 Glossary	103
18 Prior Authorization Technical Workflow	00	36 References	105

List of figures

Figure 1. U.S. healthcare ecosystem relevant to prior authorization: who talks to whom (simplified; payer and provider organizations vary)	12	Figure 17. Diagram 7: Prior authorization business workflow (swimlanes)	56
Figure 2. Medblocks logical architecture reconstructed from public docs (VERIFIED surfaces; INFERRED internals dashed)	19	Figure 18. Medical-benefit vs. pharmacy-benefit prior authorization: different triggers, standards and counterparties	57
Figure 3. Medblocks documented data flow	20	Figure 19. Diagram 8: Relationship between CRD, DTR and PAS and the Platform's role	59
Figure 4. Medblocks patient-session and connection states. States are VERIFIED; transition rules are INFERRED	20	Figure 20. PA case state machine (normalized states; payer vocabulary preserved alongside)	63
Figure 5. Medblocks patient-access sequence based on the patient-session documentation	21	Figure 21. Diagram 9 (part 1): Medical PA sequence: discovery and documentation	64
Figure 6. Medblocks backend pattern (docs marked work in progress)	21	Figure 22. Diagram 9 (part 2): Medical PA sequence: submission, pending, additional information and decision	65
Figure 7. Medblocks pull lifecycle and documented failure types	22	Figure 23. Connector framework: interface, shared building blocks and plugins	72
Figure 8. Medblocks webhook delivery contract	22	Figure 24. Diagram 11: Layered security architecture	75
Figure 9. Diagram 1: System context. Who and what the Platform interacts with	26	Figure 25. Diagram 14: PHI boundaries and permitted crossings	77
Figure 10. Diagram 2: Logical architecture	30	Figure 26. Diagram 13: Production AWS deployment (reference)	78
Figure 11. Diagram 3: Physical / deployment architecture (technology-neutral runtime tiers)	33	Figure 27. Diagram 12: Multi-tenant architecture with three isolation tiers	81
Figure 12. Diagram 6: FHIR data ingestion flow	38	Figure 28. Diagram 10: Failure, retry and error architecture	83
Figure 13. Diagram 4: EHR → interoperability platform → payer flow	41	Figure 29. Diagram 15: MVP architecture	91
Figure 14. Payer capability decision tree used on every case	42	Figure 30. Illustrative roadmap (months from kickoff; ESTIMATE)	92
Figure 15. Diagram 5: SMART on FHIR authorization flows (EHR launch and Backend Services)	44	Figure 31. Diagram 16: Future enterprise architecture	98
Figure 16. Conceptual data model (entities, key fields and main relationships)	47	Figure 32. Final recommended target architecture: patient → provider → EHR → platform → CRD/DTR/PAS → payer → decision, with infrastructure, security and PHI boundaries	100

List of tables

Table 1. Reading guide by audience	6	Table 33. PAS at a glance (IG 2.2.1)	61
Table 2. Evidence labels used throughout	6	Table 34. Latency expectations by interaction	61
Table 3. Key recommendations	9	Table 35. Technical step contracts (part 1: intake and requirements)	65
Table 4. Business drivers and evidence	10	Table 36. Technical step contracts (part 2: submission and closure)	66
Table 5. Proposed success measures	11	Table 37. FHIR resources and their role in the PA workflow	67
Table 6. Healthcare ecosystem actors	12	Table 38. API conventions	68
Table 7. Distinguishing provider, EHR, payer, HIE, clearinghouse, interoperability platform and patient portal	14	Table 39. API endpoint catalog (v1)	68
Table 8. Exchange directions with payers	15	Table 40. Connector cross-cutting behaviours	73
Table 9. Medblocks capabilities: documented vs inferred	16	Table 41. Regulatory and assurance baseline	74
Table 10. Medblocks developer and operational surfaces	23	Table 42. Security controls by domain	75
Table 11. Lessons and design consequences	24	Table 43. Compliance milestones	77
Table 12. Platform design principles	25	Table 44. AWS services and rationale	79
Table 13. Business capabilities and owners	27	Table 45. Development, staging and production environments	80
Table 14. Candidate product modules	27	Table 46. Recovery objectives (initial targets)	80
Table 15. Customer segments and value propositions	28	Table 47. Tenant isolation options	81
Table 16. Pricing model options	28	Table 48. Per-tenant isolation checklist	82
Table 17. Who is responsible for what (RACI summary)	28	Table 49. Reliability mechanisms	83
Table 18. Platform components	00	Table 50. Observability: key metrics and alerts	84
Table 19. Required standards and versions (baseline as of 30 Sep 2026)	33	Table 51. Admin console capabilities	85
Table 20. Architecture decision records (proposed)	34	Table 52. Test types, scope and tooling	86
Table 21. EHR integration modes used by the Platform	36	Table 53. Example failure scenarios and expected behaviour	87
Table 22. EHR integration comparison (public developer information, retrieved 30 Sep 2026)	36	Table 54. Build vs buy decisions by subsystem	88
Table 23. Exchange frameworks and networks	39	Table 55. MVP scope: MUST / SHOULD / LATER	90
Table 24. Payer integration considerations	40	Table 56. Roadmap phases 0–5	92
Table 25. SMART roles	43	Table 57. Roadmap phases 6–10	93
Table 26. FHIR server options compared	45	Table 58. Team requirements (FTE estimates)	94
Table 27. Entity catalog: identifiers, source of truth, PHI sensitivity and retention	48	Table 59. Risk register	95
Table 28. Terminologies relevant to prior authorization	52	Table 60. Effort model by stage	97
Table 29. Prior authorization workflow: steps and responsibilities	54	Table 61. Non-labor cost categories	97
Table 30. Decision outcomes	57	Table 62. Future-state capabilities and triggers	98
Table 31. CRD at a glance (IG 2.2.1)	59	Table 63. Internal quality-control checklist	101
Table 32. DTR at a glance (IG 2.2.0)	60	Table 64. Glossary	103

How to read this document

This blueprint is written for three audiences. Each audience can read a subset and still get a complete picture at its own level.

Table 1. Reading guide by audience

Audience	Question answered	Read first	Then
Level 1: Executive / business (CEO, CTO, board, client sponsors)	Why are we building this, and what will it take?	§2 Executive Summary, §3 Business Problem, §8 Vision	§9 Business Architecture, §28 MVP, §31 Risks, §32 Cost/Effort, §34 Conclusion
Level 2: Product / domain (product managers, business analysts, PA subject-matter experts, client operations)	How does prior authorization work, and where does the platform fit?	§4 Ecosystem, §16 PA Business Workflow, §17 CRD/DTR/PAS	§5–7 Medblocks, §12 Payer Connectivity, §25 Admin/Developer Platform, §29 Roadmap
Level 3: Engineering / architecture (architects, tech leads, security, SRE, integration engineers)	How do we actually build it?	§10 Technical Architecture, §18 PA Technical Workflow, §13 FHIR/SMART	§11, §14–15, §19–24, §26–27, §33

Evidence labels

Every important statement carries one of the labels below. Labels apply to the sentence or table cell they appear in. Where a paragraph mixes fact and recommendation, the fact is cited and the recommendation is labeled.

Table 2. Evidence labels used throughout

Label	Meaning
Verified	Confirmed against a cited primary source retrieved on 30 September 2026 (regulator, standards body, or the vendor's own documentation). Vendor documentation establishes what the vendor says; it is not independent certification.
Industry-standard	Widely accepted practice or a normative standard pattern (for example OAuth 2.0 authorization-code flow with PKCE). Cited where a specific source is relied on.
Recommended	Our architectural or product recommendation. It is a design choice, not a fact about any vendor or regulation.
Inferred	A reasoned inference from public information, for example that a vendor that performs background pulls must operate some kind of job scheduler. It is not a claim about how that vendor actually built it.
Needs validation	Plausible but not confirmed. It must be validated with the named party (EHR vendor, payer, partner, counsel) before it is relied on.
Estimate	A planning estimate with stated assumptions. It is not a quote or a commitment.
Proposed rule	A proposed rule or draft standard that is not in effect.
Historical	Superseded or historical information, kept only for context.

Scope and assumptions

Working assumptions (validate at kickoff)

1. **Market.** United States. The initial focus is **provider-side, medical-benefit prior authorization** (procedures, imaging, durable medical equipment, and drugs billed under the medical benefit). Pharmacy-benefit PA is covered for completeness and is a separate, later track.
2. **Role.** The platform acts on behalf of provider organizations as a **HIPAA business associate** under BAAs. A payer-side offering is a later option (§33).
3. **Relationship to Medblocks.** This is an independent design. It is not affiliated with, endorsed by, or derived from Medblocks' proprietary implementation. Medblocks is studied only through its public documentation.
4. **Cloud.** AWS is the reference cloud, used under an AWS BAA with HIPAA-eligible services only. The architecture is portable in principle.
5. **Evidence date.** All sources were retrieved on 30 September 2026. Regulatory dates reflect rules in effect on that date. Proposed rules are labeled **Proposed rule**.
6. **No testing performed.** This is desk research and design. No vendor sandbox, payer endpoint, conformance test, or load test was executed for this document.

2 Executive Summary

We propose to build a **healthcare interoperability platform** with capabilities comparable to Medblocks-style data-access platforms: connecting to EHRs, normalizing clinical data, and notifying downstream systems. On top of it we would add a **prior authorization (PA) engine** that carries a request from the moment a clinician signs an order to the moment the payer's decision is written back into the EHR.

1. What are we building?

A multi-tenant, API-first platform in two layers

Recommended:

- **Interoperability layer:** EHR and payer connections, SMART on FHIR, a FHIR R4 data platform, terminology, documents, events and webhooks, and audit.
- **Prior authorization layer:** a case engine that orchestrates the Da Vinci **CRD → DTR → PAS** workflow, with managed fallbacks (X12 278 via a clearinghouse, or a tracked portal task) for payers that are not ready.

2–3. Why does it exist, and what problem does it solve?

Prior authorization is still largely manual: phone, fax, and payer portals. CMS estimates that requesting prior authorizations takes providers an average of **13 hours per week**, about **\$34,000 a year** per provider^[25] **Verified**.

From **1 January 2027**, CMS-regulated payers must operate a FHIR Prior Authorization API^[24] **Verified**. Providers still need someone to connect their EHR workflows to many payers that implement those APIs unevenly.

4. How is it related to Medblocks?

Medblocks publicly documents a data-integration platform. Its core concepts are *sources*, *connections*, *pulls*, *exports*, *webhooks*, clinician-workflow embedding via SMART and CDS Hooks, and clinical domain models^[2,3,4] **Verified**.

Its public documentation does **not** describe a prior authorization product. Its September 2026 PA article is educational^[21] **Verified**.

We adopt the *functional pattern* and design our own implementation, then add the PA layer. The two are not affiliated.

5. How does it enable prior authorization?

- It pulls the patient's coverage and clinical evidence from the EHR (SMART / US Core).
- It discovers payer requirements (CRD) and renders the payer's documentation template with pre-filled answers (DTR).
- It submits a standards-based request (PAS Claim/\$submit) and tracks pended responses through subscriptions.
- It routes requests for more information back to staff, then writes the decision and authorization number back to the EHR **Recommended**.

6. Who uses it?

- **Primary users:** provider PA and revenue-cycle staff, and ordering clinicians (inside the EHR).
- **Customers:** provider groups and health systems, health-tech and RCM companies that embed our APIs, and prior-authorization vendors.
- **Later:** patients (status visibility) and payers (\$9)

Recommended.

7. What are the major components?

API gateway and identity; tenant and connection management; a pluggable connector framework (EHR, payer, clearinghouse, HIE); a FHIR repository (HAPI FHIR recommended); terminology service; document service; PA case engine with workflow orchestration; DTR app; PAS client; events and webhooks; audit; admin and developer portals (\$10)

Recommended.

8. What standards are required?

- **Core:** HL7 FHIR R4 (4.0.1), US Core, SMART App Launch 2.x (including Backend Services), OAuth 2.0 / OIDC, CDS Hooks.
- **Da Vinci:** CRD 2.2.1, DTR 2.2.0 and PAS 2.2.1 are the current published versions. CMS lists earlier versions as recommended, and ONC approved these for voluntary certification use from 29 Aug 2026^[48,51,53,64] **Verified**.
- **Supporting:** Subscriptions R5 Backport, CDex, and X12 278/275 for fallback.
- **Code sets:** SNOMED CT, LOINC, RxNorm, ICD-10-CM, CPT/HCPCS, NDC.

9. What is the MVP?

Medical-benefit PA only, with **Recommended**:

- Epic plus one other EHR, via SMART launch and US Core reads;
- one payer with a FHIR PA API (CRD/DTR/PAS) and one clearinghouse X12 278 route;
- our DTR app, PAS client, and case engine with work queue and SLA timers;
- documents, webhooks, audit, and an admin console.

Every other payer is a tracked manual task, with no silent gaps (§28).

10. What are the major risks?

1. **Payer readiness varies.** UnitedHealthcare labels its FHIR PA API "coming soon" and Blue Cross NC says "coming 2027", while trade press reports Epic's CRD live with three payers at four health systems^[83,84,116].
2. **EHR onboarding lead times.** EHR app registration, customer activation, and production access take time.
3. **EHR-native competition.** EHR vendors are building native CRD/DTR/PAS.
4. **Rules are still moving.** CMS-0062-P would change the HIPAA standards for PA, but it is only proposed^[26,27] **Proposed rule**.
5. **PHI security** and HIPAA minimum-necessary obligations. PA disclosures are "payment" activities, so the treatment exception does not apply^[93,94].
6. **Data quality and terminology gaps** that break automated pre-population.

The full register is in §31.

Key recommendations at a glance

Table 3. Key recommendations

#	Recommendation Recommended	Rationale
1	Position the product as a provider-side PA coordinator that complements EHR-native capability rather than competing with it.	Trade press reports Epic's native CRD live at four health systems ^[116] . The durable value is multi-payer orchestration, fallbacks, work-queue operations, analytics, and support for EHRs and payers without native support.
2	Build the PA engine, DTR app, connector framework, and case data model. Adopt open source for the FHIR server (HAPI FHIR). Partner for clearinghouse (X12) and HIE/TEFCA connectivity.	The differentiating logic sits in orchestration and workflow. The commodity layers are mature (§27).
3	Treat "PA not required" as a positive assertion that needs evidence, never as a default.	A false "not required" causes denials. CRD responses carry explicit coverage information ^[49] .
4	Enforce minimum necessary by construction: payer bundles are generated from the questionnaire's data requirements, not from the whole chart.	HIPAA's minimum-necessary standard applies to payment disclosures ^[93,94] .
5	Start with medical-benefit PA . Treat pharmacy ePA (NCPDP SCRIPT) as a separate track.	They use different standards, networks, and counterparties (§16). The Part D SCRIPT 2023011 date is 1 Jan 2028 ^[36] .
6	Plan a 12-month MVP and a 4-month production pilot, with a core team of about 12–13 dedicated FTE plus fractional specialists Estimate .	Onboarding lead times, not coding, are the critical path (§29, §32).

The consolidated recommended target architecture is shown in [Figure 32](#) (§34).

3 Business Problem

3.1 Prior authorization in plain terms

In plain terms

Before a health plan pays for certain treatments, such as an MRI, a knee arthroscopy, a specialty infusion, or a power wheelchair, it asks the doctor's office to prove the treatment is covered and medically necessary. That approval is called **prior authorization** (also "pre-authorization", "pre-certification", or "prior approval").

Each plan has its own list of services that need approval, its own forms and clinical criteria, and its own way of receiving requests. Office staff spend hours finding out whether approval is needed, gathering chart notes, filling in forms, faxing or uploading them, and chasing status. Patients wait in the meantime.

3.2 Why this is a problem now

Table 4. Business drivers and evidence

Driver	Evidence (as of 30 Sep 2026)	Label
Provider burden	CMS cites an average of 13 hours per week, about \$34,000 and 700 hours per provider per year ^[25] .	Verified
Federal mandate on payers	CMS-0057-F requires Medicare Advantage organizations, state Medicaid and CHIP fee-for-service programs, Medicaid managed care plans, CHIP managed care entities, and QHP issuers on the federally facilitated exchanges to implement a Prior Authorization API by 1 Jan 2027 . The operational provisions (decision timeframes, specific denial reasons) applied from 1 Jan 2026 ^[24] .	Verified
Decision timeframes	Impacted payers other than QHP issuers on the FFEs must decide within 72 hours for expedited requests and 7 calendar days for standard requests ^[24] . CMS-0062-P would extend comparable timeframes to QHP issuers on the FFEs and to drugs ^[26] .	Verified / Proposed rule
Provider-side incentive	CMS-0057-F adds an Electronic Prior Authorization measure for MIPS clinicians and hospitals starting with 2027 reporting ^[24] . Per CMS's overview page, the FY 2027 IPPS final rule makes the hospital measure an optional bonus in CY 2027 and mandatory from CY 2028 ^[25] .	Verified
Certified EHR capability	HTI-4 created certification criteria for CRD (§170.315(g)(31)), DTR ((g)(32)) and PAS ((g)(33)), plus CDS Hooks triggers and a Subscriptions client ^[63] . The 2026 SVAP lets developers use CRD 2.2.1, DTR 2.2.0 and PAS 2.2.1 from 29 Aug 2026 ^[64] .	Verified
Industry commitments	AHIP and BCBSA member plans made voluntary commitments (June 2025). Goals include standardized FHIR-based electronic PA and answering at least 80% of electronic PA approvals in real time by 1 Jan 2027. The AMA notes the commitments exclude pharmacy benefits ^[117] .	Verified (secondary source)
Uneven readiness	UnitedHealthcare describes a CRD/DTR/PAS Prior Authorization API as "Coming soon" ^[83] . Blue Cross NC lists Prior Authorization and Provider Access APIs as "Coming 2027" ^[84] . Trade press reports Epic's CRD API live at four health systems with UnitedHealthcare, Aetna and Network Health, with 16 payers in sandbox testing ^[116] .	Verified (payer pages); trade press Needs validation
Standards not settled for PA attachments	HHS finalized HIPAA claims-attachment standards (X12 275/277 v6020 plus the HL7 C-CDA and Attachments IG; compliance 26 May 2028). It explicitly did not finalize prior-authorization attachment standards ^[31] .	Verified

3.3 The gap this platform fills

The mandate falls on payers. Providers still face these gaps **Inferred** :

1. **Many payers, uneven APIs.** Each payer's endpoints, onboarding, trust registration, and supported versions differ. Some payers will support only part of CRD/DTR/PAS for some time.
2. **Many EHRs, uneven capability.** Some EHRs ship native CRD/DTR/PAS. Others will rely on third-party SMART apps or none at all. Practices on smaller EHRs are the least served.
3. **Operations, not just transactions.** Staff need work queues, deadline tracking, requests for more information, appeals, and reporting across all payers, including the ones still on portals and fax.
4. **Clinical data quality.** Automated questionnaire pre-population only works when coded data (diagnoses, labs, prior therapies) is present and normalized.

3.4 Success measures

Table 5. Proposed success measures

Measure	Definition	Pilot target Estimate
Electronic submission rate	Share of PA cases submitted via PAS or X12 278, not portal or fax	≥ 60% of cases for connected payers
Staff touch time per case	Minutes of human effort from order to submission	≥ 40% reduction against the site's measured baseline
Time to decision	Order signed → payer decision (median, P90)	Reported per payer. A baseline is set before any target.
First-pass completeness	Share of submissions with no additional-information request	Tracked from day one. No target until the baseline is known.
"Unknown requirement" rate	Share of orders where the requirement could not be determined electronically	Trending down per payer each quarter
Deadline breaches	Cases where internal SLA timers expired without action	0 unresolved

4 Healthcare Ecosystem

Before designing technology, we need a shared model of who the actors are, what each owns, and what each needs. Most integration failures come from confusing *who holds the data* with *who is allowed to act on it*.

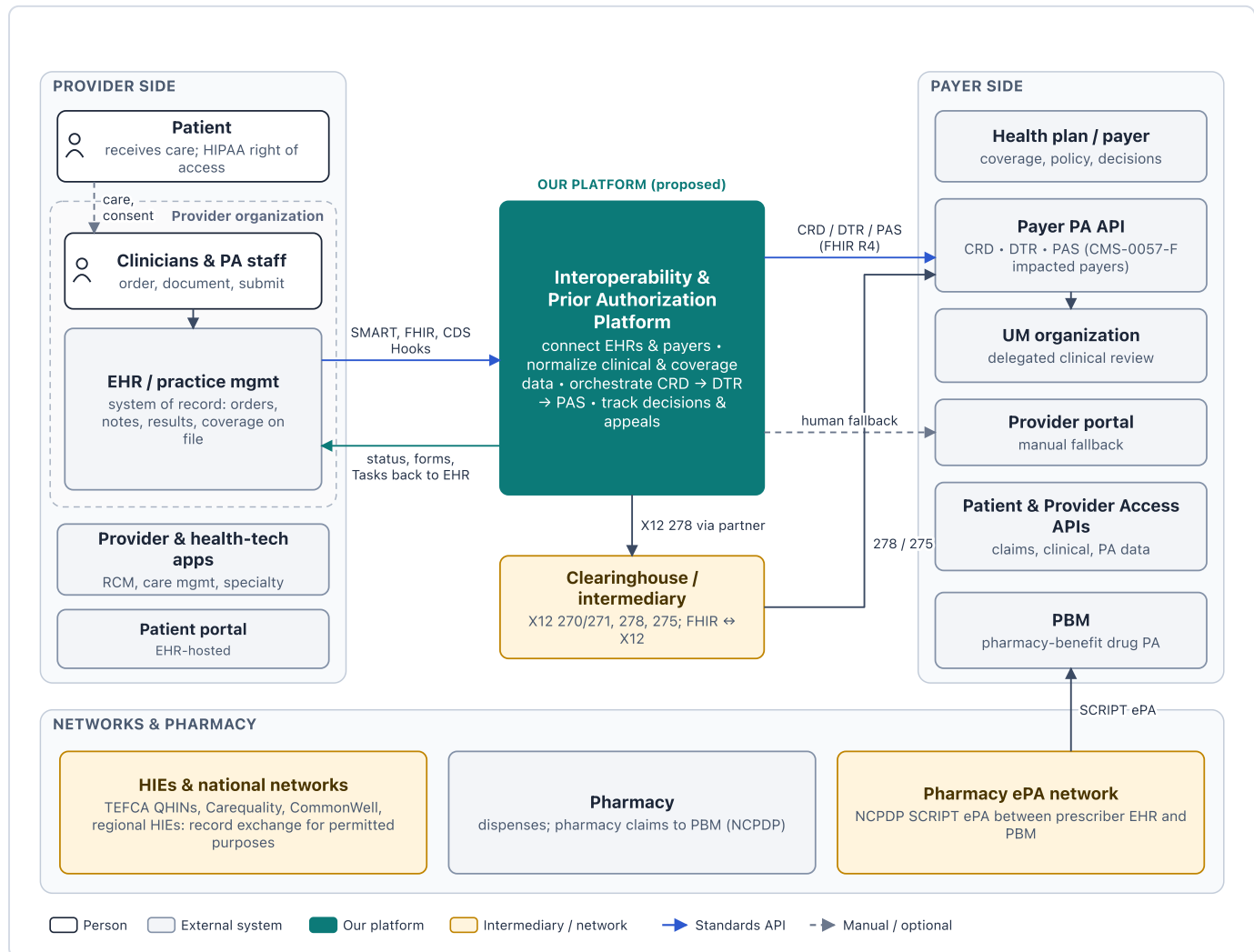


Figure 1. U.S. healthcare ecosystem relevant to prior authorization: who talks to whom (simplified; payer and provider organizations vary)

4.1 Actors, ownership and data needs

Table 6. Healthcare ecosystem actors

Actor	What it is / owns	Data it generates	Data it needs	Role in PA
Patient	The person receiving care. Has a HIPAA right of access to their own records.	History, symptoms, consent, preferences	Status of their authorization, out-of-pocket implications	Subject of the request. Rarely an active participant. May be asked for information.
Provider (organization)	Legal entity delivering care: hospital, clinic, physician group. Usually a HIPAA covered entity.	Orders, notes, results, claims	Coverage, PA requirements, decision, auth number	Requester. Responsible for requesting PA and supplying documentation.

Actor	What it is / owns	Data it generates	Data it needs	Role in PA
Clinician	Individual licensed professional (physician, NP, PA)	Orders, clinical rationale, attestations	Whether PA is needed at the point of ordering; alternatives	Ordering or rendering provider. Attests to medical necessity. Handles peer-to-peer and appeals.
Hospital / health system	Inpatient and outpatient facilities, often with centralized PA and financial-clearance teams	Encounters, admissions, procedures	Cross-payer work queues, deadline tracking	High-volume requester. Often runs a central PA unit.
Clinic / practice	Ambulatory site, often a smaller EHR and limited staff	Visits, referrals, orders	Simple, low-touch submission	Most burdened per FTE. Least served by native EHR tooling Inferred .
EHR vendor	Software company (Epic, Oracle Health, athenahealth, eClinicalWorks, MEDITECH ...)	Platform, APIs, app registration	App trust, conformance, customer demand	Gatekeeper of API access. Increasingly ships native CRD/DTR/PAS.
EHR (instance)	A specific provider's deployed EHR. The system of record for clinical data.	FHIR resources, HL7 v2 feeds, C-CDA documents	Status updates, completed forms, auth numbers	Source of evidence and target of write-back.
Payer / health plan	Insurer or government program that pays claims	Coverage, policies, decisions, claims	Complete, accurate PA requests	Decision-maker. Under CMS-0057-F, must expose a PA API if impacted ^[24] .
Insurance plan / product	A specific benefit design (e.g., an MA HMO plan) under a payer	Benefit rules, networks	Member and product identification	Determines which rules apply. The same payer can apply different rules per product.
Utilization management organization	Company delegated by a payer to perform clinical review (e.g., imaging, oncology, musculoskeletal)	Criteria, review outcomes	Clinical documentation	Often the actual reviewer. May operate its own portal or API Needs validation per payer.
HIE	Health information exchange: regional or national network that moves records between organizations	Record locator, document exchange	Identity matching, permitted purpose	Source of outside records as evidence (e.g., prior imaging elsewhere).
Clearinghouse	Intermediary that translates and routes administrative transactions (X12) between providers and payers. A HIPAA covered entity when it translates.	Transaction logs, acknowledgements	Payer routing, trading-partner agreements	X12 278 path. Some offer FHIR-to-X12 translation ^[86] Verified (vendor claim).
Pharmacy	Dispenses medications	Pharmacy claims, fills	Coverage, PA status for the drug	Pharmacy-benefit PA is often triggered at claim rejection.
PBM	Pharmacy benefit manager: administers drug benefits for plans	Formulary, drug PA criteria and decisions	Prescriber documentation	Decision-maker for pharmacy-benefit PA (NCPDP SCRIPT ePA).
PA platform	Software that orchestrates PA work (ours, EHR-native modules, standalone vendors)	Cases, audit, analytics	Clinical data, payer requirements	Coordinates the workflow on the provider's behalf.

Actor	What it is / owns	Data it generates	Data it needs	Role in PA
Interoperability platform	Software that connects systems and normalizes data (Medblocks-style)	Connections, normalized data, events	Authorized access to sources	Supplies data and connectivity to the PA platform. In our design it is the same product's lower layer.
FHIR server	A system that stores and serves FHIR resources via the FHIR REST API	Resources, versions, search	Profiles, terminology	Persistence for clinical and PA resources (ours); EHR and payer APIs (theirs).
Integration vendor	Company selling connectivity (interface engines, integration networks, API aggregators)	Interfaces, mappings	Customer contracts, EHR access	Possible partner or competitor for specific connections.
Patient portal	EHR- or payer-hosted website and app for patients	Patient messages, access logs	Results, visit data	The patient authorizes third-party apps here (SMART standalone launch). Not a PA channel.

4.2 Five roles that are often confused

Table 7. Distinguishing provider, EHR, payer, HIE, clearinghouse, interoperability platform and patient portal

Role	Is...	Is not...	Implication for us
Provider	The accountable party that requests PA and holds the treatment relationship	Its software. The provider can switch EHRs; the obligations stay.	Our customer and covered entity. We sign BAAs with providers.
EHR	The provider's system of record and the host for embedded apps	The decision-maker on access. The provider authorizes; the EHR enforces.	We need both the vendor's program (app registration) and each customer's activation.
Payer	The coverage and decision authority	A data source for clinical history (mostly claims)	A counterparty with its own onboarding and trust registration per API.
HIE	A network for exchanging records across organizations for permitted purposes	A PA submission channel	Optional evidence source. Access depends on purpose-of-use and participation agreements.
Clearinghouse	A transaction router and translator (X12)	A clinical data store or a decision-maker	Fallback route for X12 278 and eligibility. Contracted as a partner.
Interoperability platform	Connectivity plus normalization plus events across many systems	A system of record for clinical care	Our lower layer. It must preserve provenance back to the source.
Patient portal	The patient-facing surface of an EHR or payer	An integration endpoint for provider workflows	Relevant only for patient-mediated access (Medblocks' "patient access" pattern ^[4]).

4.3 Directions of exchange

Payer interactions are not symmetric. The same payer may expose different APIs, with different trust models, to different parties.

Table 8. Exchange directions with payers

Direction	Typical content	Standards / mechanism	Authorization basis
Provider → payer	PA requests, attachments, eligibility inquiries	PAS (FHIR), X12 278/275, 270/271, portals	Provider–payer relationship, trading-partner agreement, API registration
Payer → provider	Coverage requirements, questionnaires, decisions, member data	CRD responses, DTR packages, ClaimResponse, Provider Access API (Bulk FHIR) ^[24,28]	Attribution / treatment relationship; payer's API terms
Patient → payer	Patient pulls claims, clinical and PA data into an app	Patient Access API (SMART, OIDC, CARIN BB, PDex) ^[28] ; e.g., CMS Blue Button ^[35]	Patient's own authorization
EHR → payer	Hook calls, questionnaire retrieval, PAS submissions made by the EHR itself	CDS Hooks / CRD, DTR, PAS ^[48,51,53]	EHR–payer endpoint registration on the provider's behalf
Clearinghouse → payer	Translated X12 transactions	X12 278/275; FHIR at the front end for some intermediaries	Clearinghouse–payer contract; provider enrollment

5 What Medblocks Is

Evidence boundary for §5–§7

Everything labeled **Verified** in these sections comes from Medblocks' own public documentation or public repositories, retrieved 30 September 2026. Vendor documentation shows what Medblocks *states*. It is not an independent audit. Several documentation areas (Backend, Network, Clinician Workflow) are explicitly marked "work in progress" by Medblocks^[7,8,9].

Anything about how Medblocks is built internally is labeled **Inferred**. We make no claim about proprietary Medblocks internals.

5.1 What it is

Medblocks describes itself as "one integration for all healthcare data." It connects an application to EHRs, networks, patient portals and clinician workflows^[1] **Verified**. Its documentation says it is "built for product teams that need healthcare data access without becoming integration infrastructure teams"^[1] **Verified**.

The current product documentation centers on a product Medblocks calls **Medblocks Connect** in its billing documentation^[18] **Verified**. Separately, Medblocks has earlier "**Medblocks Stack**" / **Digital Health Platform** material describing an openEHR + FHIR + SMART + S3 architecture, and it originated the **openFHIR** mapping engine^[20,23] **Verified**. These are different offerings. The earlier stack material should not be read as a description of how Connect is built **Inferred**.

5.2 The problem it solves

- **Integration effort.** Teams avoid building and maintaining per-EHR OAuth, SMART, endpoint discovery, token refresh, rate limiting and vendor quirks. Medblocks states it manages these server-side^[3] **Verified**.
- **Data usability.** Records arrive in "clinical domain models" that normalize units and codes and preserve provenance back to the source record^[10] **Verified**.
- **Cost and packaging.** Medblocks positions direct connection to regulated APIs as an alternative to "renting access" through brokers. It claims this "typically costs 10-20x less than a traditional bundled integration"^[19]. That is a *vendor marketing claim* and was not verified here.

5.3 Target users and customers

The documented users are product and engineering teams at digital-health companies. They use an SDK, REST APIs, a dashboard, webhooks, and no-code, AI and MCP integration surfaces listed in the documentation navigation^[1] **Verified**. Customer segments beyond "product teams" are not enumerated in the pages reviewed. Any list of specific customer types would be **Inferred**.

5.4 Capabilities at a glance

Table 9. Medblocks capabilities: documented vs inferred

Capability	What is publicly documented	Status	Relevance to our PA platform
Source catalog	Catalog entries for Epic, Oracle Health, athenahealth, eClinicalWorks, Meditech, CMS Blue Button, payer APIs, networks and other systems. Entries carry optional metadata (display name, logo, portal URL, FHIR base URL, vendor type, setup requirements) ^[3] .	Verified	Same concept needed. Our catalog must also hold payer PA endpoints and capabilities.

Capability	What is publicly documented	Status	Relevance to our PA platform
Connections	The authorized link between a patient, organization or workflow and a source. States: <code>active</code> , <code>failed</code> , <code>refresh_failed</code> , <code>expired</code> , <code>disconnected</code> . Organizations may supply their own client credentials ^[3] .	Verified	Adopt the state model. Add payer-connection states (trust registration, endpoint health).
Integration patterns	Patient access (patient authorizes via portal); clinician workflow (CDS Hooks + SMART App Launch); backend (SMART Backend Services + FHIR Bulk Data); network (TEFCA and other exchange networks; requires permitted purpose) ^[4] .	Verified	PA mainly uses clinician workflow and backend . Patient access is secondary.
Hosted patient session	Server creates a patient session and receives a redirect URL. Medblocks hosts hospital search or accepts the customer's own picker, "completes the OAuth handshake", then pulls records in the background. Session states: <code>open</code> , <code>complete</code> , <code>expired</code> ^[5,6] .	Verified	Useful pattern for patient-mediated evidence (later phase).
Background pulls	Pulls start on session completion, admin action, or a scheduled/retry path. Access tokens are refreshed before expiry where possible. Failures include portal auth failed, retrieval error, token refresh failed and export failed. Pull history is visible per patient ^[12] .	Verified	Same operational model. PA adds on-demand, case-scoped evidence pulls.
Clinical domain models	Product-facing shapes on top of FHIR. Normalize units and codes. Preserve source identity, references, timestamps and supporting context for audit ^[10] .	Verified	Our normalization layer must also preserve provenance. PA evidence must be traceable.
Data out	<code>GET /patients/{id}/records</code> via SDK. Exports to a FHIR R4 server or NDJSON in S3-compatible storage, GCS or Azure Blob. Exports are configured in the dashboard, not the public REST API. Per-destination watermark; one destination can fail without blocking another ^[11] .	Verified	Export pattern is reusable. PA needs write-back to EHRs as well.
Webhooks	Events <code>patient_session.completed</code> , <code>connection.token_refresh_failed</code> , <code>records.sync.completed</code> , <code>records.sync.failed</code> . <code>Medblocks-Signature</code> verified over the raw body. Receivers must return 2xx within 5 seconds or Medblocks retries. Receivers must be idempotent because the same <code>event.id</code> may arrive more than once ^[13] .	Verified	Adopt the receiver contract. Add PA events (decision, pending, info requested, deadline at risk).
Workspaces and keys	Sandbox (<code>mb_sk_sbx_</code>) and production (<code>mb_sk_live_</code>) workspaces. Keys cannot cross environments. Keys are server-side secrets. Rotate by creating the replacement before revoking the old key ^[14] .	Verified	Adopt environment-scoped credentials and key prefixes.
Sandboxes	Vendor sandboxes (Epic, Cerner, athenahealth, eClinicalWorks, Meditech, CMS Blue Button). A "Seed 10 synthetic patients" (Synthea) option. Explicit caution that synthetic data does not indicate production coverage or quality ^[15] .	Verified	Same caution applies. Sandbox success does not predict production behaviour.
API surface	Groups: system (health), patients, connections (FHIR sources), patient sessions, webhooks, errors ^[16] .	Verified	Our API adds PA cases, documents, questionnaires, decisions.
Security and compliance	Public materials list HIPAA, SOC 2 Type II, ISO 27001 and GDPR. BAA support on commercial plans. Formal security packet on request ^[17] .	Verified (vendor statement)	We must earn equivalent attestations (§21).
Pricing	Free (\$0, up to 1,000 active patients) and Enterprise (\$60,000/year, uncapped; adds Backend Services, Clinical Workflows, OCR and data structuring). Metered by "active patient". HTTP 402 <code>billing_error</code> ^[18] .	Verified	A reference point for market packaging, not a benchmark for our costs.

Capability	What is publicly documented	Status	Relevance to our PA platform
Prior authorization	No PA product is described in the docs reviewed. Clinician Workflow docs contain no CRD/DTR/PAS content ^[9] . A 24 Sep 2026 article explains CRD/DTR/PAS and CMS-0057-F educationally ^[21] .	Verified (absence in reviewed docs)	The PA layer is ours to design. "Medblocks-like" applies to the interoperability layer only.
Internals (queues, stores, token vault, normalization engine)	Not documented.	Inferred	We design our own (§10).

5.5 Open-source components

- **openFHIR.** The original `medblocks/openFHIR` repository is archived; its last push was 5 Mar 2026^[22]. The successor `openFHIR/openfhir` is Apache-2.0. It implements the FHIRConnect specification for bidirectional openEHR↔FHIR mapping. Release 3.0.1 is dated 9 Sep 2026. It explicitly says the open-source version is "not intended for production use" because it lacks authentication, RBAC, terminology-server integration and performance optimizations^[23] **Verified**.
- **Medblocks Stack material.** It names HAPI FHIR JPA and Aidbox (FHIR), EHRbase and EHR Server (openEHR), and MinIO (object storage) as example implementations^[20] **Verified**.

Implication **Recommended**

openEHR and openFHIR matter only if our customers require openEHR persistence. For U.S. prior authorization, FHIR R4 with US Core and Da Vinci profiles is the required interchange model (§13). We therefore do not recommend adopting openEHR for the MVP.

6 Medblocks Publicly Documented Architecture

The diagrams below reconstruct Medblocks' architecture **only from public documentation**. Solid blue components are documented. Dashed components are logically necessary but undocumented, and are therefore inferred. None of this describes proprietary internals.

6.1 (A) Logical architecture

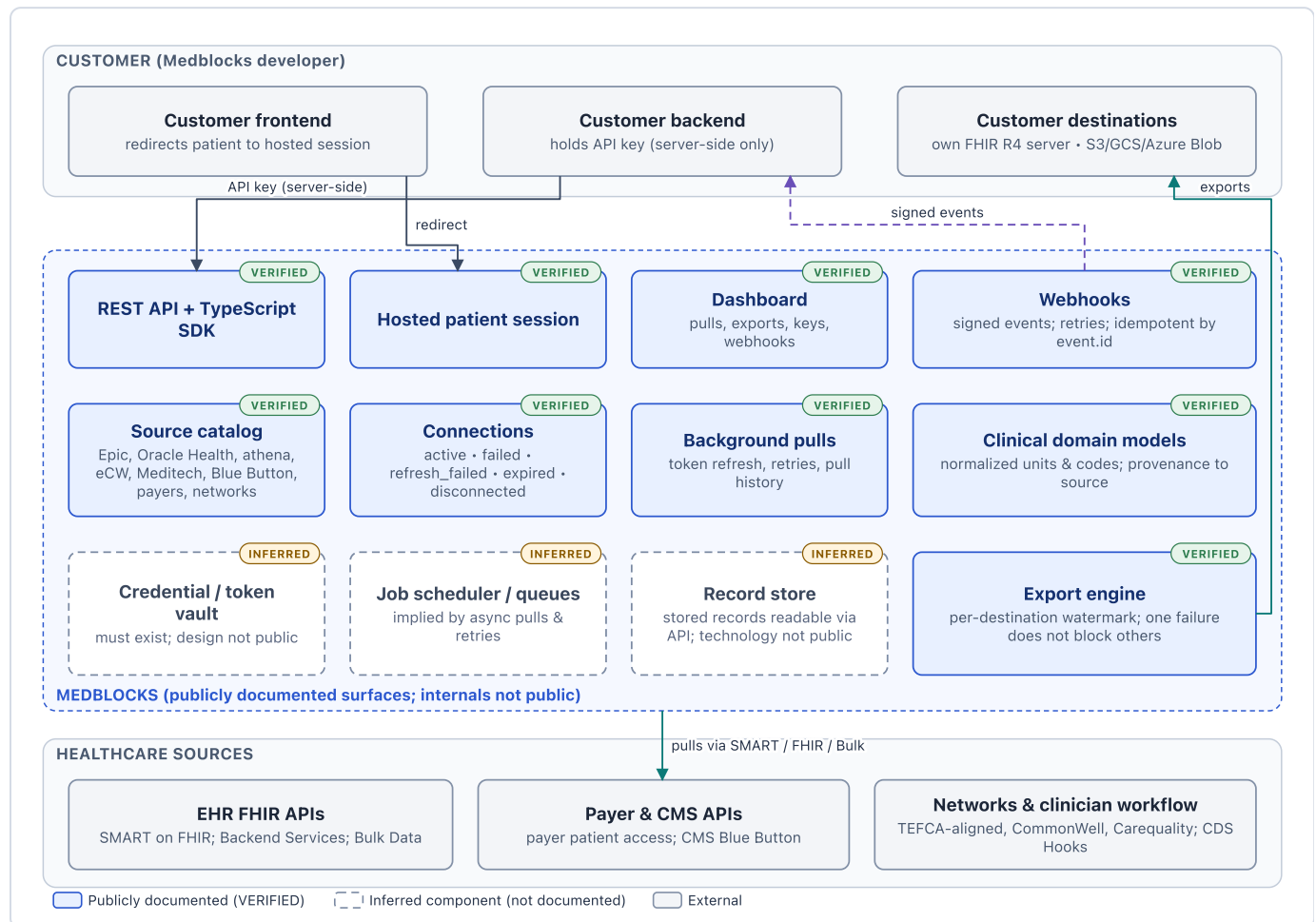


Figure 2. Medblocks logical architecture reconstructed from public docs (VERIFIED surfaces; INFERRED internals dashed) [2,3,11,13]

6.2 (B) Data flow

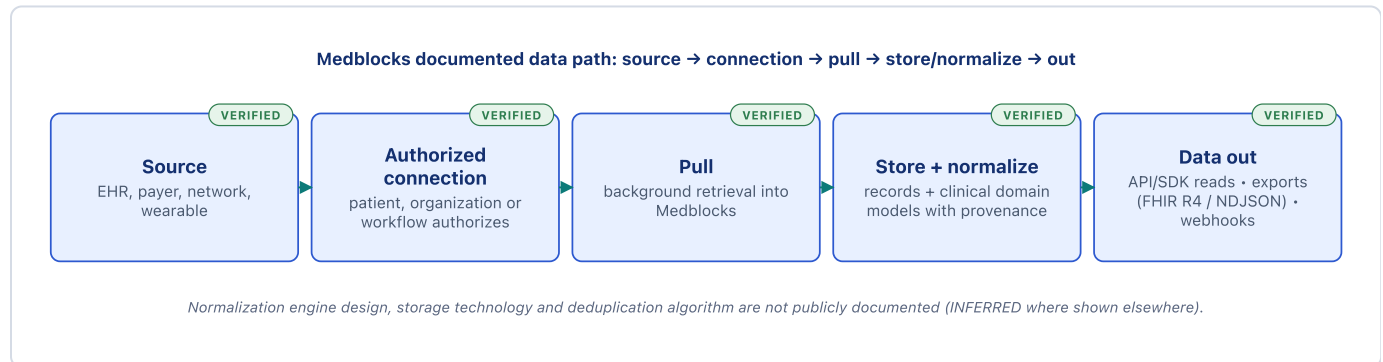


Figure 3. Medblocks documented data flow^[2,11]

Medblocks states it acts as "the integration layer between your product and the healthcare systems that hold patient data". It completes authorization, retrieves records in the background, and reports operational updates "through webhooks and dashboard history"^[2] **Verified**.

6.3 (C) Connection flow and states

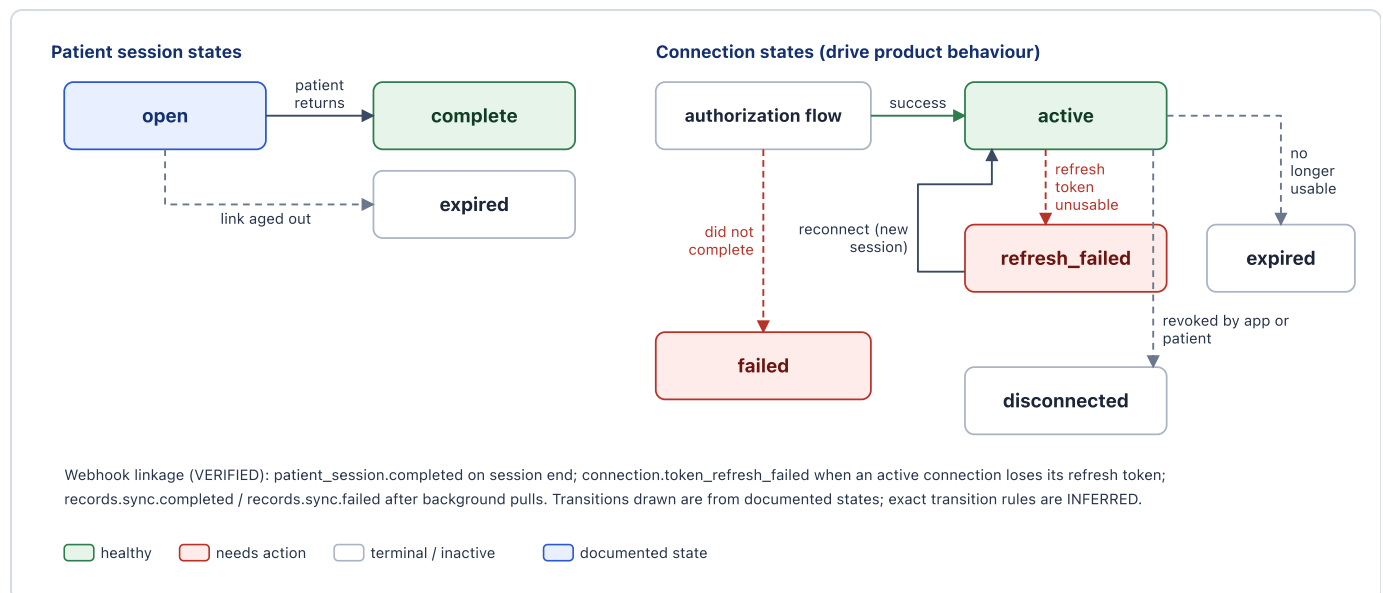


Figure 4. Medblocks patient-session and connection states. States are VERIFIED; transition rules are INFERRED^[3,6,13]

Medblocks advises: "Your app should act on connection state, not just on whether a browser flow finished"^[3] **Verified**. We adopt this principle. Every PA case must record which connection supplied its evidence and whether that connection was healthy at the time **Recommended**.

6.4 (D) Patient-access flow

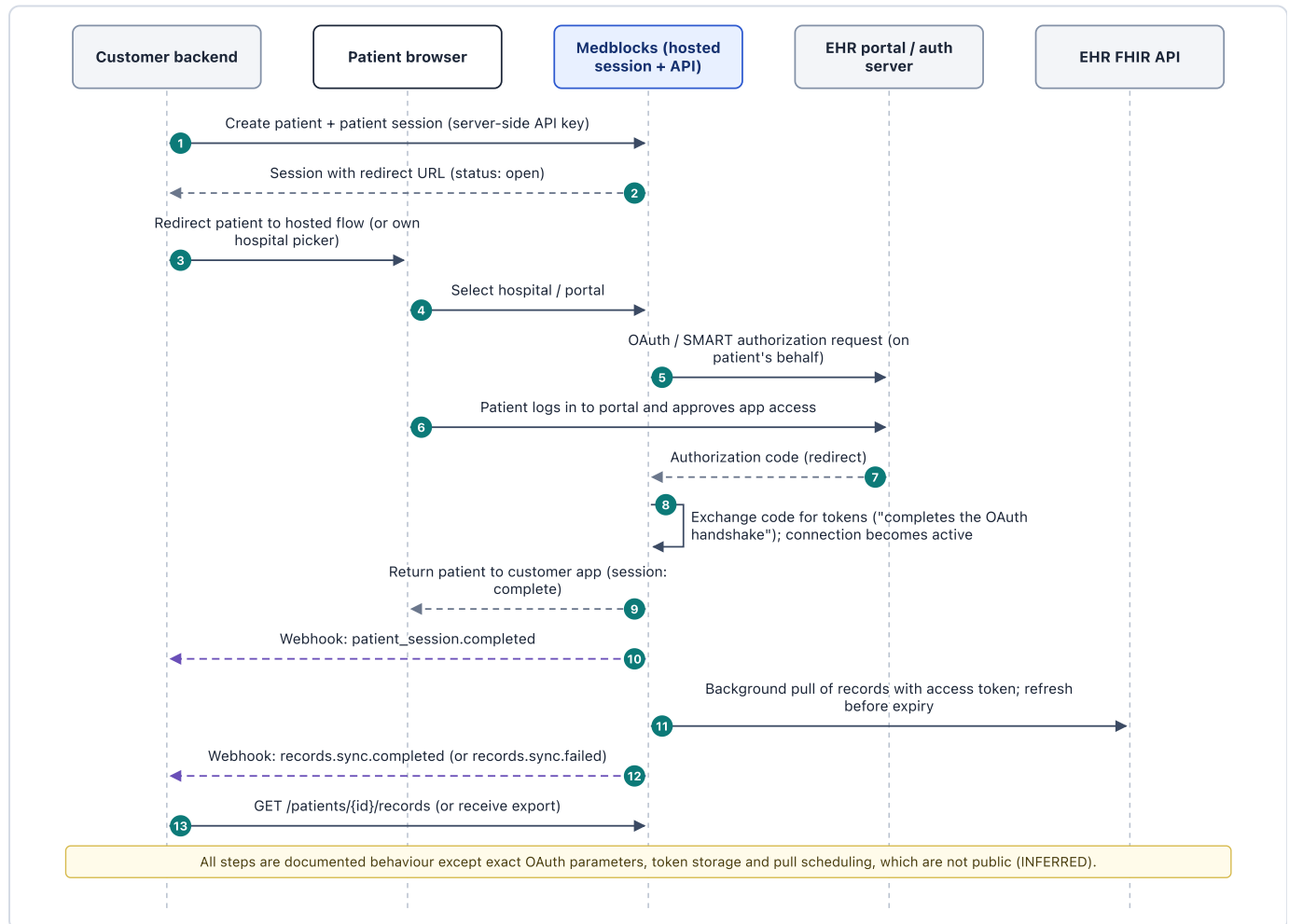


Figure 5. Medblocks patient-access sequence based on the patient-session documentation^[6,11,13]

6.5 (E) Backend / system-to-system flow

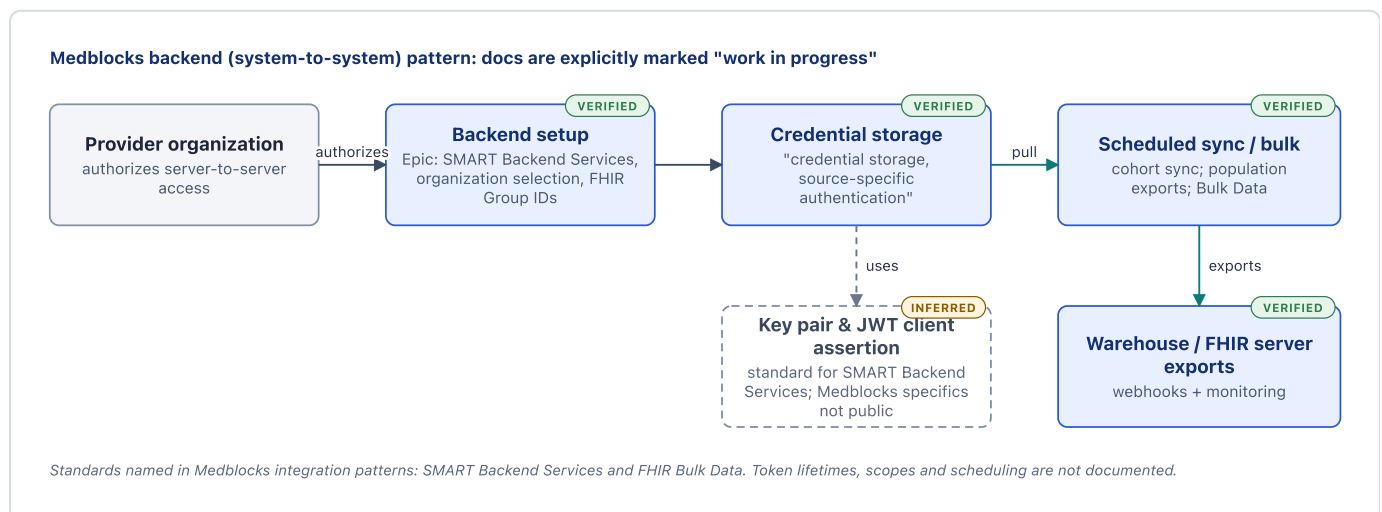


Figure 6. Medblocks backend pattern (docs marked work in progress)^[4,7]

For Epic, Medblocks states backend setup "centers on SMART Backend Services, organization selection, and FHIR Group IDs"^[7] **Verified**. That is consistent with the SMART Backend Services client-credentials pattern^[44]

Industry-standard. Key management and scheduling details are not public **Inferred**.

6.6 (F) Data ingestion flow

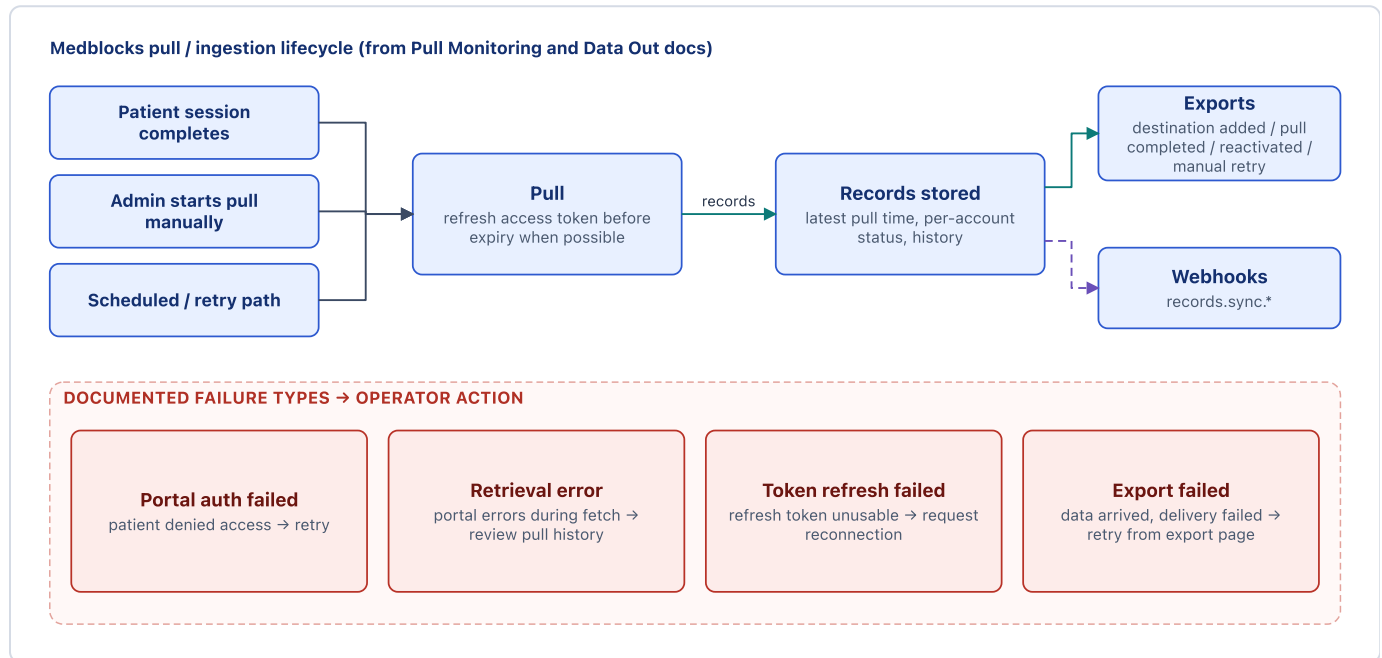


Figure 7. Medblocks pull lifecycle and documented failure types^[11,12]

6.7 (G) Event / webhook flow

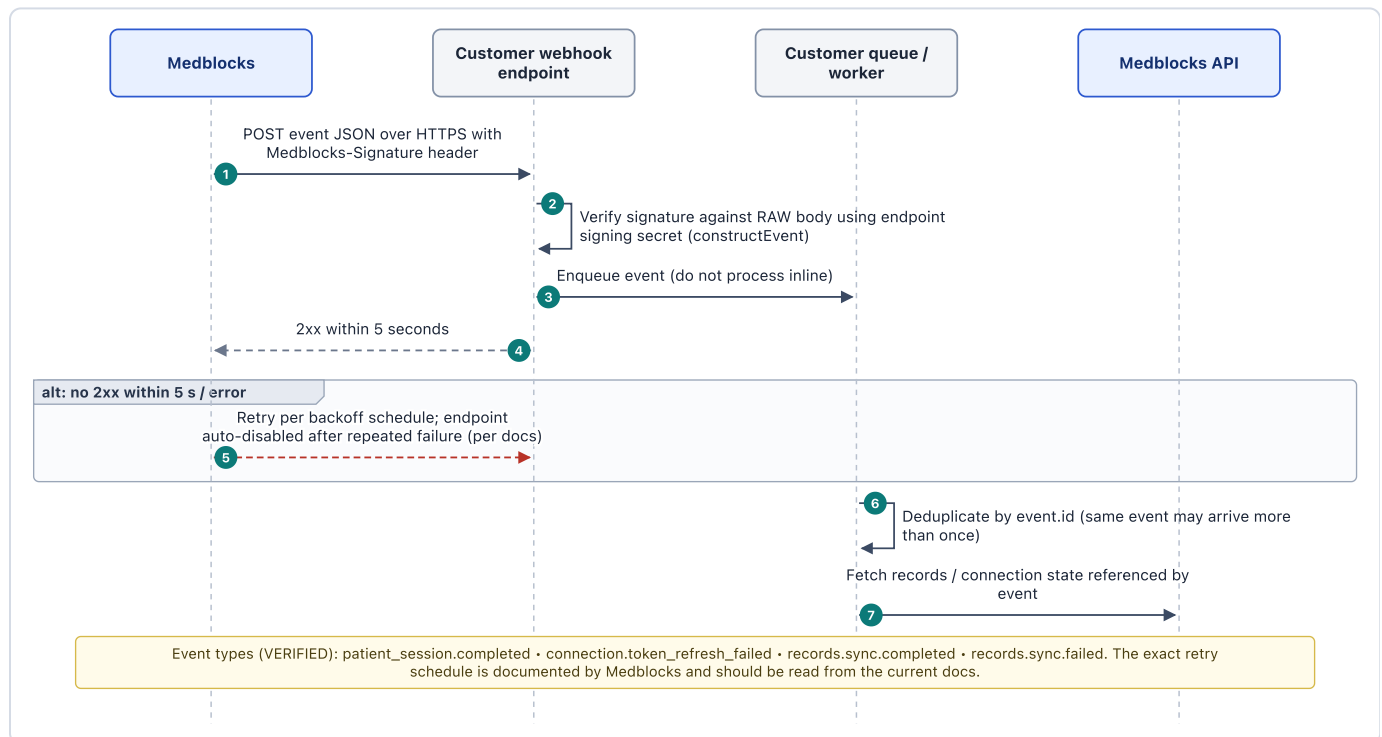


Figure 8. Medblocks webhook delivery contract^[13]

6.8 Developer experience and operating model

Table 10. Medblocks developer and operational surfaces

Surface	Documented behaviour	Status
SDK and REST	TypeScript SDK wraps REST (for example <code>mb.patients.records</code> → <code>GET /patients/{id}/records</code>) ^[11] .	Verified
Dashboard	Patient detail shows record status, latest pull time, per-account status and pull history. Export destinations and webhooks are managed here ^[11,12] .	Verified
Environments	Sandbox and production workspaces with separate keys and sources ^[14] .	Verified
Monitoring	Pull monitoring, auth event history, export page retries ^[1,12] .	Verified
Onboarding for networks	"Setup is usually a conversation rather than a purely self-serve toggle" ^[8] .	Verified
Operating model (people, support tiers, SLAs)	Not documented in pages reviewed.	Needs validation

7 Lessons from Medblocks

What we should copy (as patterns), what we must add, and where a PA platform differs fundamentally from a data-access platform.

Table 11. Lessons and design consequences

Observed pattern (source)	Why it matters	Our design consequence Recommended
Catalog / connection / pull / export as first-class concepts ^[2]	It separates "what exists" from "what is authorized" and from "what moved".	Keep the same four nouns, and add Case and Submission as the PA nouns.
Connection state machine including <code>refresh_failed</code> ^[3]	Token failures are the most common silent breakage.	Surface connection health on every PA case. Alert before a deadline is at risk.
Pattern-based access (patient / clinician / backend / network) tied to real relationships ^[4]	The legal basis for access differs by pattern.	Record purpose-of-use and authorizing party on every grant. PA is a "payment" purpose under HIPAA ^[93] .
Customer-supplied credentials supported ^[3]	Health systems want direct relationships and their own branding.	Support "bring your own client ID" per tenant for EHRs and payers.
Webhook contract: signature over raw body, 5 s acknowledgment, idempotency ^[13]	It is industry-standard and reduces customer integration bugs.	Adopt it, and add replay and a delivery log API (§19).
Exports independent per destination with watermarks ^[11]	One failing consumer does not block the others.	Apply the same pattern to EHR write-back and customer webhooks.
Provenance preserved in normalized models ^[10]	Payer reviewers and auditors need to trace evidence to its source.	Every answer in a QuestionnaireResponse links to source resources (Provenance / <code>information-origin</code> per DTR ^[52]).
Explicit caution that sandbox ≠ production ^[15]	Integration plans fail when sandbox success is treated as readiness.	Maintain a readiness level per connector and payer (sandbox → pilot → production), with its own evidence.
WIP docs for backend and network patterns ^[7,8]	Even a focused vendor finds these patterns hard to productize.	Treat backend and network access as partner-assisted onboarding, not self-serve, in the first year.

Where PA differs from a data-access platform

- **Bidirectional and stateful.** Data access is mostly read-and-deliver. PA is a long-running, multi-party case: states, deadlines, requests for more information, appeals, and write-back into the EHR Industry-standard.
- **Payer counterparties.** Each payer is a separately onboarded API partner, with trust registration (for example, DTR requires payers to authenticate DTR apps via SMART Backend Services)^[52] Verified.
- **Latency budgets.** CRD servers must respond within 5 seconds (10 seconds for certain hooks) 90% of the time^[50]. PAS aims for a response within 15 seconds or returns a pended response^[54] Verified. Background-pull architectures cannot meet these on their own. A synchronous path is required.
- **Minimum necessary.** Delivering "all records" is appropriate for many data-access use cases. A payer PA disclosure must be limited to what is needed for the purpose^[94] Verified.
- **Accountability for correctness.** Wrong data in a dashboard is a defect. A wrong "no PA needed" becomes a denied claim and a patient bill Inferred.

8 Proposed Platform Vision

Working name: **Healthcare Interoperability & Prior Authorization Platform** ("the Platform"). The name is temporary and not final.

Vision statement Recommended

Every order that needs payer approval is detected at the moment it is placed. It is documented once, from data already in the chart. It is submitted through the best available standard channel, tracked to a decision without anyone phoning a payer, and closed back in the EHR with a complete audit trail.

8.1 Design principles Recommended

Table 12. Platform design principles

Principle	What it means in practice
Standards first, fallbacks always	Use CRD/DTR/PAS where the payer supports them. Otherwise route to X12 278 via a partner or to a tracked portal task. Never silently drop a case.
The EHR remains the system of record	We keep case state and evidence references. Clinical truth stays in the EHR, and final artifacts (QuestionnaireResponse, status, auth number) are written back.
Complement native EHR capability	Where the EHR already calls payer CRD or hosts DTR, consume those results rather than duplicate them.
Minimum necessary by construction	Payer-bound data is derived from payer-declared requirements, not the full chart ^[94] .
Human in the loop for clinical judgment	The platform pre-fills and routes. Clinicians attest. Payers decide. No automated medical-necessity determinations.
Everything is an event	Every state change is an immutable, auditable, webhook-able event.
Tenant isolation is a feature	Isolation tiers (pooled, siloed, dedicated) are productized (§23).
Connectors are plugins	Vendor-specific behaviour lives only in connectors. The core never branches on vendor name (§20).

8.2 System context

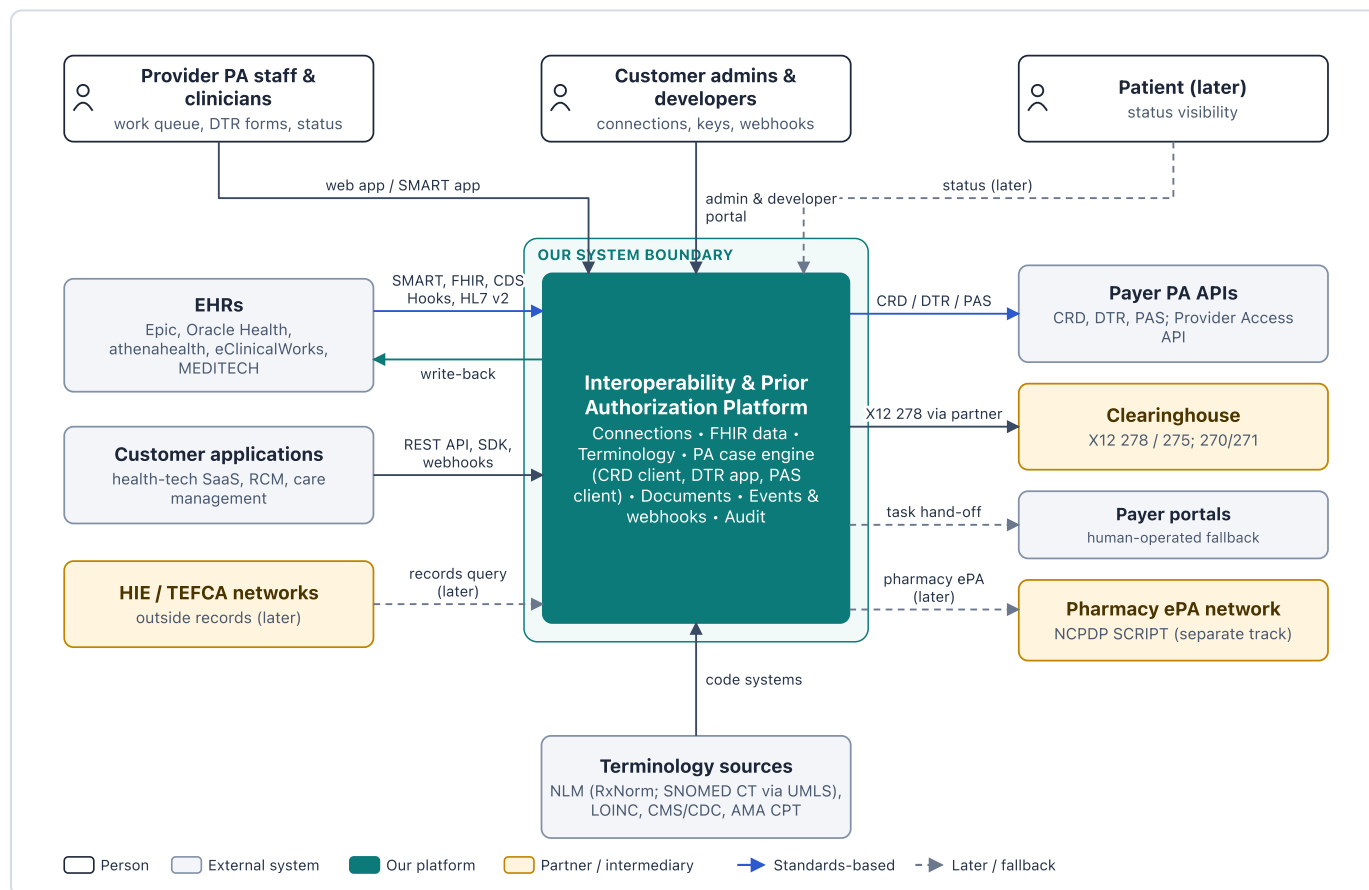


Figure 9. Diagram 1: System context. Who and what the Platform interacts with

8.3 Scope boundaries

In scope (target)

- Provider-side medical-benefit PA across payers
- EHR connectivity via SMART, FHIR and CDS Hooks; HL7 v2 where needed
- Clinical and coverage data normalization for PA evidence
- CRD client or router, DTR app, PAS client, subscriptions, CDex attachments
- X12 278 via a clearinghouse partner
- Work queues, SLA tracking, appeals tracking, analytics
- Developer APIs, SDKs, webhooks; admin console

Out of scope (initially)

- Making clinical coverage determinations (payer role)
- Acting as a payer's PA API (possible later, §33)
- Pharmacy-benefit ePA (NCPDP SCRIPT), until a later phase
- Claims submission and billing
- Consumer health-record aggregation as a product
- Autonomous AI determinations of any kind

9 Target Business Architecture

9.1 Business capability map

Table 13. Business capabilities and owners

Capability	Description	Primary user / owner
Coverage & requirement discovery	Identify active coverage and whether PA is required for an order, and why	Ordering clinician, PA staff
Documentation assembly	Collect payer-required clinical information and documents, pre-filled from the chart	Clinician (attests), PA staff
Submission & tracking	Submit through the best channel; track pended, more-info and decision states against deadlines	PA staff
Additional information & appeals	Respond to payer information requests; manage appeals and peer-to-peer scheduling	PA staff, clinician
Decision distribution	Write back to the EHR; notify scheduling, clinicians and patients	Platform (automated)
Connectivity management	Onboard EHRs, payers and partners; monitor connection health	Customer admin, our integration ops
Payer policy intelligence	Maintain versioned knowledge of payer PA lists and documentation requirements where no CRD exists	Our content team Recommended
Analytics & reporting	Turnaround, denial reasons, first-pass rates, payer performance, staff productivity	Revenue-cycle leadership
Developer platform	APIs, SDKs, sandbox, webhooks for partners embedding PA	Partner developers
Trust & compliance	BAAs, audits, access reviews, incident response, attestations	Our security and compliance team

9.2 Product structure **Recommended**

Table 14. Candidate product modules

#	Module	What the customer gets	Stage
1	Interoperability Platform	Connections, catalog, events, audit: the foundation for everything else	MVP (internal foundation)
2	EHR Connectivity	Certified-EHR connections via SMART, FHIR and CDS Hooks, with connection health	MVP (2 EHRs)
3	Payer Connectivity	Onboarded payer PA APIs plus clearinghouse route, with capability registry	MVP (1 payer + 1 partner)
4	FHIR Platform	Tenant-scoped FHIR R4 API over normalized data (read), with SMART	Pilot
5	Prior Authorization Platform	Case engine, DTR app, PAS client, work queue, SLA timers	MVP (core product)
6	Clinical Data Platform	Normalized longitudinal data with provenance for other use cases	Later
7	Workflow Automation	Rules-based routing, auto-assignment, templated responses, appeal packets	Production
8	Developer APIs / SDK	REST APIs, TypeScript and Python SDKs, sandbox with synthetic data	Pilot
9	Admin Console	Tenant, user, connection, payer and webhook management; audit viewer	MVP (basic)
10	Analytics	Operational dashboards and exports (de-identified or tenant-scoped)	Production

9.3 Target customers

Table 15. Customer segments and value propositions

Segment	Pain today Inferred	Value proposition Recommended	Priority
Specialty provider groups (imaging, oncology, orthopedics, cardiology)	High PA volume; limited IT; EHRs with less native ePA	Turnkey multi-payer PA workspace embedded in their EHR	High (design partner)
Hospitals / health systems	Central PA teams juggle portals; native EHR ePA covers only some payers	Cross-payer orchestration, fallbacks, analytics, complementing EHR-native CRD	High (pilot)
Revenue-cycle management companies	Operate PA as a service across many clients and EHRs	One API across EHRs and payers; multi-client work queues	High (channel)
Health-tech / care-management SaaS	Need PA inside their product without building integrations	Embedded PA APIs and SDK, white-label DTR	Medium
Prior-authorization vendors	Need FHIR/Da Vinci plumbing and EHR connectivity	Connectivity and PAS/DTR infrastructure as a service	Medium (partner or competitor)
Payer organizations	Must operate PA APIs; need provider adoption	Later: provider-adoption tooling, or a payer-side CRD/DTR/PAS service	Later

9.4 Pricing models (high level)

No Medblocks pricing is implied. The only Medblocks pricing referenced is its own published plan structure^[18]. Options

Recommended:

Table 16. Pricing model options

Model	Fits	Risk
Platform subscription (tiered)	Health systems, predictable budgets	Under-monetizes high-volume users
Per connection (EHR instance / payer)	Integration-heavy customers	Discourages adding payers, which reduces value
Per active patient	Data-access use cases (the Medblocks model ^[18])	Poor proxy for PA workload
Per transaction / API call	Developers, RCM partners	Revenue volatility; may penalize retries
Per authorization case	Directly aligned with value delivered	Needs a clear definition of a "case" (updates, appeals)
Enterprise contract	Large IDNs, payers, dedicated deployments	Long sales cycles; custom terms

Recommended starting point **Recommended**: a platform fee (covering connections and tenancy tier) plus per-case pricing with volume bands. Enterprise contracts cover dedicated deployments. Validate with design partners before publishing prices **Needs validation**.

9.5 Operating model and responsibilities

Table 17. Who is responsible for what (RACI summary)

Activity	Provider customer	Our company	EHR vendor	Payer	Partner (clearinghouse / HIE)
BAA and data-use terms	A	R	–	–	R (sub-BAA)
EHR app activation per site	A	R	C	–	–
Payer API registration and trust	C	R	–	A	–
Clinical attestation of submitted content	A/R	–	–	–	–

Activity	Provider customer	Our company	EHR vendor	Payer	Partner (clearinghouse / HIE)
PA decision	–	–	–	A/R	–
Platform security and availability	I	A/R	–	–	C
X12 transaction translation	–	C	–	C	A/R
Payer policy content where no CRD	C	A/R	–	C (source)	–

R = responsible, A = accountable, C = consulted, I = informed.

10 Target Technical Architecture

A layered, event-driven architecture. The interoperability layer (Medblocks-like capabilities) sits underneath a PA engine. We recommend starting as a **modular monolith plus workers** and splitting services only where scaling or isolation requires it **Recommended**.

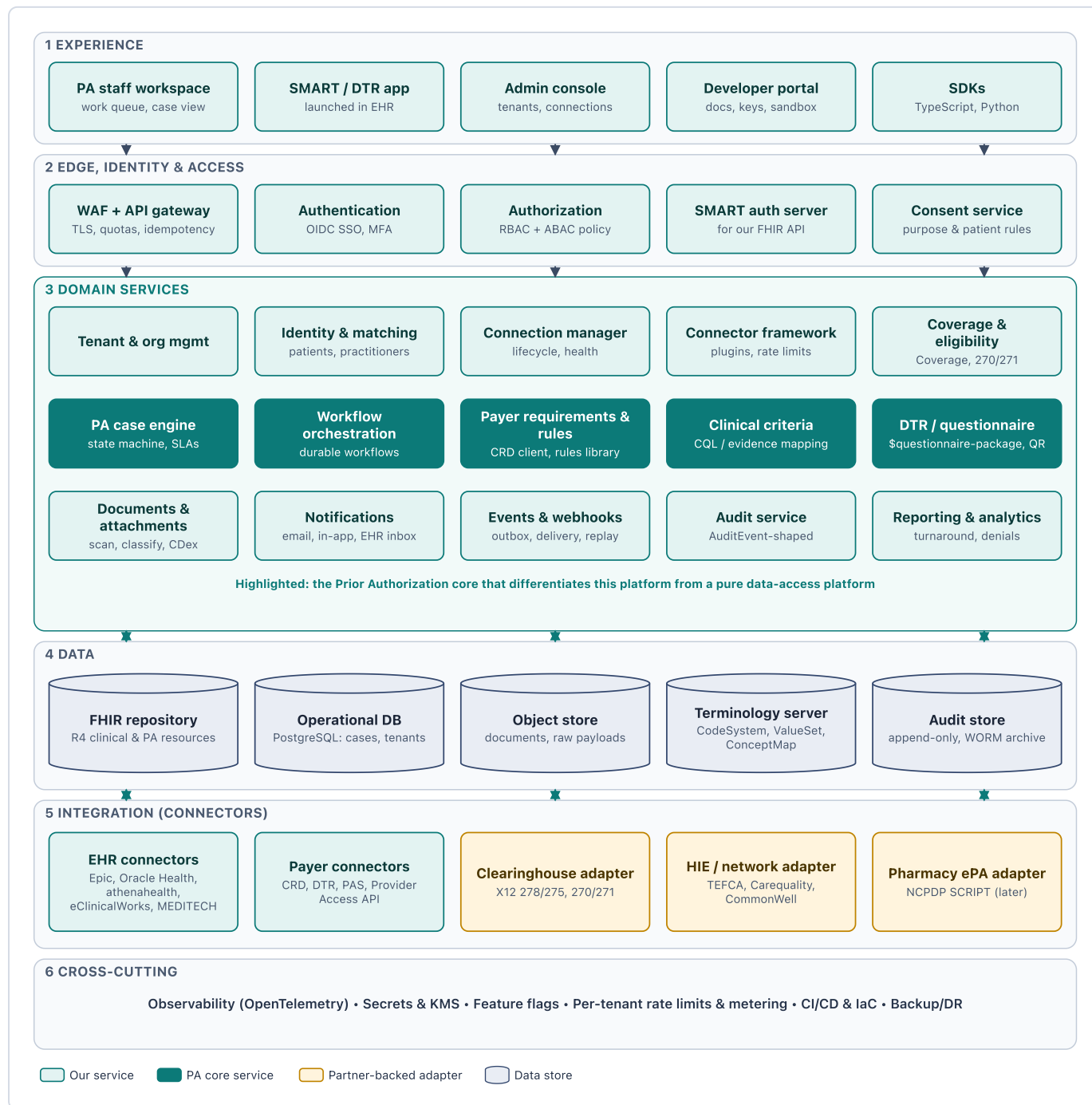


Figure 10. Diagram 2: Logical architecture

10.1 Component inventory

All 38 components requested in the brief are covered below. "Approach" refers to the build-versus-buy analysis in §27.

Table 18. Platform components

#	Component	Responsibility	Key design notes	Approach
			Recommended	
1	API Gateway	TLS termination, routing, authentication offload, quotas, request size limits, idempotency-key enforcement	Managed gateway + WAF; per-tenant usage plans	Buy (cloud)
2	Authentication service	Workforce and customer user login (OIDC/SAML), MFA, machine clients	Managed IdP; no home-grown password storage	Buy
3	Authorization service	Policy decisions (RBAC + ABAC): tenant, org, role, purpose-of-use, patient compartment	Central PDP with policy-as-code; enforcement in gateway and services	Build on OSS engine
4	Tenant management	Tenant lifecycle, isolation tier, region, feature flags, limits	Control plane, no PHI	Build
5	Organization management	Org hierarchy (system → facility → department), NPIs/TINs, payer enrollments	Maps to FHIR Organization/Location	Build
6	Provider identity	Practitioner records, NPI validation, role in org, EHR user mapping	NPI as anchor; FHIR Practitioner/PractitionerRole	Build
7	Patient identity	Patient records per tenant; cross-source matching; member IDs	Deterministic first (MRN + source), probabilistic later; confidence scores; human review queue	Build; buy MPI later
8	Connection management	Connection lifecycle, credentials references, health, state machine	States modeled on Medblocks' documented set plus payer states	Build
9	Connector framework	Plugin SPI, auth adapters, rate limiting, paging, retries, error translation	§20	Build
10	EHR connectors	Vendor-specific SMART/FHIR/CDS Hooks/HL7 v2 behaviour	One plugin per vendor plus a generic SMART connector	Build
11	Payer connectors	CRD, DTR, PAS, subscriptions, CDex; Provider Access API later	Capability registry per payer and product line	Build
12	HIE / network connectors	Record location and retrieval via HIE or TECCA participation	Via partner or sub-participant arrangement	Partner
13	SMART on FHIR	(a) Client of EHR authorization servers; (b) our own SMART authorization server for our FHIR API	Certified OIDC library; PKCE; private_key_jwt	OSS + build
14	OAuth 2.0	Client-credentials for partners, token lifecycle, introspection, revocation	Follow RFC 9700 BCP ^[71]	Buy / OSS
15	FHIR server	Persistence and FHIR REST for clinical and PA resources; validation; subscriptions	HAPI FHIR JPA on PostgreSQL (§13)	Open source
16	Canonical data model	FHIR R4 + US Core + Da Vinci profiles as the canonical clinical model; relational model for operations	No proprietary clinical model in the MVP	Build (profiles)
17	Mapping / normalization engine	Source-to-canonical mapping, unit conversion (UCUM), code mapping, deduplication	Versioned mappings; FHIR Mapping Language or code; test fixtures per source	Build
18	Terminology service	Code validation, ValueSet expansion, ConceptMap translation	FHIR terminology operations ^[59] (§15)	OSS / buy
19	Document service	Upload, virus scan, type detection, rendering, DocumentReference creation, retention	S3 + scanning; hash and store content once	Build on cloud
20	Prior Authorization engine	Case lifecycle, submissions, versions, decisions, deadlines	Explicit state machine (§18)	Build (core IP)
21	Workflow / orchestration engine	Durable long-running workflows, timers, retries, human tasks	Temporal (OSS or cloud) or AWS Step Functions	OSS / buy
22	Rules engine	Routing rules (payer channel, assignment), tenant rules, payer policy lookup	Data-driven rules in versioned tables; avoid opaque rule engines early	Build

#	Component	Responsibility	Key design notes	Approach
			Recommended	
23	Clinical criteria engine	Execute CQL from DTR packages; evaluate evidence completeness	OSS CQL engine; payer-supplied logic only (we do not author medical-necessity criteria)	OSS
24	Questionnaire / DTR handling	\$questionnaire-package, rendering, adaptive \$next-question, QR storage and write-back	SMART app; multi-payer ^[52]	Build (OSS renderer)
25	Attachment handling	Link documents to PA items; CDex \$submit-attachment; X12 275 via partner	LOINC-typed attachments	Build
26	Claims / coverage data	Coverage resources, eligibility (270/271 via partner), payer Provider Access data later	Coverage is required input to CRD/DTR/PAS	Build + partner
27	Queue / job system	Work queues, delayed jobs, DLQs, fair scheduling per tenant	SQS + outbox pattern	Buy (cloud)
28	Webhook / event system	Domain events, subscriptions, signed delivery, replay	Outbox → bus → dispatcher	Build on cloud
29	Notification system	Email, in-app, EHR inbox messages (Communication/Task), paging for ops	Templated; no PHI in email bodies	Build + buy email
30	Audit service	Append-only record of access and changes, including who, what, which patient, purpose and outcome	FHIR AuditEvent-shaped; hash-chained; WORM archive	Build
31	Consent service	Consent and restriction records (e.g., Part 2 data, patient restrictions), enforced at evidence selection	FHIR Consent; policy integration	Build
32	Security service	Key management, secrets, signing (JWT assertions), token vault	KMS + Secrets Manager; HSM-backed keys where feasible	Buy (cloud)
33	Observability	Traces, metrics, logs with PHI redaction	OpenTelemetry; BAA-covered backend	OSS + buy
34	Monitoring	SLOs, synthetic probes per connector and payer, alerting, on-call	Per-connector health checks (§24)	Buy + build
35	Admin portal	Tenants, users, connections, payers, webhooks, audit viewer, DLQ triage	Role-restricted; break-glass audited	Build
36	Developer portal	Docs, API keys and clients, sandbox, webhook tester, changelog	OpenAPI-generated reference	Build + OSS
37	SDKs	TypeScript and Python clients, webhook verification helpers	Generated from OpenAPI plus hand-written helpers	Build
38	Data warehouse / analytics	Operational analytics; de-identified or limited data sets	Separate account; de-identification pipeline; no PHI by default	Buy (cloud)

10.2 Physical / deployment view

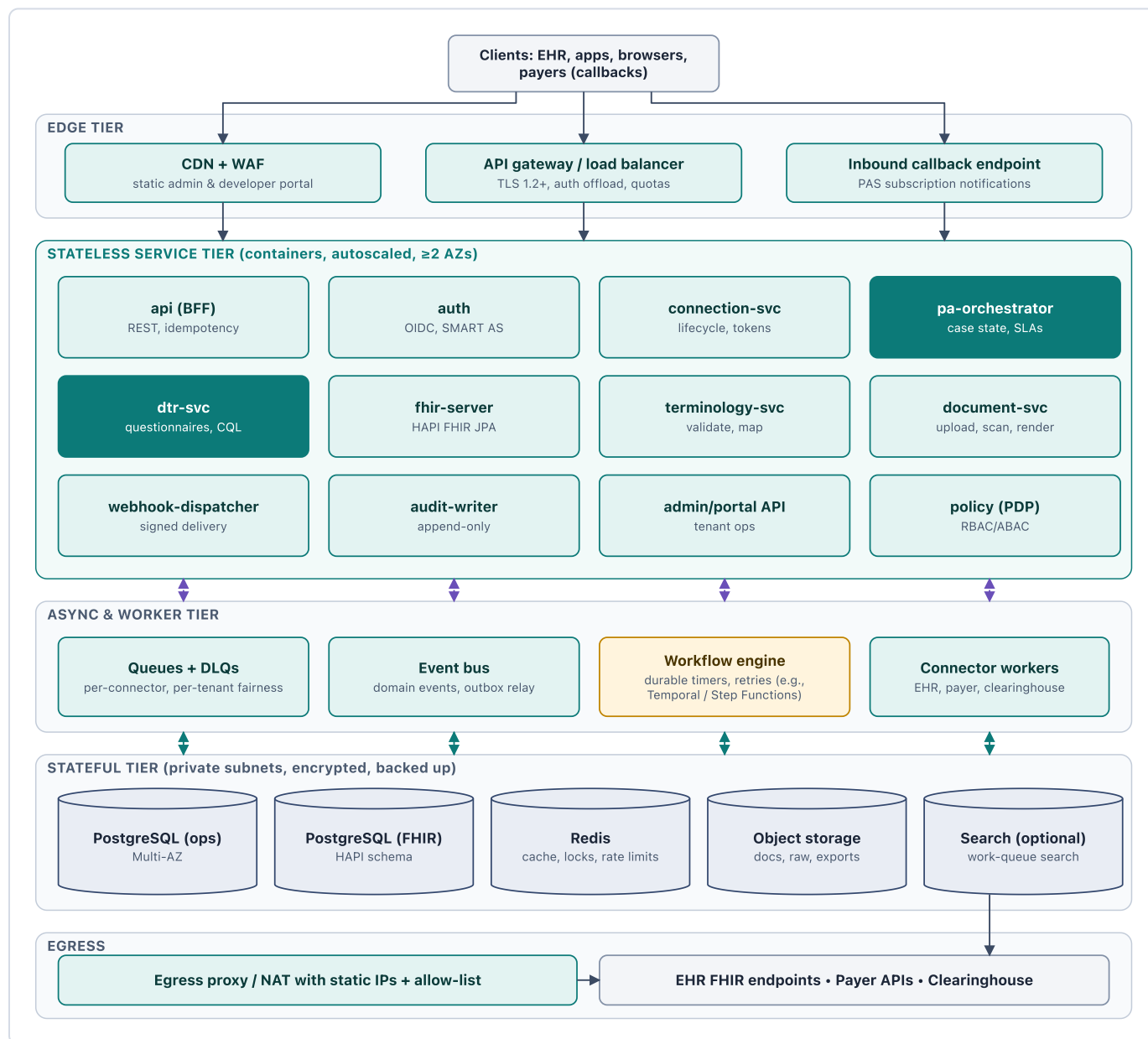


Figure 11. Diagram 3: Physical / deployment architecture (technology-neutral runtime tiers)

10.3 Required standards

Table 19. Required standards and versions (baseline as of 30 Sep 2026)

Standard	Version baseline	Use in platform	Label
HL7 FHIR	R4 (4.0.1) ^[41] . R5 published 2023; R6 still in ballot/draft ^[40]	Canonical clinical and PA resource model; all Da Vinci IGs are R4 ^[48,51,53]	Verified
US Core	Negotiate per EHR (commonly 3.1.1 / 6.1.0 in CMS rules). The current published version is 9.0.0; 9.0.0 is in the 2026 SVAP ^[28,42,64]	Profiles for EHR reads; validation	Verified

Standard	Version baseline	Use in platform	Label
USCDI	v6 approved in 2026 SVAP ^[64,65]	Data-class expectations for certified EHRs	Verified
SMART App Launch	2.2.0 (current); CMS rules reference 1.0.0 and 2.0.0 ^[28,43]	EHR launch, standalone launch, Backend Services	Verified
OAuth 2.0 / OIDC	RFC 9700 security BCP; OIDC Core 1.0 ^[71,72]	All authorization flows	Verified
CDS Hooks	2.0.1 ^[47]	CRD invocation	Verified
Da Vinci CRD / DTR / PAS	Current: 2.2.1 / 2.2.0 / 2.2.1. CMS recommended: 2.0.1 / 2.0.1 (2.0.0 in the original rule) / 2.0.1 and 2.1.0; HTI-4 certification at 2.0.1 ^[28,48,51,53,63]	PA core. Support multiple versions per payer Recommended	Verified
Subscriptions R5 Backport	1.1.0 ^[46]	PAS pended-response notifications	Verified
Da Vinci CDex / HReX	CDex 2.1.0; HReX 1.2.0 ^[56,57]	Attachments; shared conventions	Verified
Bulk Data	3.0.0 current; CMS references 1.0.0 ^[28,45]	Backend population sync; payer Provider Access API	Verified
HL7 v2 / C-CDA	v2.x per site; C-CDA R5.0.0 in 2026 SVAP ^[60,61,64]	Legacy feeds (ADT, ORM/ORU); documents as evidence	Verified
X12 278 / 275 / 270-271	HIPAA-adopted 278 (005010). Claims attachments 275/277 v6020 compliance 26 May 2028; PA attachments not finalized ^[31]	Fallback PA route via partner	Verified
NCPDP SCRIPT	2023011 required for Part D from 1 Jan 2028 ^[36]	Pharmacy ePA (later track)	Verified

10.4 Key architecture decisions

Table 20. Architecture decision records (proposed)

ADR	Decision Recommended	Rationale	Revisit when
001	FHIR R4 + US Core + Da Vinci profiles as the canonical clinical model	All regulatory APIs and IGs are R4. A proprietary model adds mapping cost	R6 adoption by EHRs and payers
002	HAPI FHIR JPA server (Apache-2.0) on PostgreSQL	Most mature OSS R4 server; partitioning; validation; subscriptions ^[108,109]	Scale or ops burden exceeds budget → evaluate managed options
003	Modular monolith + worker pool for MVP	A small team; fewer distributed-system failure modes	Independent scaling or isolation needs
004	Durable workflow engine for PA cases	Cases span days to weeks with timers and human steps	—
005	Outbox pattern for all events	Queues are at-least-once ^[115] ; no lost or phantom events	—
006	AWS, HIPAA-eligible services only, under a BAA	Eligibility list covers the needed services ^[101]	Customer requires another cloud
007	Pooled multi-tenancy with RLS by default; siloed and dedicated tiers productized	Cost-efficient start; enterprise path	\$23 triggers

ADR	Decision Recommended	Rationale	Revisit when
008	Partner for X12 and HIE connectivity	Established networks and contracts; not differentiating	Volume justifies direct connections

11 EHR Connectivity

EHR connectivity has two separate gates. The first is the **vendor program**: app registration, sandbox, and any certification or review. The second is each **customer's activation**: the provider organization approves the app, scopes and environment. Plans that budget only for the first gate slip **Inferred**.

11.1 Integration modes

Table 21. EHR integration modes used by the Platform

Mode	Standard	Used for in PA	Priority Recommended
SMART EHR launch (user-facing)	SMART App Launch 2.x + FHIR R4 / US Core ^[43]	DTR app, case view inside the chart; user-context reads	MVP
Backend services (system)	SMART Backend Services ^[44] ; Bulk Data ^[45]	Background evidence pulls, status reconciliation, write-back where allowed	MVP where the site permits
CDS Hooks service	CDS Hooks 2.0.1 ^[47]	Receiving order-sign/order-select hooks when the EHR routes hooks to us (CRD router role)	Pilot (EHR-dependent)
FHIR Subscriptions (from EHR)	Subscriptions Backport ^[46]	New orders/coverage changes → auto-create cases	Production (EHR-dependent)
HL7 v2 feeds	ADT, ORM/OMG, ORU, SIU via interface engine ^[60]	Order and scheduling events where FHIR events are unavailable	Pilot (site-dependent)
Documents	C-CDA, DocumentReference ^[58,61]	Clinical notes and reports as attachments	MVP (read)

11.2 EHR comparison

Only publicly documented facts are stated as verified. Integration constraints that depend on contracts or customer configuration are marked **Needs validation**.

Table 22. EHR integration comparison (public developer information, retrieved 30 Sep 2026)

EHR	FHIR / SMART / APIs	Developer access & auth	Onboarding & constraints	PA-relevant notes
Epic	R4 (plus STU3, DSTU2) APIs; patient, clinician and backend apps; CDS Hooks and Bulk FHIR documentation ^[73] Verified	Free sandbox. EHR launch, standalone launch and backend OAuth 2.0; refresh tokens for confidential clients; JWKS ^[74] Verified	open.epic: self-service registration; connect to customers and go live "without needing Epic's involvement". Connection Hub listing optional ^[75] . Vendor Services optional paid program ^[76] . Client records propagate to customer environments over time ^[74] Verified . Per-customer scope approval, security review and rate limits Needs validation .	Trade press reports native CRD live at four health systems with UHC, Aetna, Network Health ^[116] Needs validation . Design for coexistence : consume native CRD/DTR outcomes; do not intercept.
Oracle Health (Millennium)	FHIR R4 APIs, Bulk Data; SMART apps and system accounts (backend) ^[77] Verified	Open and secure sandboxes for R4. "Oracle no longer supports DSTU 2 FHIR APIs" ^[77] Verified	Application registration via Oracle's authorization framework ^[77] . Per-client (domain) enablement Needs validation .	Confirm write-back support (e.g., DocumentReference, Task, QuestionnaireResponse) per client Needs validation .

EHR	FHIR / SMART / APIs	Developer access & auth	Onboarding & constraints	PA-relevant notes
athenahealth	Two product lines. athenaPractice/athenaFlow developer portal: FHIR R4 (4.0.1), SMART v2 with v1 backward compatibility, client-credentials for service apps, sandbox ^[78] Verified . athenaOne: FHIR and proprietary APIs ^[79] Needs validation	Product-specific identity (e.g., Azure AD B2B/B2C for athenaPractice users/patients) ^[78] Verified	Marketplace/partner program terms and per-practice enablement Needs validation .	Treat athenaOne and athenaPractice as separate connectors Recommended .
eClinicalWorks	Provider-facing FHIR developer portal and healow patient-facing portal; SMART and bulk/backend service apps ^[80] Verified	Registration via portals ^[80] . FHIR version and scopes: Needs validation (not stated on page)	Per-practice enablement and any fees Needs validation . eCW states TECCA participation ^[80] .	Many ambulatory specialty practices. Likely high PA value where native ePA is limited Inferred .
MEDITECH (Expanse)	Greenfield Workspace: US Core FHIR R4 APIs (patient-facing, view-only after patient authorization); FHIR scheduling APIs ^[81] Verified	Greenfield registration; contact form for use cases beyond documented ones ^[81] Verified	"Only patient workflows are currently supported" for US Core APIs per the page ^[81] Verified . Provider/backend PA access Needs validation .	May require HL7 v2 or site-specific interfaces for provider-side PA Inferred .
Others (e.g., NextGen, Veradigm, ModMed)	Not researched for this version. Certified EHRs must meet ONC API criteria, but product-specific capabilities, onboarding and write-back vary Needs validation .			

11.3 Terminology and data differences to expect **Inferred**

- **Coded vs. free text.** Problems may be SNOMED CT, ICD-10-CM or local codes. Labs may lack LOINC. Medications may be RxNorm at different term types (SCD, SBD) or local formulary IDs.
- **Coverage quality.** The **Coverage** resource often lacks payer identifiers usable for routing. Member IDs may be stored differently from how the payer expects them.
- **Order representation.** ServiceRequest codes may be CPT, HCPCS, internal order codes or LOINC (for lab orders). A mapping to billing codes is required for payer rules.
- **Extensions and identifiers.** Vendor extensions and identifier systems differ. Patient matching across sources needs normalized identifiers.
- **Write-back.** Support for creating Task, Communication, DocumentReference or QuestionnaireResponse varies by vendor and site.

11.4 Ingestion pipeline

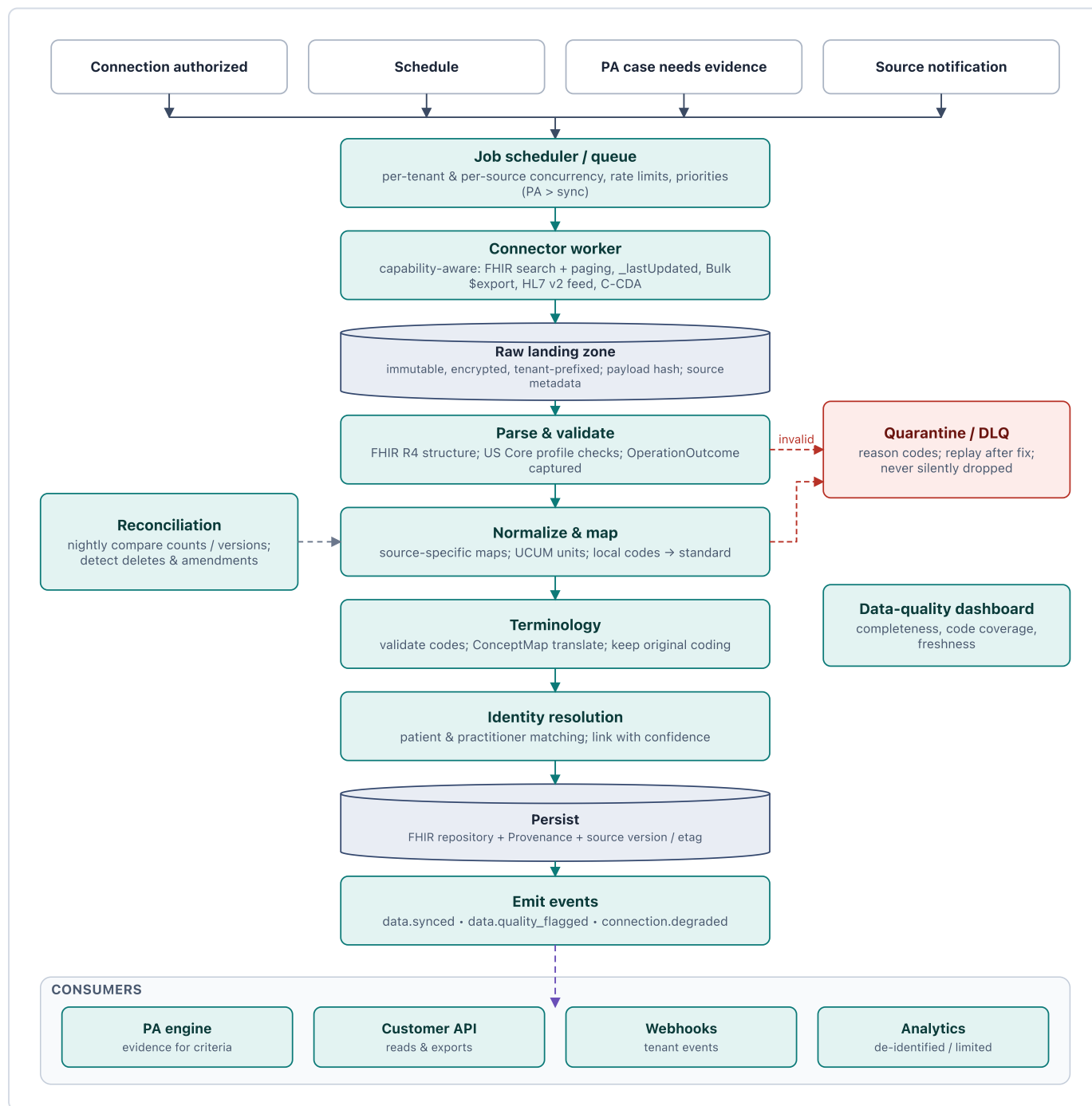


Figure 12. Diagram 6: FHIR data ingestion flow

Ingestion serves PA in two modes **Recommended**:

- **Case-scoped, on-demand pulls.** Read only the resources a questionnaire's CQL `dataRequirement` needs^[52]. These are interactive, with a latency budget of seconds.
- **Background synchronization.** Optional; for analytics and pre-warming, under backend authorization.

The case-scoped mode is also the minimum-necessary mode. It is the default.

11.5 Production onboarding checklist Recommended

1. Vendor program enrollment; app registration (sandbox and production client IDs); JWKS published.
2. Customer-side: security questionnaire, BAA, app approval, scope approval, environment URLs, user provisioning.
3. Connectivity test in the customer's non-production environment with their test patients.
4. Data-quality assessment: coded coverage, order codes, problem-list coding rates.
5. Go-live runbook: rollback, support contacts, monitoring dashboards, change freeze windows.

11.6 HIEs and national networks

Networks matter for PA as a **source of outside evidence** (for example, prior imaging or specialist notes from another health system), not as a submission channel. Access depends on participation agreements and a permitted purpose. Medblocks' own documentation stresses that network access "is not a shortcut around the relationship rules"^[4]

Verified.

Table 23. Exchange frameworks and networks

Framework / network	What it is (as documented)	Relevance to PA Recommended
TEFCA	National framework under ONC/ASTP. The Sequoia Project serves as Recognized Coordinating Entity. Qualified Health Information Networks (QHINs) exchange under the Common Agreement (v2.1, Feb 2025) and QHIN Technical Framework (v2, Jun 2025). Exchange purposes include treatment, payment, health care operations, public health, government benefits determination and individual access services ^[66] . Designated QHINs are listed by the RCE ^[67] .	"Payment" is a listed exchange purpose, but responding obligations and practical support for PA-related queries must be confirmed with a QHIN partner Needs validation . Join as a participant or sub-participant via a QHIN, not as a QHIN.
Carequality	An interoperability framework (legal, policy and technical) connecting implementers and their networks ^[68] Needs validation (page not machine-retrievable).	Access typically comes through an implementer such as an EHR vendor or HIE vendor.
CommonWell	A health information network offering record-location and exchange services to members and service adopters ^[69] Needs validation (page not machine-retrievable).	As above. Some EHRs already participate on behalf of their customers Needs validation .
CMS Interoperability Framework	A voluntary CMS framework under which networks pledge to become "CMS Aligned Networks". Criteria include FHIR APIs adhering to US Core with USCDI v3 and identity-proofing expectations (IAL2/AAL2). The first early adopters reached general availability in July 2026 ^[38] Verified .	A potential future channel for provider and payer data access. Monitor. Not an MVP dependency.
Regional / state HIEs	Operate in specific geographies with their own governance Industry-standard .	Useful for large health-system customers. Partner-led integration.

Recommendation Recommended

Leave networks out of the MVP. In the production phase, select a QHIN or HIE partner and implement a "retrieve outside documents for this case" action that is purpose-scoped, auditable and uses case-level patient matching.

12 Payer Connectivity

Payers are not interchangeable. Each has its own onboarding, endpoints, supported IG versions, product-line coverage and fallback channels. The Platform maintains a **payer capability registry**: per payer and product line, which of CRD, DTR and PAS are live, at which version, and with which fallback **Recommended**.

12.1 Payer categories

Table 24. Payer integration considerations

Category	Regulatory position (verified)	Integration considerations
Medicare fee-for-service (CMS / MACs)	Not among the CMS-0057-F "impacted payers" list ^[24] . Uses PA and pre-claim review programs. esMD accepts electronic PA requests and documentation ^[33] . DRLS prototype for requirement lookup ^[34] . WISer model (1 Jan 2026 to 31 Dec 2031, six states, selected services) routes requests to model participants or via MACs ^[32] .	Channel is esMD via a Health Information Handler, or MAC portals. WISer adds state- and service-specific routing. Patient-authorized claims data is available via Blue Button 2.0 ^[35] .
Medicare Advantage	Impacted payer: 72 h / 7 days decision timeframes and specific denial reasons since 1 Jan 2026; Prior Authorization API by 1 Jan 2027 ^[24] .	Highest near-term FHIR PA readiness expected Inferred . Many delegate UM to vendors for specific service lines.
Medicaid (FFS and managed care), CHIP	Impacted payers under CMS-0057-F ^[24] .	State-by-state variation in vendors, portals and timelines. Each managed care plan is a separate integration Inferred .
QHP issuers on FFEs	Impacted for APIs. Not subject to the 72 h / 7 d timeframes today; CMS-0062-P would require provider notice within those limits ^[26] Proposed rule .	Same technical path as MA plans once APIs are live.
Commercial (employer / non-FFE)	Not directly subject to CMS-0057-F API requirements. Voluntary AHIP/BCBSA commitments target standardized FHIR ePA by 1 Jan 2027 ^[117] .	Readiness varies widely. State laws (e.g., gold-carding, timelines) may apply Needs validation .
Large national insurers (examples)	UnitedHealthcare: Provider Portal real-time submission, API for status checks, EDI, National Gold Card program ^[82] ; FHIR CRD/DTR/PAS API described and marked "Coming soon" ^[83] . Aetna: developer portal ^[85] Needs validation for PA scope; reported live on Epic CRD ^[116] .	Expect staged rollout by product line. Confirm per line of business before routing.
Blue Cross Blue Shield plans	Independent companies with separate APIs. Example: Blue Cross NC offers Patient Access, Provider Directory and Payer-to-Payer; Provider Access and Prior Authorization "Coming 2027"; 10-business-day API access review ^[84] .	Treat each Blue plan as a distinct payer in the registry.
UM organizations (delegated)	Act on behalf of payers for specific services (not separately regulated by CMS-0057-F as payers) Inferred .	The payer's CRD may redirect to the UM vendor's DTR/PAS endpoints. Registry must model delegation Recommended .

12.2 EHR → Platform → payer flow

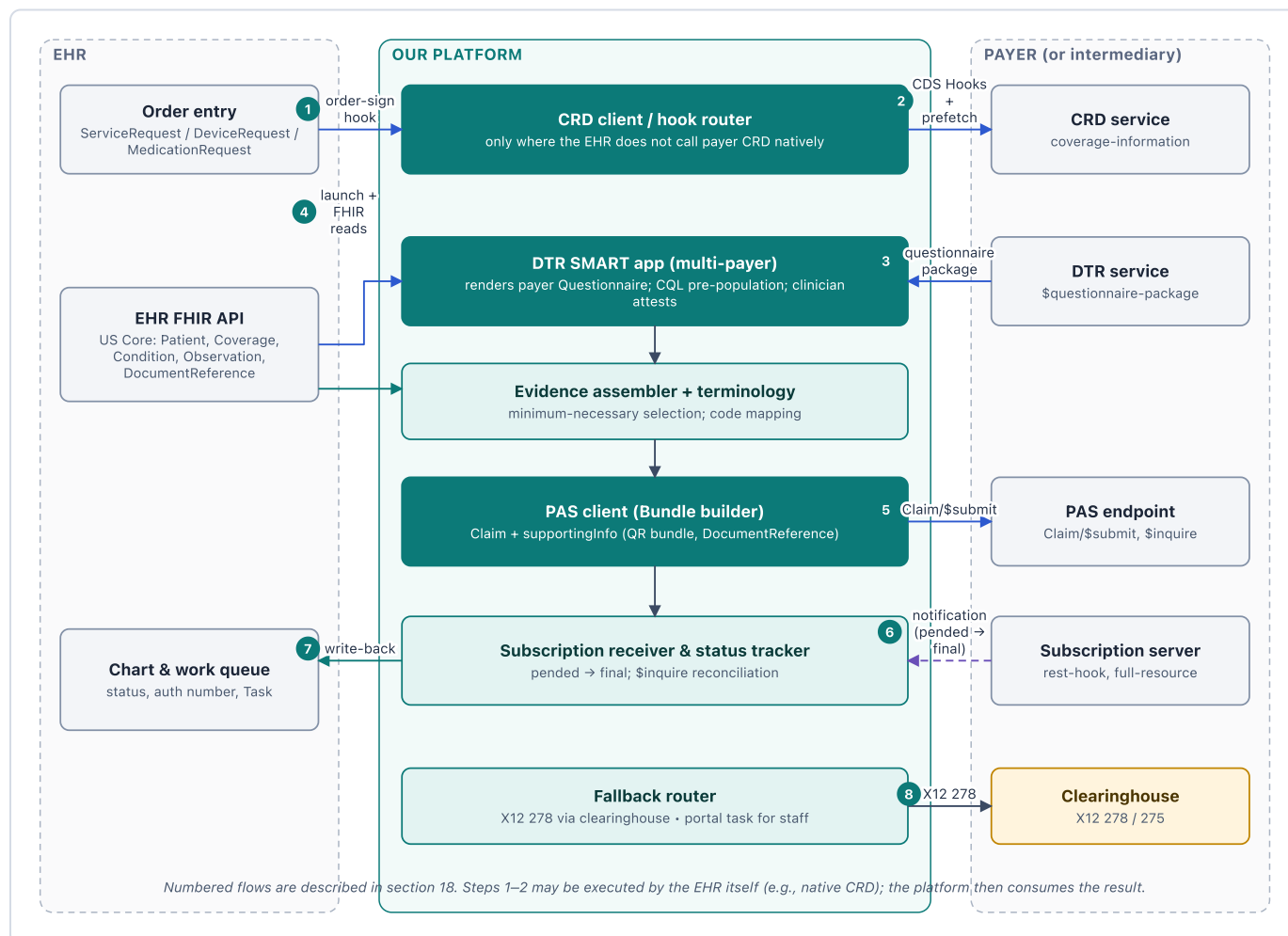


Figure 13. Diagram 4: EHR → interoperability platform → payer flow

12.3 Payer onboarding lifecycle Recommended

1. **Discovery.** Endpoints, supported IG versions and profiles, product lines covered, test environment, trust model (SMART Backend Services registration, mTLS, UDAP-style certificates if required Needs validation).
2. **Legal.** API terms; our status as the provider's business associate; any payer-specific agreements.
3. **Technical registration.** Client registration and public keys for Backend Services, as required for DTR^[52]. Subscription endpoint registration for PAS^[54].
4. **Conformance.** Inferno test kits for CRD/DTR/PAS (client roles)^[70]. Payer-specific test scripts.
5. **Pilot.** Limited services, sites and volumes. Compare with portal outcomes.
6. **Production.** Monitoring, SLOs, escalation contacts, change notification process.

12.4 When the payer is not ready

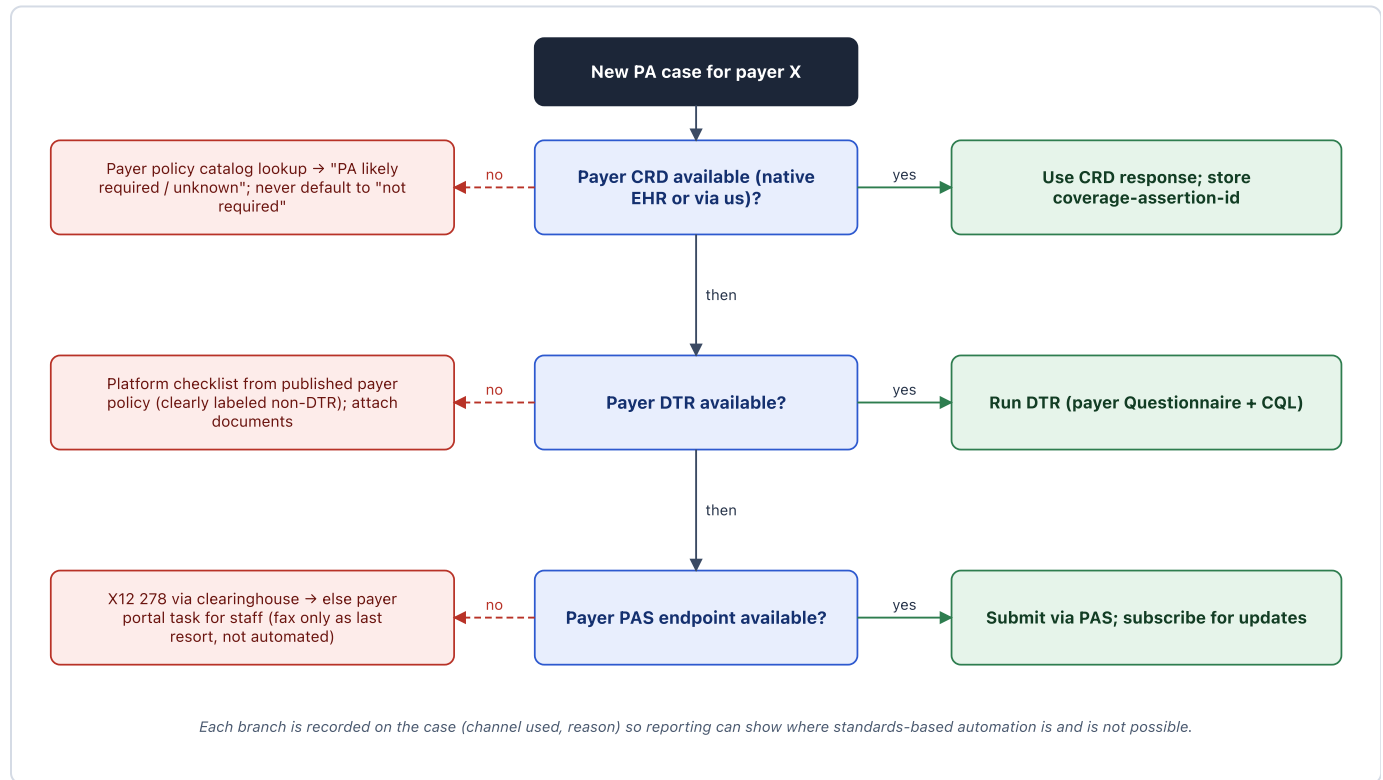


Figure 14. Payer capability decision tree used on every case

13 FHIR / SMART Architecture

13.1 Our two SMART roles

Table 25. SMART roles

Role	Description	Key controls Recommended
SMART client of EHRs and payers	Our DTR app and backend services obtain tokens from EHR authorization servers (EHR launch, backend) and payer authorization servers (Backend Services for DTR/PAS)	PKCE; <code>private_key_jwt</code> (asymmetric, preferred by SMART ^[43]); per-tenant keys; narrow scopes; tokens server-side only
SMART authorization server for our FHIR API	Customer apps access tenant data through our FHIR API with SMART scopes	OIDC-certified library; v2 scopes; token introspection; short lifetimes; consent-aware policies

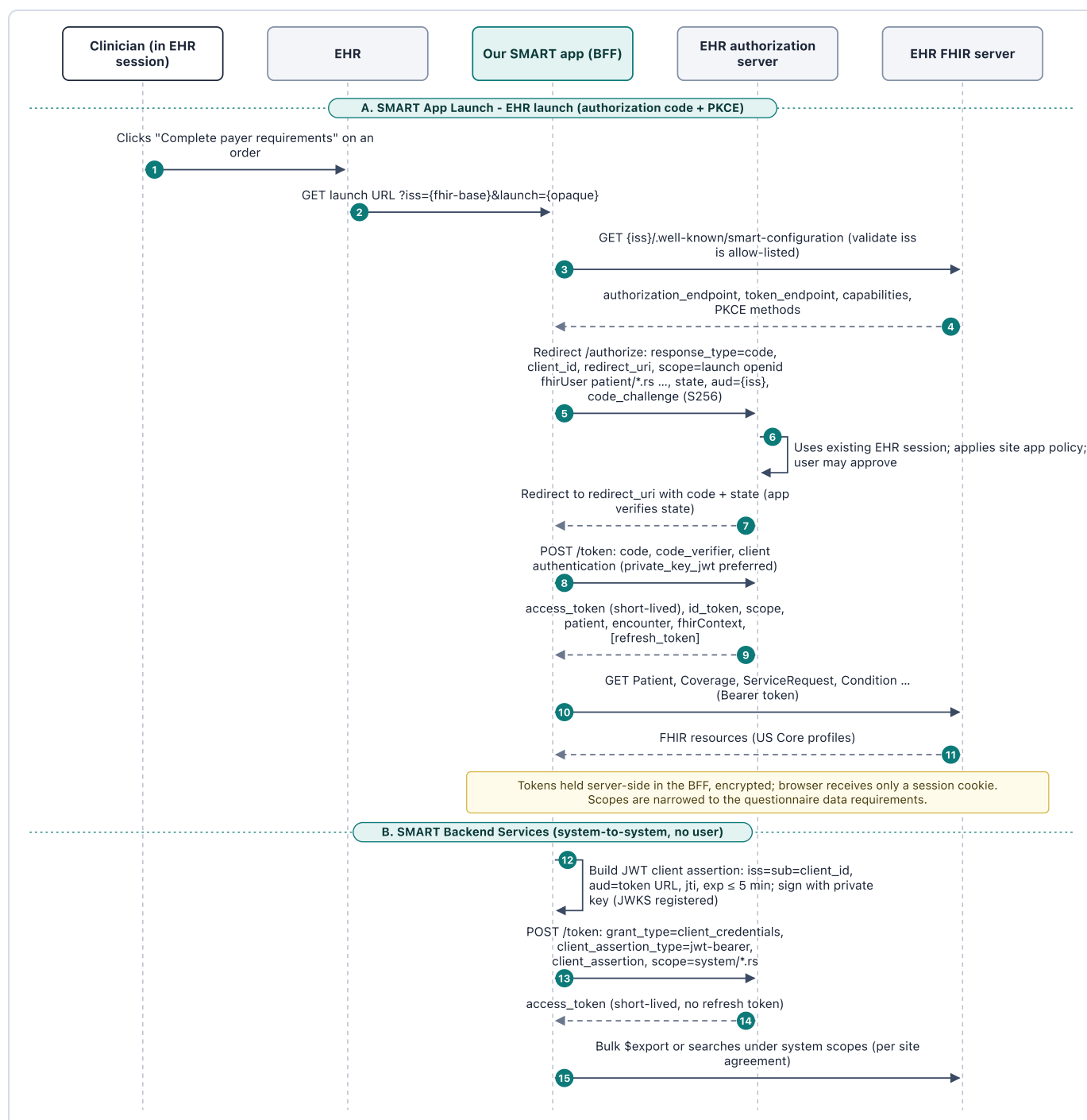


Figure 15. Diagram 5: SMART on FHIR authorization flows (EHR launch and Backend Services)^[43,44]

13.2 Token and session security Industry-standard

- Use the authorization-code flow with PKCE for all user-facing launches, with exact redirect-URI matching and a validated `state`. Never use the resource-owner password grant^[71].
- Use a backend-for-frontend (BFF). The browser holds only an HTTP-only session cookie; access and refresh tokens are encrypted at rest in a token vault.
- Allow-list `iss` values per tenant. Reject launches from unknown FHIR servers.
- Backend JWT assertions are short-lived (the SMART guidance is ≤ 5 minutes) and signed with RS384 or ES384 keys stored in KMS/HSM where supported Needs validation per EHR.

- Refresh proactively. On `invalid_grant`, mark the connection `refresh_failed` and notify, following the pattern Medblocks documents^[12].

13.3 FHIR server strategy

We need a FHIR server for four things:

- storing normalized clinical evidence and PA artifacts (Claim, ClaimResponse, QuestionnaireResponse, Task, DocumentReference, Provenance);
- profile validation;
- search;
- exposing a tenant-scoped FHIR API to customers.

We do *not* need our FHIR server to host payer-side operations. For CRD, DTR and PAS we are the client.

Table 26. FHIR server options compared

Option	Maturity / versions	Extensibility & multi-tenancy	Terminology	Hosting & licensing	Ops effort / fit
HAPI FHIR JPA (OSS)	Widely used Java server; active releases (v8.8.2, 25 Sep 2026) ^[108]	Interceptors, custom operations; partitioning incl. URL-based tenants; authorization required for real isolation ^[109]	Built-in CodeSystem/ValueSet support; can front external servers Needs validation	Self-host; Apache-2.0 ^[108]	Medium-high ops (DB tuning, reindexing, upgrades). Best fit for MVP Recommended
Medplum (OSS platform)	Active (v5.1.43, 30 Sep 2026); TypeScript ^[110]	Auth (OAuth/OIDC/SMART), bots, subscriptions included ^[110]	Needs validation	Self-host or vendor cloud; Apache-2.0	Attractive if the team is TypeScript-first. Evaluate PA-specific profile validation Needs validation
Microsoft FHIR Server (OSS)	Open-source basis of Azure's service ^[112,114]	Needs validation for partitioning	Needs validation	Self-host (Azure-oriented)	Better fit on Azure
AWS HealthLake (managed)	R4 only; HIPAA-eligible ^[111]	Data store per tenant is possible; custom operations Needs validation	Needs validation	Managed; usage pricing	Low ops. Validate Da Vinci profile validation, search parameters and operation needs before choosing Needs validation
Azure Health Data Services FHIR	Managed; SMART; audit logs ^[112]	Per-service database isolation ^[112]	Needs validation	Azure	Strong if the customer mandates Azure
Google Cloud Healthcare API	DSTU2, STU3, R4, R5 stores ^[113]	Store per tenant; Pub/Sub notifications ^[113]	Needs validation	GCP	Strong if the customer mandates GCP
Commercial servers (e.g., Smile CDR, Aidbox ^[20] , Firely Server)	Not assessed in this version. Typically add support, enterprise features and performance tooling. Worth a bake-off at production scale Needs validation .				
Custom implementation	Not recommended. FHIR search, versioning, validation and conformance are large efforts with no differentiation Recommended .				

Recommendation Recommended

- Use **HAPI FHIR JPA on Aurora PostgreSQL** with partitioning for pooled tenants, and dedicated databases for siloed tenants.
- Load US Core, CRD, DTR, PAS and CDex IG packages for validation.
- Keep the operational case model in a separate PostgreSQL schema. The FHIR server is the store for FHIR artifacts, not the workflow engine.
- Revisit at production scale with a managed or commercial bake-off, using real workload data.

14 Data Architecture

14.1 Conceptual model

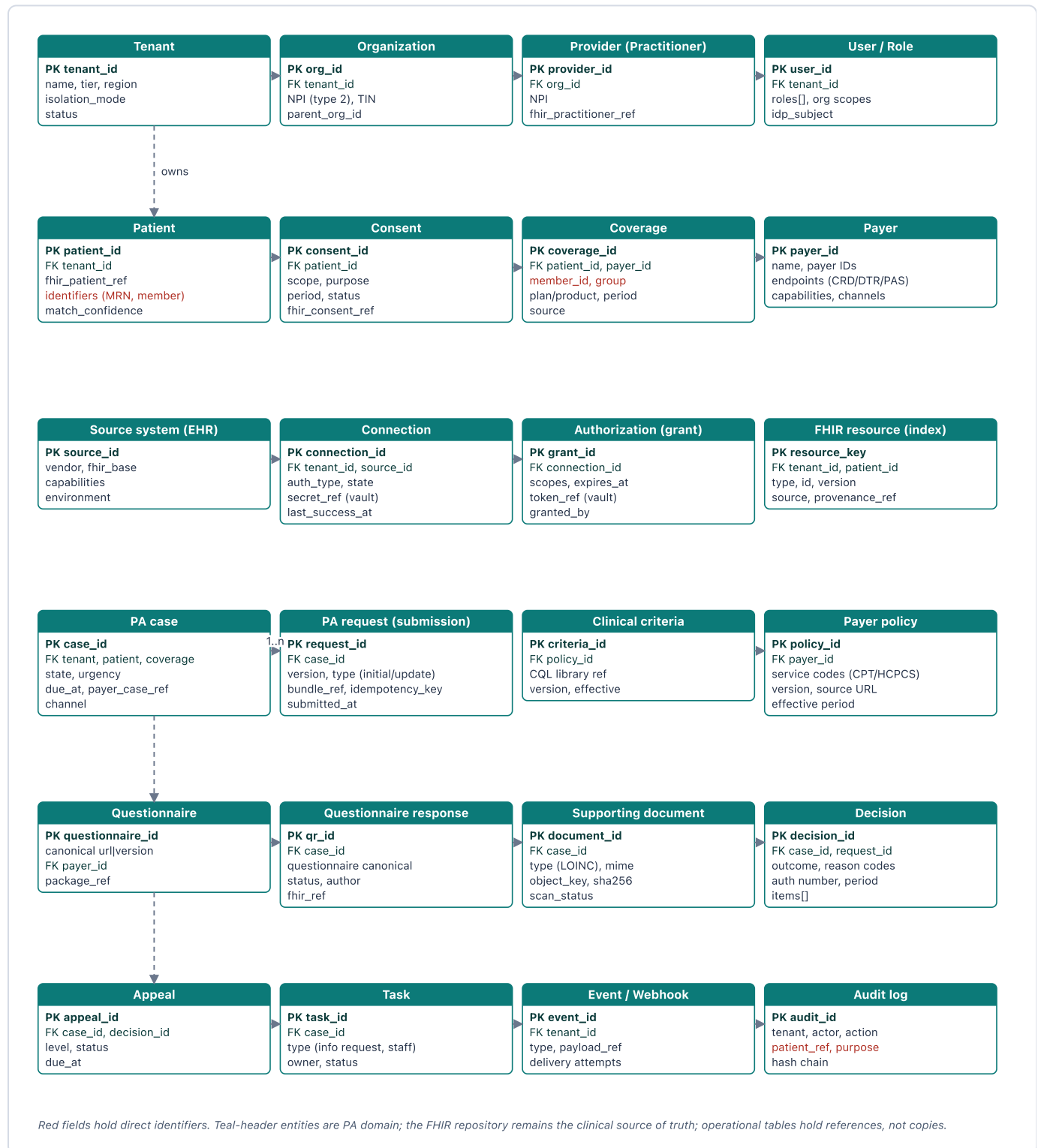


Figure 16. Conceptual data model (entities, key fields and main relationships)

14.2 Logical model: entity catalog

Table 27. Entity catalog: identifiers, source of truth, PHI sensitivity and retention

Entity	Key fields / identifiers	Relationships	Source of truth	PHI	Retention Recommended (validate with counsel)
Tenant	tenant_id (UUID), isolation tier, region	owns everything	Our control plane	No	Life of contract + audit period
Organization	org_id; NPI (type 2), TIN, payer enrollment IDs	Tenant 1–n	Customer / NPPES	No (business data)	Life of contract
Provider	provider_id; NPI; EHR user IDs	Org n–n	NPPES + EHR	Low	Life of contract
Patient	patient_id; MRN per source; payer member ID; demographics	Tenant 1–n; Coverage 1–n	EHR	High	While cases open + retention policy; delete/return at contract end per BAA
Payer	payer_id; payer IDs (X12, NAIC Needs validation); endpoints; capabilities	Coverage, Policy	Our registry	No	Indefinite (versioned)
Coverage	coverage_id; member ID; group; plan; period	Patient, Payer	EHR / payer eligibility	High	With case
Connection	connection_id; source; auth type; state; secret_ref	Tenant, Source	Our platform	No (secrets referenced, not stored)	Life of connection + audit
EHR / Source system	source_id; vendor; FHIR base; environment	Connections	Our catalog	No	Indefinite
Consent	consent_id; scope; purpose; period; restrictions	Patient	Customer / EHR	High	Per policy (≥ case retention)
Authorization (grant)	grant_id; scopes; expiry; token_ref	Connection	EHR / payer auth server	Medium (tokens are secrets)	Tokens: until expiry/revocation; metadata: audit period
FHIR resource	type/id/version; source; provenance	Patient, Case	EHR (copy) or Platform (PA artifacts)	High	Evidence copies: minimum needed for case and audit; PA artifacts: see Case
PA case	case_id; state; urgency; due_at; payer_case_ref	Patient, Coverage, Requests, Decision	Our platform	High	Policy-driven (e.g., ≥ 6 years Needs validation). PAS: pended PAs queryable ≥ 6 months after anticipated service completion ^[54]
PA request (submission)	request_id; version; channel; bundle_ref; idempotency_key	Case 1–n	Our platform	High	With case
Clinical criteria	criteria_id; CQL library ref; version	Policy	Payer (DTR packages)	No	Versioned indefinitely (for reproducibility)
Questionnaire	canonical URL version; payer	Criteria, QR	Payer	No	Versioned indefinitely
Questionnaire response	qr_id; questionnaire canonical; status; author	Case	EHR (written back) + our copy	High	With case
Supporting document	document_id; LOINC type; sha256; object key	Case, Attachment	EHR or uploader	High	With case
Attachment	link of document to request item; LOINC attachment code	Request, Document	Our platform	High	With case

Entity	Key fields / identifiers	Relationships	Source of truth	PHI	Retention Recommended (validate with counsel)
Payer policy	policy_id; service codes; source URL; effective dates	Payer, Criteria	Payer publications / CRD	No	Versioned indefinitely
Decision	decision_id; outcome; reason codes; auth number; validity; items	Request, Case	Payer	High	With case
Appeal	appeal_id; level; status; due date	Decision	Our platform + payer	High	With case
Task	task_id; type; owner; status; payer Task ref	Case	Our platform / payer (PAS Task)	Medium	With case
Webhook	endpoint_id; secret_ref; event types	Tenant	Customer	No	Life of subscription
Event	event_id; type; payload_ref; delivery attempts	Tenant, Case	Our platform	Medium (IDs only in payloads Recommended)	30–90 days for replay; metadata longer
Audit log	audit_id; actor; action; patient ref; purpose; hash	All	Our platform	High (identifiers)	≥ 6 years (aligns with HIPAA documentation retention ^[89]) Needs validation
Terminology mapping	ConceptMap id; source code/system → target; version; reviewer	Terminology	Our platform (curated)	No	Versioned indefinitely

14.3 Recommended database model Recommended

- **PostgreSQL (operational)**. Schemas `control` (no PHI), `ops` (cases, requests, tasks; tenant_id plus row-level security), `audit` (append-only; partitioned by month), `outbox`.
- **HAPI FHIR (PostgreSQL)**. FHIR artifacts and evidence copies, partitioned per tenant.
- **S3**. Raw payloads, documents and exports under tenant prefixes, with KMS keys per tenant tier.
- **Redis**. Ephemeral only: rate-limit buckets, locks, CRD response cache (keyed by order hash and short TTL; no PHI values as keys).

Example tables (DDL excerpt)

```
CREATE TABLE ops.pa_case (
  case_id          uuid PRIMARY KEY,
  tenant_id        uuid NOT NULL,
  patient_ref      text NOT NULL,          -- FHIR Patient reference (HAPI partition)
  coverage_ref     text NOT NULL,
  order_ref        text NOT NULL,          -- ServiceRequest / DeviceRequest / MedicationRequest
  payer_id         uuid NOT NULL REFERENCES control.payer(payer_id),
  state            text NOT NULL CHECK (state IN ('draft','requirements_checked','not_required',
    'documentation_in_progress','ready_to_submit','submitted','pending',
    'info_requested','decided','appeal_in_progress','closed','cancelled','action_required')),
  urgency          text NOT NULL CHECK (urgency IN ('standard','expedited')),
  requirement       text,                  -- 'required' | 'not_required' | 'unknown' + evidence ref
  coverage_assertion_id text,              -- from CRD coverage-information
  channel           text,                  -- 'pas' | 'x12_278' | 'portal'
  payer_case_ref    text,                  -- preAuthRef / X12 trace
  due_at           timestamptz,           -- internal SLA timer
  created_at        timestamptz NOT NULL DEFAULT now(),
  updated_at        timestamptz NOT NULL DEFAULT now(),
  version           integer NOT NULL DEFAULT 1
);
ALTER TABLE ops.pa_case ENABLE ROW LEVEL SECURITY;
CREATE POLICY tenant_isolation ON ops.pa_case
  USING (tenant_id = current_setting('app.tenant_id')::uuid);

CREATE TABLE ops.pa_submission (
  request_id       uuid PRIMARY KEY,
  case_id          uuid NOT NULL REFERENCES ops.pa_case(case_id),
  tenant_id        uuid NOT NULL,
  seq              integer NOT NULL,       -- 1 = initial, 2.. = updates / responses
  kind             text NOT NULL,         -- 'initial' | 'update' | 'cancel' | 'attachment'
  channel          text NOT NULL,
  idempotency_key  text NOT NULL,
  bundle_object_key text,                 -- S3 key of exact payload sent (immutable)
  bundle_sha256    text,
  http_status      integer,
  submitted_at     timestamptz,
  UNIQUE (tenant_id, idempotency_key),
  UNIQUE (case_id, seq)
);
```

14.4 Example FHIR resources (synthetic)

Illustrative, abbreviated examples. Profiles and required elements must follow the IG versions agreed with each payer.

```
{ "resourceType": "Coverage",
  "id": "cov-123",
  "status": "active",
  "subscriberId": "W000000000",
  "beneficiary": { "reference": "Patient/pat-1" },
  "payor": [ { "reference": "Organization/payer-acme",
    "display": "Acme Health Plan" } ],
  "class": [ { "type": { "coding": [ { "system":
    "http://terminology.hl7.org/CodeSystem/coverage-
class",
    "code": "plan" } ] }, "value": "MA-HMO-01" } } ] }
```

```
{ "resourceType": "ServiceRequest",
  "id": "sr-77",
  "status": "active", "intent": "order",
  "code": { "coding": [ { "system": "http://www.ama-
assn.org/go/cpt",
    "code": "72148",
    "display": "MRI lumbar spine
w/o contrast" } ] },
  "subject": { "reference": "Patient/pat-1" },
  "reasonCode": [ { "coding": [ { "system":
    "http://hl7.org/fhir/sid/icd-10-cm", "code":
    "M54.16" } ] },
  "insurance": [ { "reference": "Coverage/cov-123" } ],
  "requester": { "reference": "PractitionerRole/pr-9" }
}
```

```

{ "resourceType": "Bundle", "type": "collection",          // PAS request Bundle (abbreviated)
  "identifier": { "system": "urn:ietf:rfc:3986", "value": "urn:uuid:4f1c..." },
  "entry": [
    { "fullUrl": "urn:uuid:9b2e...", "resource": { "resourceType": "Claim",    // FIRST entry SHALL be Claim
      "use": "preauthorization", "status": "active",
      "patient": { "reference": "urn:uuid:pat..." },
      "insurer": { "reference": "urn:uuid:org-payer..." },
      "provider": { "reference": "urn:uuid:org-provider..." },
      "priority": { "coding": [{ "code": "normal" }] },
      "insurance": [{ "sequence": 1, "focal": true, "coverage": { "reference": "urn:uuid:cov..." } }],
      "supportingInfo": [
        { "sequence": 1, "category": { "coding": [{ "code": "freeFormMessage" }] },
          "valueReference": { "reference": "urn:uuid:qr-bundle..." } } ],    // DTR QuestionnaireResponse bundle
      "item": [{ "sequence": 1,
        "productOrService": { "coding": [{ "system": "http://www.ama-assn.org/go/cpt", "code": "72148" }] },
        "extension": [{ "url": ".../extension-serviceItemRequestType", "valueCodeableConcept": { ... } } ] } ],
      { "fullUrl": "urn:uuid:pat...", "resource": { "resourceType": "Patient", ... } },
      { "fullUrl": "urn:uuid:cov...", "resource": { "resourceType": "Coverage", ... } },
      { "fullUrl": "urn:uuid:qr-bundle...", "resource": { "resourceType": "Bundle", "type": "collection", ... } } ] }

```

Rules shown are from PAS 2.2.1: the first entry is the Claim; every supporting resource is referenced from `Claim.supportingInfo`; GUID-based `fullUrl`s must be unique across submissions^[54]. Codes such as `freeFormMessage` are placeholders; use the category codes defined in the payer-agreed IG version **Needs validation**.

15 Terminology Architecture

15.1 Why terminology normalization matters for PA

In plain terms

Payer rules are written in standard codes: "CPT 72148 requires PA when diagnosis is in this ICD-10 list and conservative therapy of at least 6 weeks is documented." If the chart stores the diagnosis under a local code, stores the therapy as free text, or files the lab without a LOINC code, the automation cannot "see" the evidence. The questionnaire then comes back blank and a person has to hunt for it. Normalization is the difference between a form that fills itself and a form that doesn't.

- **CQL pre-population** in DTR evaluates FHIR data against ValueSets. Membership depends on standard codes^[52] Verified.
- **PAS intermediaries** may need "terminology translations (e.g., SNOMED to ICD10)" when mapping to X12^[54] Verified.
- **Payer policies** are keyed on CPT/HCPCS service codes and ICD-10-CM diagnoses Industry-standard.

15.2 Code systems

Table 28. Terminologies relevant to prior authorization

Code system	Steward	Used for in PA	Licensing / notes
SNOMED CT	SNOMED International; distributed in U.S. via NLM	Problems, findings, procedures in clinical records	Free U.S. use via UMLS license; redistribution restrictions ^[102] Verified
LOINC	Regenstrief Institute	Lab/observation codes; document and attachment types (PAS additional-information codes) ^[55]	Free under LOINC license terms ^[103] Verified
RxNorm	NLM	Normalized clinical drugs; maps to NDC	Free (UMLS terms apply to some sources) ^[104] Verified
ICD-10-CM	CDC NCHS (with CMS)	Diagnoses justifying the service	Public; annual updates Industry-standard ^[105]
CPT	AMA	Professional services and procedures (HCPCS Level I)	License required for use in products, including development and distribution licenses ^[106] Verified
HCPCS Level II	CMS	DME, supplies, drugs administered (J-codes), services not in CPT	Public ^[39] Verified
NDC	FDA (labelers assign)	Drug products and packages (pharmacy; medical-benefit drug detail)	10-digit today; uniform 12-digit format effective 7 Mar 2033 ^[107] Verified . Plan storage for both
UCUM	Regenstrief	Units of measure	Normalize units for CQL comparisons Industry-standard
X12 / PAS code sets	X12; HL7 (PAS)	Review action codes, certification types, reject reasons	PAS uses X12-derived codes; X12 content may carry licensing terms Needs validation
NUCC taxonomy	NUCC	Provider specialty (routing, payer rules)	Needs validation

15.3 Terminology service design Recommended

- **Operations.** FHIR terminology operations: `$validate-code`, `$expand`, `$translate`, `$lookup` ^[59].
- **Content.** Versioned loads of each code system, keeping the loaded version on every mapping and every evaluation for reproducibility. ValueSets arrive in DTR packages (expanded when small) ^[52]; cache them per payer package version.
- **Mappings.** Tenant- and source-specific ConceptMaps (local order codes → CPT/HCPCS; local labs → LOINC). Every mapping has an owner, a reviewer and an effective date. The original coding is always preserved alongside the mapped coding.
- **Implementation.** For the MVP, HAPI FHIR terminology for ValueSets and ConceptMaps, plus NLM RxNorm content. At scale, evaluate a dedicated server such as Snowstorm (SNOMED) or a commercial terminology server Needs validation.
- **Quality loop.** Unmapped-code dashboards per source. Mapping-coverage KPIs feed the data-quality score of each connection (§24).

16 Prior Authorization Business Workflow

This section explains prior authorization first for a business reader (Level 2), then maps each step to who is responsible. The technical contract for each step is in §18.

16.1 The story of one authorization

In plain terms: a lumbar MRI

1. A patient with six weeks of back pain and leg numbness sees an orthopedic clinician, who orders a lumbar spine MRI.
2. The EHR knows the patient's insurance. The payer's rules say this MRI needs approval for this plan, and the payer wants to know about symptom duration, conservative therapy tried, and neurological findings.
3. Most of that is already in the chart: visit notes, a physical-therapy referral, medication history. A form pre-fills itself, and the clinician confirms two answers the chart didn't contain.
4. The request goes electronically to the payer. Seconds later the answer is either "approved, authorization number X, valid for 60 days" or "pending, under clinical review".
5. If pending, the payer may ask for the physical-therapy notes. Staff are alerted, attach them, and send. The decision arrives later and the EHR is updated automatically. The scheduler books the MRI.
6. If denied, the denial carries a specific reason (required for CMS-regulated payers since 1 Jan 2026^[24]). The clinician can request a peer-to-peer discussion or file an appeal.

16.2 End-to-end workflow and responsibilities

Table 29. Prior authorization workflow: steps and responsibilities

#	Step	EHR	Provider	Payer	Interop platform	PA engine	Notes
1	Patient needs a service		●				Clinical decision
2	Order placed	● records	● orders				ServiceRequest / DeviceRequest / MedicationRequest
3	Coverage discovery	● coverage on file		○ eligibility	● verify / enrich		270/271 via partner, or payer APIs
4	Is PA required?	● CRD client (native)		● CRD service	○ hook router	● records outcome	"Unknown" is a valid outcome and routes to staff
5	Retrieve documentation requirements	○ DTR host		● DTR package		● DTR app	Questionnaire + CQL
6	Collect clinical information	● data source	○ confirms		● FHIR reads	● pre-populates	Minimum necessary
7	Collect supporting documents	● documents	● selects / uploads		● retrieves	● attaches	LOINC-typed attachments
8	Validate request		● attests			● profile + completeness checks	Blocking vs warning issues
9	Build request					● PAS Bundle / 278	Deterministic identifiers

#	Step	EHR	Provider	Payer	Interop platform	PA engine	Notes
10	Send to payer			● receives	● transport	● submits	PAS, X12 via partner, or portal task
11	Payer evaluation			● rules or clinical review		● tracks deadline	72 h / 7 days for impacted payers ^[24]
12	Additional information request		● responds	● Task / 278 pend	● receives	● creates work item	May repeat
13	Decision			● decides	● receives	● normalizes	Approved / partial or modified / denied / pended
14	Store decision					● stores	Auth number, validity, items
15	Notify provider / update EHR	● receives write-back	● informed		● writes back	● emits events	Task / Communication / order annotation
16	Appeal if necessary		● decides to appeal	● adjudicates appeal		● tracks appeal	Appeal channels are payer-specific

● primary responsibility, ○ supporting role.

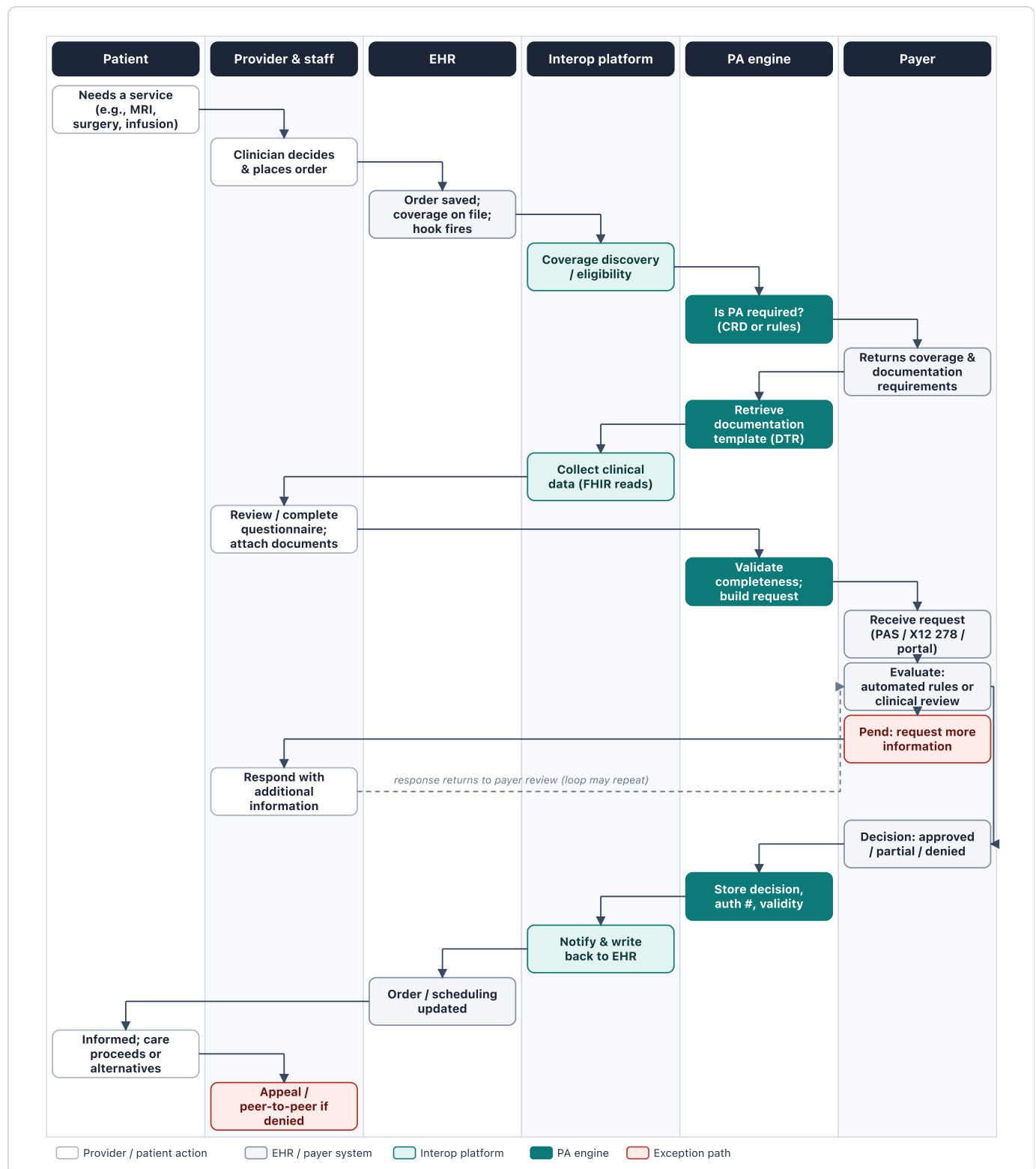


Figure 17. Diagram 7: Prior authorization business workflow (swimlanes)

16.3 Outcomes and their meaning

Table 30. Decision outcomes

Outcome	Meaning	Platform behaviour Recommended
Approved	Service authorized as requested, usually with an authorization number and validity period (CMS FAQ: approval states an end date or circumstance ^[30])	Write back; unblock scheduling; set expiry reminder
Partially approved / modified	Fewer units, different code or site, or shorter period. PAS marks the item "Modified" and returns the authorized detail ^[54]	Highlight the difference; clinician decides to accept, modify the order or appeal
Denied	Not authorized, with a specific reason (impacted payers) ^[24]	Capture reason codes; offer appeal / peer-to-peer workflow
Pended	Payer needs more time; the final answer comes later (PAS subscriptions) ^[54]	Start deadline timer; wait on notification; reconcile
More information requested	Payer asks for specific documents or questionnaire answers (PAS Task / X12 PWK codes) ^[55]	Create work item with exact requested items
Not required	Payer states no PA needed (CRD <code>pa-needed = no-auth</code>) ^[49]	Store evidence of the assertion (coverage-assertion-id, date)

16.4 Urgent vs. standard

CMS-0057-F impacted payers (excluding QHP issuers on FFEs) must decide within **72 hours** for expedited (urgent) requests and **7 calendar days** for standard requests^[24] Verified. The Platform must capture urgency with a justification, set internal timers shorter than the regulatory limit, and escalate before breach Recommended. Payer-specific definitions of "urgent" and state-law timelines vary Needs validation.

16.5 Medical-service PA vs. pharmacy PA

MEDICAL-BENEFIT PA (services, devices, medical-benefit drugs)		PHARMACY-BENEFIT PA (retail / specialty drugs)	
Trigger	order in EHR: ServiceRequest, DeviceRequest, MedicationRequest (clinic-administered)	Trigger	e-prescription (NCPDP SCRIPT NewRx) or pharmacy claim rejection
Requirement discovery	Da Vinci CRD (CDS Hooks) or payer policy lookup	Requirement discovery	formulary & real-time prescription benefit (RTPB) checks
Documentation	Da Vinci DTR questionnaire; clinical notes; imaging, labs	Documentation	SCRIPT ePA question set (PAInitiationResponse)
Submission	Da Vinci PAS (FHIR) or X12 278; payer portal	Submission	NCPDP SCRIPT ePA (PAREquest / PAREsponse) via ePA network
Decision rules	CMS-0057-F impacted payers: 72 h expedited / 7 days standard; specific denial reason	Decision rules	Part D: SCRIPT 2023011 required from 1 Jan 2028; CMS-0062-P would add drug PA timeframes (proposed)
Counterparty	health plan or delegated UM vendor	Counterparty	PBM (on behalf of plan)

MVP scope = left column. The right column is a separate product track with different networks, standards and contracts.

Figure 18. Medical-benefit vs. pharmacy-benefit prior authorization: different triggers, standards and counterparties

- **Medical-benefit PA** covers procedures, imaging, DME, admissions and drugs administered and billed under the medical benefit. It is the focus of CMS-0057-F's PA API, which excludes drugs^[24]. CMS-0062-P would add medical-benefit drugs to the PA API **Proposed rule**^[26].
- **Pharmacy-benefit PA** covers retail and specialty prescriptions adjudicated by a PBM. It runs over NCPDP SCRIPT ePA transactions through ePA networks^[87]. For Medicare Part D, NCPDP SCRIPT ePA transactions were adopted in a 2020 rule^[37] **Historical**, and SCRIPT 2023011 (including ePA transactions) is required from 1 Jan 2028^[36]. CMS-0062-P would require NCPDP standards for pharmacy-benefit drug PA across impacted payers **Proposed rule**^[26]. The AHIP/BCBSA commitments exclude pharmacy benefits^[117].
- **Implication.** The two share the case engine, work queue, documents and audit. They need different connectors, contracts and certification. We recommend a separate product track after the medical MVP **Recommended**.

17 CRD / DTR / PAS

The HL7 Da Vinci "Burden Reduction" guides split prior authorization into three independent capabilities. Each is useful alone; together they automate the full path^[48,51,53].

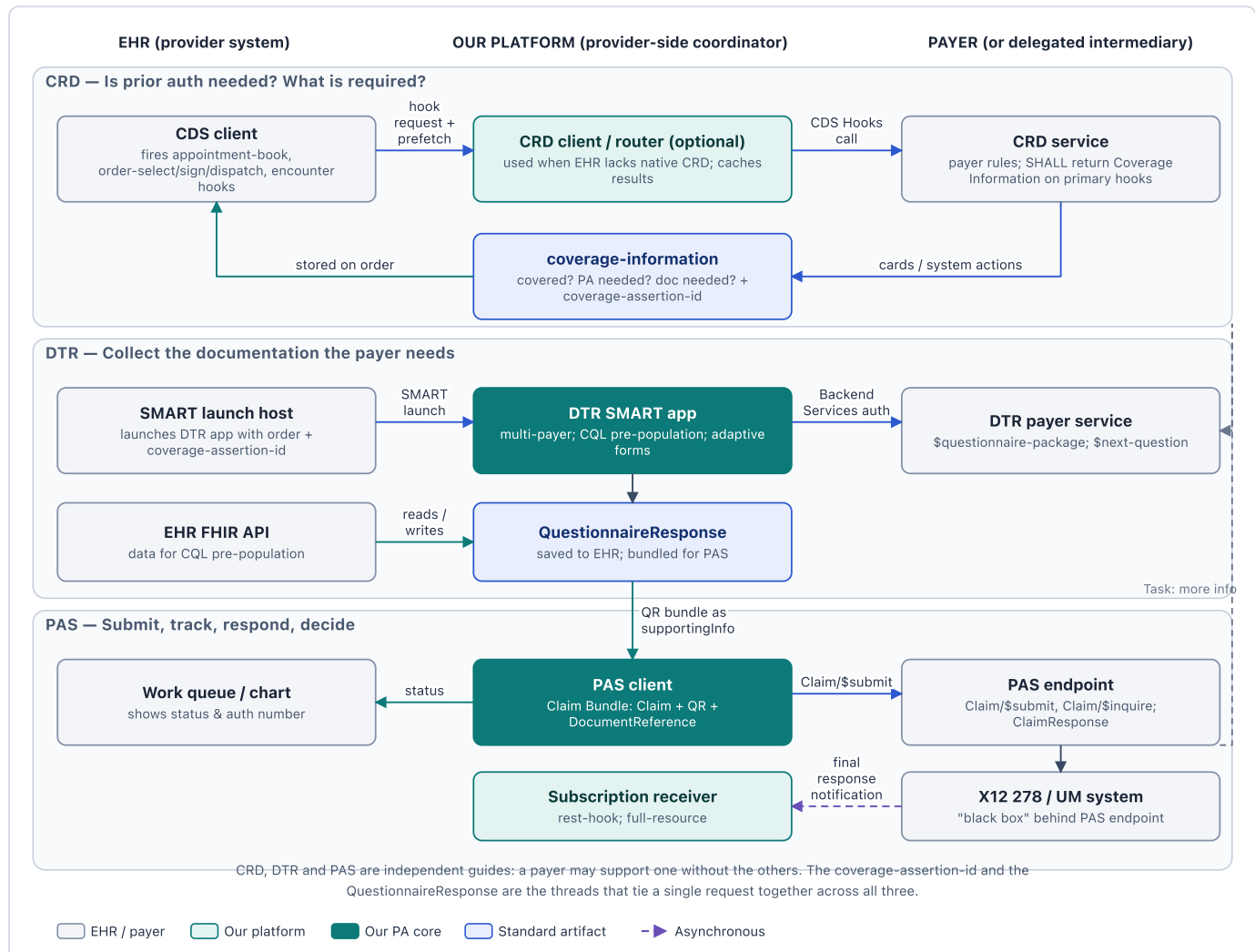


Figure 19. Diagram 8: Relationship between CRD, DTR and PAS and the Platform's role

17.1 Coverage Requirements Discovery (CRD)

Table 31. CRD at a glance (IG 2.2.1)

Purpose	Tell the provider, during ordering or scheduling, whether the service is covered, whether PA is needed, and what documentation or information is needed ^[48,49] .
Actors	CRD client: the EHR, acting as CDS Hooks client. CRD server: the payer's CDS service.
Triggers	CDS hooks: appointment-book, encounter-start, encounter-discharge, order-select, order-dispatch, order-sign. Primary hooks (appointment-book, order-sign, order-dispatch) SHALL return Coverage Information unless erroring or already present ^[49] .
Inputs	Hook context (draft orders, patient, encounter) and prefetch (Patient, Coverage, practitioners, organizations, locations). A short-lived access token lets the server fetch more ^[50] .

Outputs	Cards and system actions. The key artifact is the coverage-information extension on the order: covered (covered not-covered conditional indeterminate), pa-needed (no-auth auth-needed satisfied performpa conditional indeterminate), doc-needed (clinical admin patient conditional indeterminate), info-needed , questionnaire , coverage-assertion-id , satisfied-pa-id , expiry. Other responses include instructions, links, alternates, and launching the DTR SMART app ^[49] Verified .
Resources	ServiceRequest, DeviceRequest, MedicationRequest, NutritionOrder, VisionPrescription, Appointment, Encounter, Coverage, Patient, Practitioner/Role, Organization, Location.
Timing	Synchronous. SHALL respond within the required time 90% of the time: 5 s for most hooks; 10 s for appointment-book and order-dispatch/sign under stated conditions. Clients may abandon late calls or process them asynchronously ^[50] Verified .
Platform implementation Recommended	(1) Consume native CRD results from the EHR (coverage-information on the order), via API, FHIR read or subscription. (2) Optional hook router : where the EHR routes hooks to us, call the payer's CRD on the provider's behalf and return cards. The conformance and liability implications of acting as intermediary need validation with EHR vendors and payers Needs validation . (3) Log every invocation and response; the IG requires both sides to retain CRD logs for disputes ^[50] .
If payer lacks CRD	Payer policy catalog lookup (CPT/HCPCS + plan) returns "required / likely required / unknown" with source citation. Never "not required" without a payer assertion Recommended .

17.2 Documentation Templates and Rules (DTR)

Table 32. DTR at a glance (IG 2.2.0)

Purpose	Collect exactly the documentation the payer requires, pre-filled from EHR data, in a payer-defined Questionnaire ^[51,52] .
Actors	DTR client (a SMART on FHIR DTR app, or DTR built natively into the EHR, "Full EHR"); payer DTR service; the clinician or staff member completing the form ^[52] .
Triggers	A CRD card or system action (launch DTR), a user action on an order, or a PAS additional-information Task.
Inputs	\$questionnaire-package input: Coverage, order resources, optional Questionnaire canonical, context (CRD coverage-assertion-id or PAS transaction reference), changedsince ^[52] .
Outputs	One Questionnaire Package Bundle per form: Questionnaire, CQL Libraries, ValueSets, optional draft QuestionnaireResponse. Final output is a completed QuestionnaireResponse placed in a questionnaireResponseBundle, with information-origin extensions marking auto-populated vs. manual answers ^[52] .
Resources	Questionnaire, QuestionnaireResponse, Library (CQL), ValueSet, Parameters, Bundle; data resources read for CQL (Condition, Observation, Procedure, MedicationRequest, etc.).
Timing	Interactive. Adaptive forms via \$next-question : initial call expected within 5 s; subsequent calls within 1 s, 90% of the time ^[52] Verified .
Security	Payers SHALL require DTR apps / EHRs to authenticate with SMART Backend Services (scopes such as system/questionnaire.rs , system/valueset.rs , system/library.rs). The EHR SHALL restrict data available for auto-population, especially sensitive data ^[52] .
Platform implementation Recommended	A multi-payer DTR SMART app . The IG strongly discourages DTR clients that only work with a single payer ^[52] . It uses an OSS form renderer and CQL engine, saves in-progress QuestionnaireResponses, and writes completed ones back to the EHR (create/update) as the IG requires ^[52] . It is deployed per EHR app program.
If payer lacks DTR	A platform checklist derived from published payer policy, clearly labeled as <i>not DTR</i> , plus attachments. Collected answers go into PAS supportingInfo or X12 275 via partner Recommended .

17.3 Prior Authorization Support (PAS)

Table 33. PAS at a glance (IG 2.2.1)

Purpose	Submit PA requests and receive decisions using FHIR, while allowing X12 278 to be used behind the endpoint where required ^[53,54] .
Actors	PAS client: provider system (EHR or our Platform). PAS server: payer, or an intermediary that converts to X12 278 ^[54] .
Operations	<code>Claim/\$submit</code> (request, update, cancel) and <code>Claim/\$inquire</code> (status, query-by-example). Final results for pended requests are delivered via subscriptions : R5 Backport, PAS Subscription Topic, rest-hook only, full-resource content, one subscription per sending system filtered by <code>org-identifier</code> ^[54] Verified .
Inputs	PAS request Bundle. The first entry SHALL be a Claim; every supporting resource SHALL be referenced from <code>Claim.supportingInfo</code> . Non-FHIR documents SHOULD use DocumentReference; QuestionnaireResponses may be included ^[54] .
Outputs	PAS response Bundle with ClaimResponse first. Item-level review actions (approved, denied, pended, modified via <code>addItem</code>); <code>item.sequence</code> is the tracing identifier ^[54] .
Timing	Target of at most 15 s from user action to response, including network. Otherwise a pended response ^[54] Verified .
Errors	2xx success; 4xx not recoverable by resubmission (OperationOutcome); 5xx temporary, no OperationOutcome ^[54] .
Additional info	PAS Task profile conveys X12 278 response information (PWK codes, LOINC attachment codes, questionnaire code 102089-0 and TRNs) to CDex. The provider responds via <code>\$submit-attachment</code> ^[55] .
Access rules	Payer servers SHALL permit access to PA responses by systems other than the submitter, matching on member ID plus provider NPI ^[54] .
Retention	Pended PAs remain queryable at least 6 months after anticipated completion of the services ^[54] .
Platform implementation Recommended	PAS client with a per-payer profile and version adapter, a subscription receiver endpoint, <code>\$inquire</code> only for reconciliation (the IG says clients SHOULD NOT use inquire while waiting for final results ^[54]), deterministic identifiers, and immutable storage of every Bundle sent and received.
If payer lacks PAS	X12 278 via clearinghouse (FHIR→X12 translation at the partner or by us), or a portal task. CMS enforcement discretion allows FHIR-only PA for entities implementing the CMS-0057-F PA API, but does not compel anyone to accept FHIR ^[29] Verified .

17.4 Synchronous vs. asynchronous

Table 34. Latency expectations by interaction

Interaction	Mode	Budget (source)	Platform design Recommended
CRD hook call	Sync	5 s (10 s some hooks), 90% ^[50]	Warm connections; cache payer metadata; no queue in path
DTR <code>\$questionnaire-package</code>	Sync (interactive)	Not specified in excerpt reviewed Needs validation	Show progress; cache package by version
DTR <code>\$next-question</code>	Sync	5 s initial / 1 s subsequent, 90% ^[52]	Keep session affinity; pre-fetch data
PAS <code>\$submit</code>	Sync then async	≤ 15 s or pended ^[54]	Submit from a worker with a user-visible wait. On timeout, check with <code>\$inquire</code> before any resubmission
PAS final response	Async	Hours to days (payer timeframes) ^[24]	Subscription receiver; deadline timers; reconciliation
X12 278 via partner	Async (often)	Partner-specific Needs validation	Queue plus acknowledgement tracking

17.5 Version management

Payers may implement CMS-recommended versions (CRD/DTR/PAS 2.0.1 or 2.1.0 on CMS's page) or newer ONC-approved versions (2.2.x in the 2026 SVAP)^[28,64]. EHR certification under HTI-4 references 2.0.1^[63]. The Platform must therefore negotiate the version per payer and product line, keep adapters for at least two concurrent versions, and test with Inferno kits for each (CRD 2.0.1/2.2.1, DTR 2.0.1/2.2.0, PAS 2.0.1/2.2.1)^[70] **Recommended**.

18 Prior Authorization Technical Workflow

18.1 Case state machine

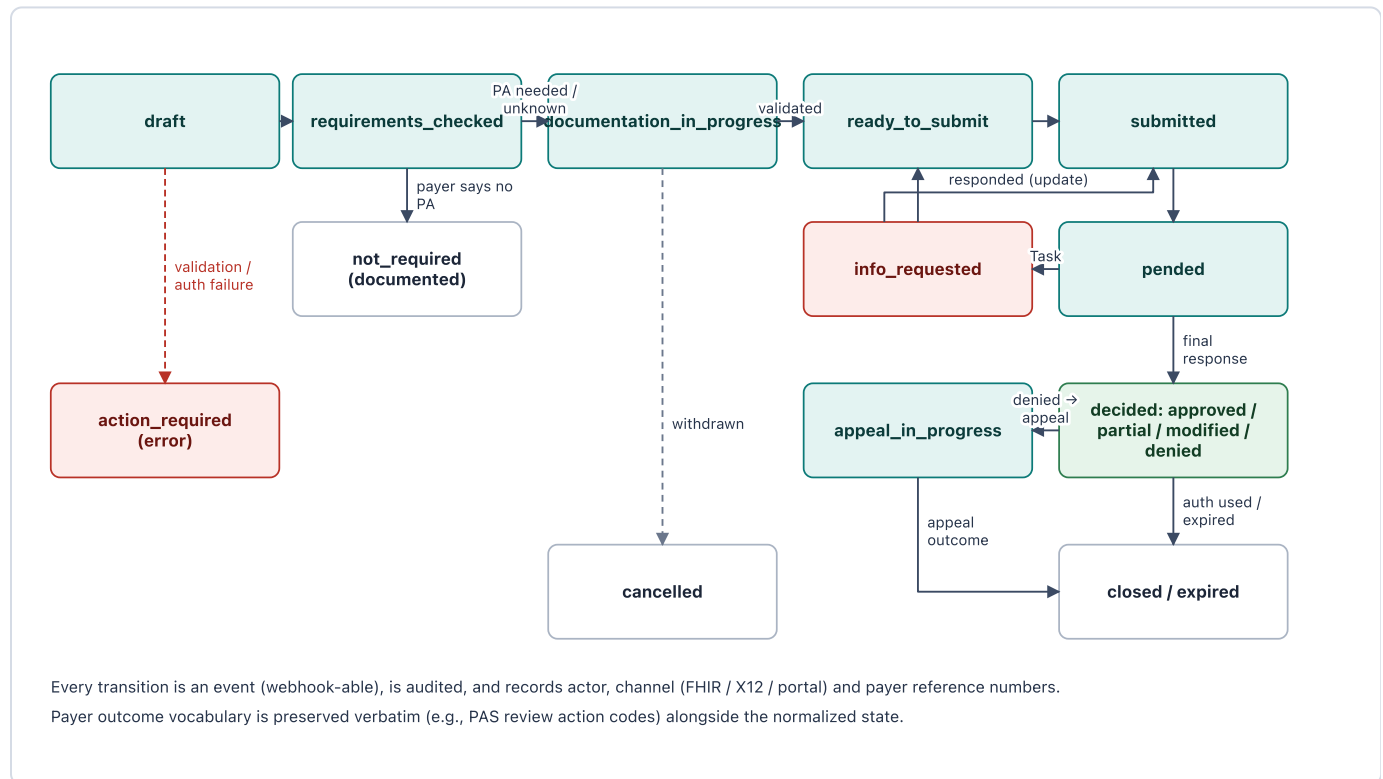


Figure 20. PA case state machine (normalized states; payer vocabulary preserved alongside)

18.2 Sequence

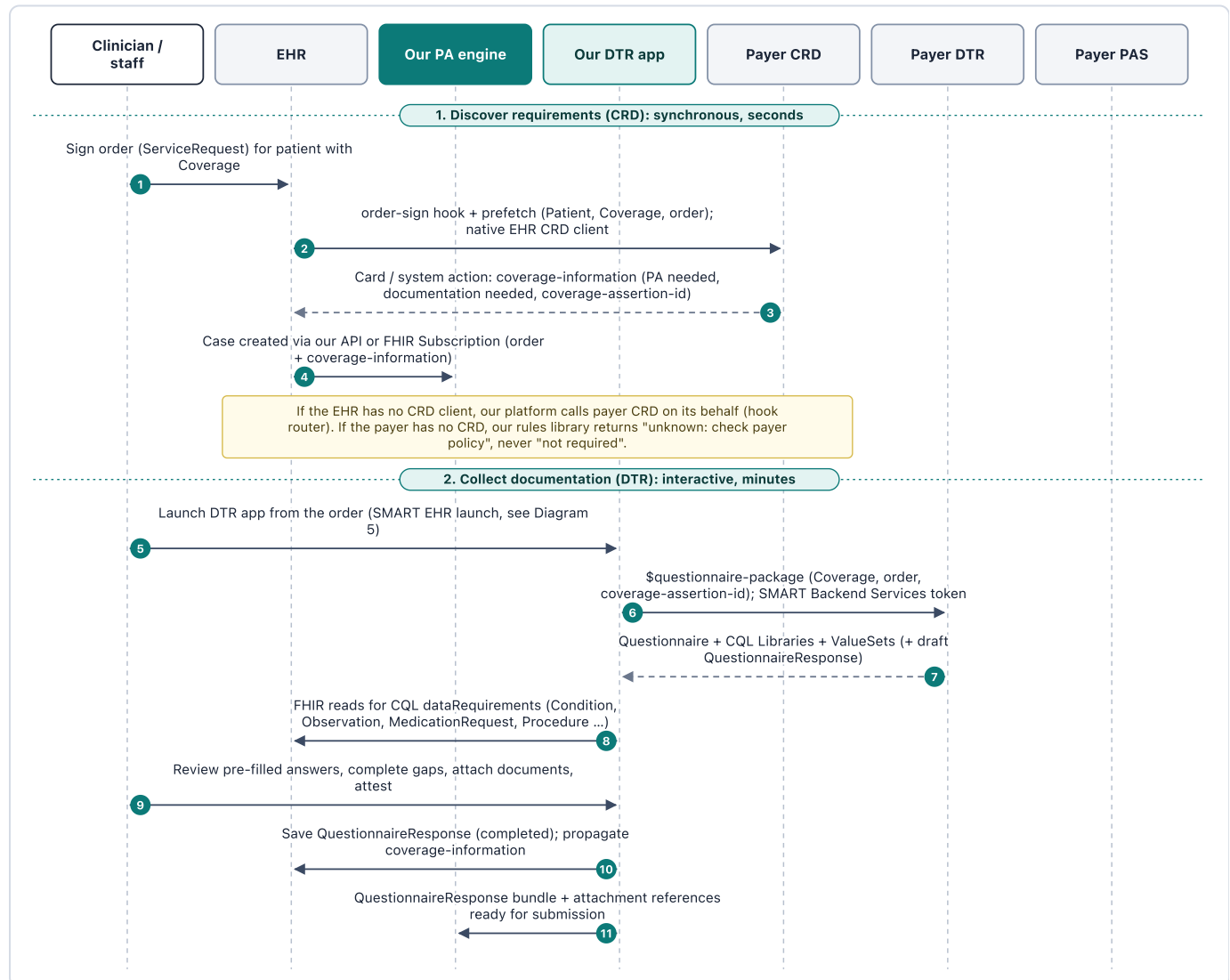


Figure 21. Diagram 9 (part 1): Medical PA sequence: discovery and documentation

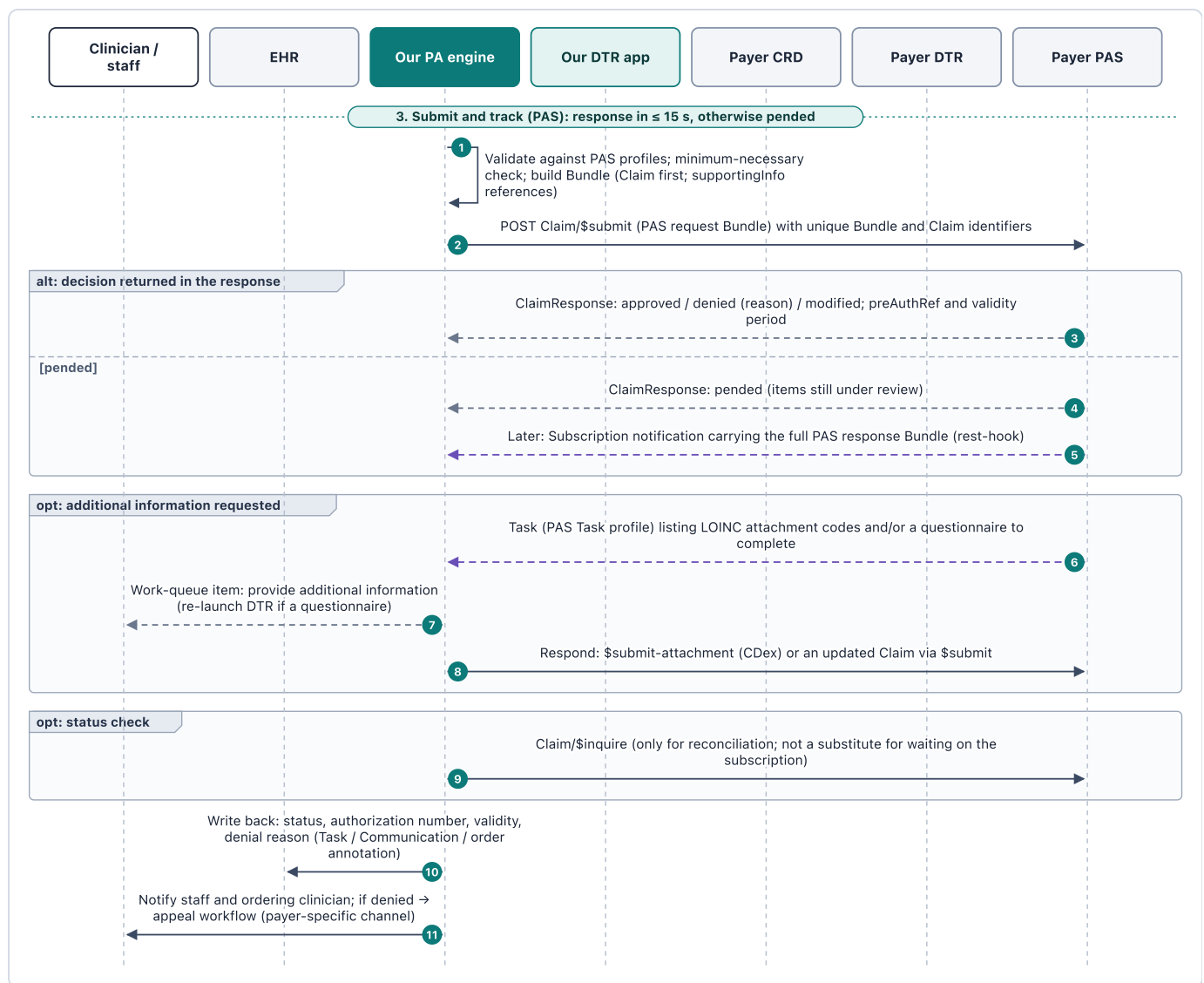


Figure 22. Diagram 9 (part 2): Medical PA sequence: submission, pending, additional information and decision

18.3 Step contracts

Each step below defines the interface contract. "Our API" refers to the Platform API in §19. Authentication (AuthN) and authorization (AuthZ) apply at the calling boundary.

Table 35. Technical step contracts (part 1: intake and requirements)

Step	API / operation	FHIR resources	Actor · Input → Output	AuthN / AuthZ	Validation · Storage	Event · Audit	Retry · Errors
1 Case intake	POST /prior-authorizations or EHR subscription notification / hook	ServiceRequest DeviceRequest MedicationRequest; Patient; Coverage; Encounter	EHR or customer app · order ref + coverage ref → case_id (draft)	OAuth client credentials or SMART user token · tenant + org scope; role <code>pa.create</code>	Refs resolvable; coverage active · ops.pa_case; FHIR copies	<code>pa.case.created</code> · who, patient, order, purpose=payment	Idempotency-Key on POST · 409 duplicate; 422 unresolvable refs
2 Coverage check	Internal; partner 270/271; payer API	Coverage, Organization (payer)	Platform · Coverage → verified plan, payer route	Service identity · payer credential per tenant	Member ID format per payer · Coverage version	<code>pa.coverage.verified</code> · data sent to partner	Backoff on 5xx/timeout · coverage_unverified → staff

Step	API / operation	FHIR resources	Actor · Input → Output	AuthN / AuthZ	Validation · Storage	Event · Audit	Retry · Errors
3 Requirements (CRD)	Consume EHR coverage-information, or call payer CRD (POST {cds-service})	Order + coverage-information extension; Coverage	EHR / Platform · hook context + prefetch → cards; coverage-assertion-id	CDS Hooks JWT; fhirAuthorization token (short-lived, narrow scopes) ^[50]	Response schema; assertion present · CRD log (request/response)	pa.requirements.determined (required / not / unknown) · full CRD exchange retained	No retry beyond budget; late response processed async · "indeterminate" → staff
4 Package (DTR)	POST [payer]/Questionnaire/\$questionnaire-package	Parameters; Bundle (Questionnaire, Library, ValueSet, QR)	DTR app · Coverage + order + context → packages	SMART Backend Services to payer ^[52] ; SMART user launch in EHR	Package structure; canonical versions · cache by canonical version	pa.documentation.started · package ids	Retry 2x on 5xx · no package → checklist fallback
5 Pre-population	EHR FHIR search/read per CQL dataRequirement	Condition, Observation, Procedure, MedicationRequest, DocumentReference, AllergyIntolerance ...	DTR app · data requirements → draft QR	SMART user token (user/patient scopes) · consent + sensitivity filter	Terminology validation · evidence refs + Provenance	— · each read audited (resource types, count)	Paging; 429 honor Retry-After · missing data → manual answers

Table 36. Technical step contracts (part 2: submission and closure)

Step	API / operation	FHIR resources	Actor · Input → Output	AuthN / AuthZ	Validation · Storage	Event · Audit	Retry · Errors
6 Complete & attest	DTR UI; POST /prior-authorizations/{id}/documents	QuestionnaireResponse; DocumentReference; Binary	Clinician/staff · answers + files → completed QR, attachments	SMART user; role pa.attest for attestation	Required items; AV scan; MIME allow-list · QR in EHR + FHIR store; files in S3	pa.documentation.completed · attestation (who/when)	Upload resumable · virus → reject; size > limit → 413
7 Build & validate	Internal	Bundle(PAS): Claim, Patient, Coverage, Practitioner/Role, Organization, QR bundle, DocumentReference, Condition	PA engine · case → PAS Bundle	Service identity	PAS profile validation (IG version per payer); minimum-necessary diff · immutable Bundle in S3 + hash	pa.request.ready · data classes included	— · validation errors → action_required
8 Submit	POST [payer]/Claim/\$submit (or X12 278 via partner; or portal task)	Bundle → Bundle(ClaimResponse)	PA engine · Bundle → response	SMART Backend Services / payer-defined (mTLS etc.) Needs validation	Response profile · pa_submission row	pa.request.submitted · destination, payload hash	5xx/timeout: \$inquire before any resubmit ; 4xx: no retry, fix ^[54]
9 Pended & notifications	Our POST /callbacks/pas/{tenant} (rest-hook); Subscription created once per sending system	Subscription (PAS topic); notification Bundle with full PAS response	Payer → Platform · notification → updated ClaimResponse	Callback auth per payer (token / mTLS) Needs validation ; org-identifier filter ^[54]	Signature/auth; match preAuthRef/identifiers · store response	pa.status.changed · inbound source	Idempotent by notification id · unknown case → quarantine
10 More info	Task received; response via \$submit-attachment (CDex) or updated Claim \$submit	Task (PAS Task profile); DocumentReference; QR	Payer ↔ staff · requested codes → attachments	As step 8	Requested LOINC codes all satisfied · link to request item	pa.info.requested / pa.info.submitted	Deadline timer; escalation
11 Decision & write-back	EHR FHIR create/update (Task, Communication, DocumentReference); our webhooks	ClaimResponse (preAuthRef, preAuthPeriod, item adjudication); Task	Platform → EHR / customers · decision → EHR updates + events	SMART backend to EHR (site-approved scopes)	Decision normalized; payer codes preserved · decision table	pa.decision.receive · write-back result	Write-back retries with backoff; failures → DLQ + staff alert
12 Appeal	POST /prior-authorizations/{id}/appeal → payer channel (portal / payer API / 278 reconsideration) Needs validation	Task; DocumentReference; Communication	Staff · denial + evidence → appeal case	Role pa.appeal	Appeal window dates · appeal record	pa.appeal.file	Deadline timers

18.4 FHIR resources used

Table 37. FHIR resources and their role in the PA workflow

Resource	Role in PA	Where it comes from
Patient	Subject; identifiers for matching; member linkage	EHR (US Core)
Practitioner / PractitionerRole	Ordering and rendering providers (NPI); payer matching on NP ^[54]	EHR
Organization / Location	Provider org, payer org, site of service	EHR; our registry
Coverage	Required input for CRD, DTR and PAS	EHR; eligibility
Encounter	Context for hooks; inpatient admissions	EHR
ServiceRequest / DeviceRequest / MedicationRequest	The order needing authorization; carries coverage-information	EHR
Condition, Observation, Procedure, DiagnosticReport, MedicationStatement / Request	Evidence for criteria (diagnoses, results, prior therapies)	EHR
DocumentReference / Binary	Clinical notes, imaging reports, PDFs as attachments ^[58]	EHR; uploads
Questionnaire / Library / ValueSet	Payer documentation template and logic	Payer DTR
QuestionnaireResponse	Completed documentation; attached to PAS	DTR app → EHR
Claim (use = preauthorization)	The PA request (PAS profiles)	PA engine
ClaimResponse	The decision / status	Payer
Task	Payer request for additional information (PAS Task); internal staff work items	Payer; Platform
Communication	Messages to clinicians / EHR inbox; optional provider-payer messages	Platform
Subscription (Backport)	Pended-response notifications	Platform creates at payer
Provenance	Source and transformation of evidence; who attested	Platform
AuditEvent	Shape for our audit records (exported on request)	Platform
Consent	Restrictions affecting evidence selection	EHR / customer

Deliberately not used as PA drivers: ExplanationOfBenefit (claims history via payer APIs is useful context but not a PA request), CarePlan (unless a payer requires it) and CommunicationRequest (only if a payer's CDex flow requires it) **Recommended**.

19 API Architecture

The Platform exposes two API styles. The first is a **task-oriented REST API** (JSON) for cases, connections, documents and events. It is what most customers integrate with. The second is a **FHIR R4 API** for standards-native consumers, with tenant-scoped SMART authorization **Recommended**.

19.1 Common conventions **Recommended**

Table 38. API conventions

Concern	Convention
Versioning	URL major version (/v1) plus additive changes; deprecations announced with a ≥ 6-month window
Authentication	OAuth 2.0 client credentials with <code>private_key_jwt</code> for servers; SMART / OIDC for user apps. API keys only in sandbox, for quick-start
Authorization	Scopes (<code>pa.read</code> , <code>pa.write</code> , <code>pa.submit</code> , <code>connections.admin</code> , <code>audit.read</code> , ...) plus tenant/org ABAC evaluated per request
Idempotency	<code>Idempotency-Key</code> header required on every POST that creates or submits. Stored 24 h (72 h for submit). A replay returns the original response
Concurrency	<code>ETag</code> / <code>If-Match</code> on case updates to prevent lost updates
Errors	<code>application/problem+json</code> (RFC 9457) with <code>type</code> , <code>title</code> , <code>status</code> , <code>detail</code> , <code>errors[]</code> , <code>trace_id</code> . No PHI in error text
Pagination	Cursor-based (<code>?cursor=...&limit=...</code>)
Rate limits	Per client and per tenant. <code>429</code> + <code>Retry-After</code> . Headers <code>RateLimit-Limit/Remaining/Reset</code>
Async operations	<code>202 Accepted</code> + <code>Location</code> for long-running work (submissions, bulk pulls); status via GET, events via webhooks
Audit	Every call is logged with client, user (if any), tenant, patient references touched, purpose-of-use header (<code>X-Purpose-Of-Use</code> , default <code>PAYMENT</code> for PA endpoints)

19.2 Endpoint catalog

Table 39. API endpoint catalog (v1)

Endpoint	Purpose	Scope	Idempotent
Connections			
POST /v1/connections	Create a connection to a source (EHR, payer, partner) for a tenant/org	connections.admin	Key required
GET /v1/connections · GET /v1/connections/{id}	List / inspect state, capabilities, health, last success	connections.read	Safe
POST /v1/connections/{id}/authorize	Start authorization (returns redirect URL for SMART standalone / admin consent, or registers backend keys)	connections.admin	Key required
POST /v1/connections/{id}/refresh	Force token refresh / health probe	connections.admin	Yes (no side effects beyond refresh)
POST /v1/connections/{id}/sync	Trigger a background sync (backend connections)	connections.admin	Key required
DELETE /v1/connections/{id}	Revoke and delete credentials	connections.admin	Yes
Patients & clinical data (normalized, read-only)			
GET /v1/patients/{id}	Patient summary with identifiers and linked sources	clinical.read	Safe
GET /v1/patients/{id}/coverages	Coverage list with payer routing info	clinical.read	Safe
GET /v1/patients/{id}/conditions medications observations procedures documents	Normalized clinical data with provenance (source, original coding)	clinical.read	Safe

Endpoint	Purpose	Scope	Idempotent
/fhir/r4/{tenant}/...	FHIR R4 read/search (US Core-aligned) with SMART scopes	SMART scopes	Safe (reads)
Prior authorization			
POST /v1/prior-authorizations	Create a case from an order reference (+ coverage, urgency)	pa.write	Key required
GET /v1/prior-authorizations/{id}	Search / get case with timeline, requirements, submissions, decision	pa.read	Safe
GET /v1/prior-authorizations/{id}/requirements	CRD outcome or policy lookup result, with evidence	pa.read	Safe
POST /v1/prior-authorizations/{id}/requirements:refresh	Re-run requirement discovery (e.g., after order change)	pa.write	Key required
GET /v1/prior-authorizations/{id}/questionnaires	DTR packages and current QR status; launch URL for DTR app	pa.read	Safe
PUT /v1/prior-authorizations/{id}/questionnaire-responses/{qrId}	Save in-progress/completed QR (for embedded partners)	pa.write	If-Match
POST /v1/prior-authorizations/{id}/documents	Upload or link a supporting document (returns DocumentReference id)	pa.write	Key required
POST /v1/prior-authorizations/{id}/validate	Dry-run: completeness and profile validation, minimum-necessary diff	pa.read	Safe
POST /v1/prior-authorizations/{id}/submit	Submit via best channel (or a forced channel)	pa.submit	Key required
GET /v1/prior-authorizations/{id}/status	Lightweight status (state, payer status, due dates)	pa.read	Safe
POST /v1/prior-authorizations/{id}/respond	Respond to a payer information request (Task) with documents / QR	pa.submit	Key required
POST /v1/prior-authorizations/{id}/update /cancel	Modify or cancel a submitted request (PAS update/cancel semantics)	pa.submit	Key required
POST /v1/prior-authorizations/{id}/appeal	Open an appeal case (channel per payer)	pa.submit	Key required
GET /v1/payers/{id}/capabilities	Payer registry and CRD/DTR/PAS support by product line	payers.read	Safe
Events, webhooks, audit			
POST /v1/webhooks · GET · DELETE · POST /{id}/rotate-secret	Manage webhook endpoints and signing secrets	webhooks.admin	Key required
GET /v1/events?since=...	Event log (pull model) and replay source	events.read	Safe
POST /v1/webhooks/{id}/replay	Re-deliver events from a cursor / time	webhooks.admin	Key required
GET /v1/audit-logs	Tenant-scoped audit search (who accessed which patient and why)	audit.read (privileged)	Safe
Inbound (called by partners)			
POST /callbacks/pas/{tenant}	PAS subscription notifications (rest-hook)	Payer-specific auth	Idempotent by notification id
POST /cds-services/{service}	CDS Hooks endpoint when acting as hook router (optional)	CDS Hooks JWT	Stateless

19.3 Key API contracts

Create a prior authorization case

```
POST /v1/prior-authorizations
Authorization: Bearer eyJ... (client credentials)
Idempotency-Key: 7c0e...-order-sr-77
X-Purpose-Of-Use: PAYMENT
{
  "organization_id": "org_2x...",
  "patient": { "fhir_ref": "Patient/pat-1",
               "connection_id": "con_epic_01" },
  "order": { "fhir_ref": "ServiceRequest/sr-77" },
  "coverage": { "fhir_ref": "Coverage/cov-123" },
  "urgency": "standard",
  "requested_by": "PractitionerRole/pr-9"
}
```

```
201 Created
Location: /v1/prior-authorizations/pa_01H...
{
  "id": "pa_01H...",
  "state": "draft",
  "payer": { "id": "payer_acme",
             "channels": ["pas","x12_278","portal"] },
  "requirements": { "status": "pending" },
  "due_at": null,
  "links": { "dtr_launch": null }
}
Errors: 400 invalid body · 401/403 · 404 unknown refs
        409 idempotency conflict (different body)
        422 coverage inactive / payer unknown
```

- **Retry:** safe to retry with the same Idempotency-Key.
- **Audit:** case creation event with patient, order and requesting client.

Submit

```
POST /v1/prior-authorizations/pa_01H.../submit
Idempotency-Key: pa_01H...-submit-1
If-Match: "v7"
{ "channel": "auto", // or "pas" | "x12_278"
  | "portal"
  "attestation": {
    "by": "PractitionerRole/pr-9",
    "statement_id": "att-2026-10-01-001" } }
```

```
202 Accepted
Location: /v1/prior-authorizations/pa_01H.../submissions/sub_1
{ "submission_id": "sub_1", "state": "submitted",
  "channel": "pas" }
-- later via webhook pa.decision.received /
pa.status.changed
Errors: 409 case not ready (validation issues listed)
        412 ETag mismatch · 424 payer channel
        unavailable
        (case queued for fallback per policy)
```

- **Semantics:** exactly one payer submission per Idempotency-Key. On an uncertain outcome (timeout), the engine performs `$inquire` before any resubmission.
- **Audit:** payload hash, destination, data classes.

Respond to additional information request

```
POST /v1/prior-authorizations/pa_01H.../respond
Idempotency-Key: pa_01H...-task-3-resp-1
{ "payer_task_id": "Task/abc", "documents": ["doc_9f..."],
  "questionnaire_responses": ["qr_12..."], "note": "PT notes 08/01-09/15 attached" }
→ 202 Accepted { "submission_id": "sub_2", "method": "cdex_submit_attachment" }
```

Webhook delivery

```
POST https://customer.example/hooks
Content-Type: application/json
Platform-Signature: t=1790812345,v1=5f2b... (HMAC-SHA256
                                over "t.raw_body" with endpoint
secret)
Platform-Event-Id: evt_01H...
{ "id": "evt_01H...", "type": "pa.decision.received",
  "created_at": "2026-10-01T14:03:11Z",
  "tenant_id": "ten_...",
  "data": { "prior_authorization_id": "pa_01H...",
            "outcome": "approved",
            "payer_reference": "AUTH-88231",
            "valid_from": "2026-10-01", "valid_to":
"2026-11-30" } }
```

Receiver contract (mirrors the practice Medblocks documents^[13]) **Recommended**:

- Verify the signature over the raw body and reject timestamps older than 5 minutes.
- Return 2xx within 5 s. Process asynchronously.
- Deduplicate by event id.
- Fetch full details via the API. Payloads carry IDs and status, not clinical content (minimum necessary).

Delivery: retries with exponential backoff for 72 h. The endpoint is auto-disabled after sustained failure and the tenant admin is notified. Delivery log and replay API are available.

Event catalog (initial)

```
connection.state_changed · connection.token_refresh_failed · data.sync.completed|failed · pa.case.created ·
pa.requirements.determined · pa.documentation.completed · pa.request.submitted · pa.status.changed ·
pa.info.requested · pa.decision.received · pa.deadline.at_risk · pa.appeal.filed|decided ·
pa.writeback.failed
```

20 Connector Architecture

All vendor-specific behaviour lives in connectors. The core platform depends only on a connector interface and on normalized FHIR. Adding an EHR, payer or partner is therefore a plugin release, not a core change

Recommended

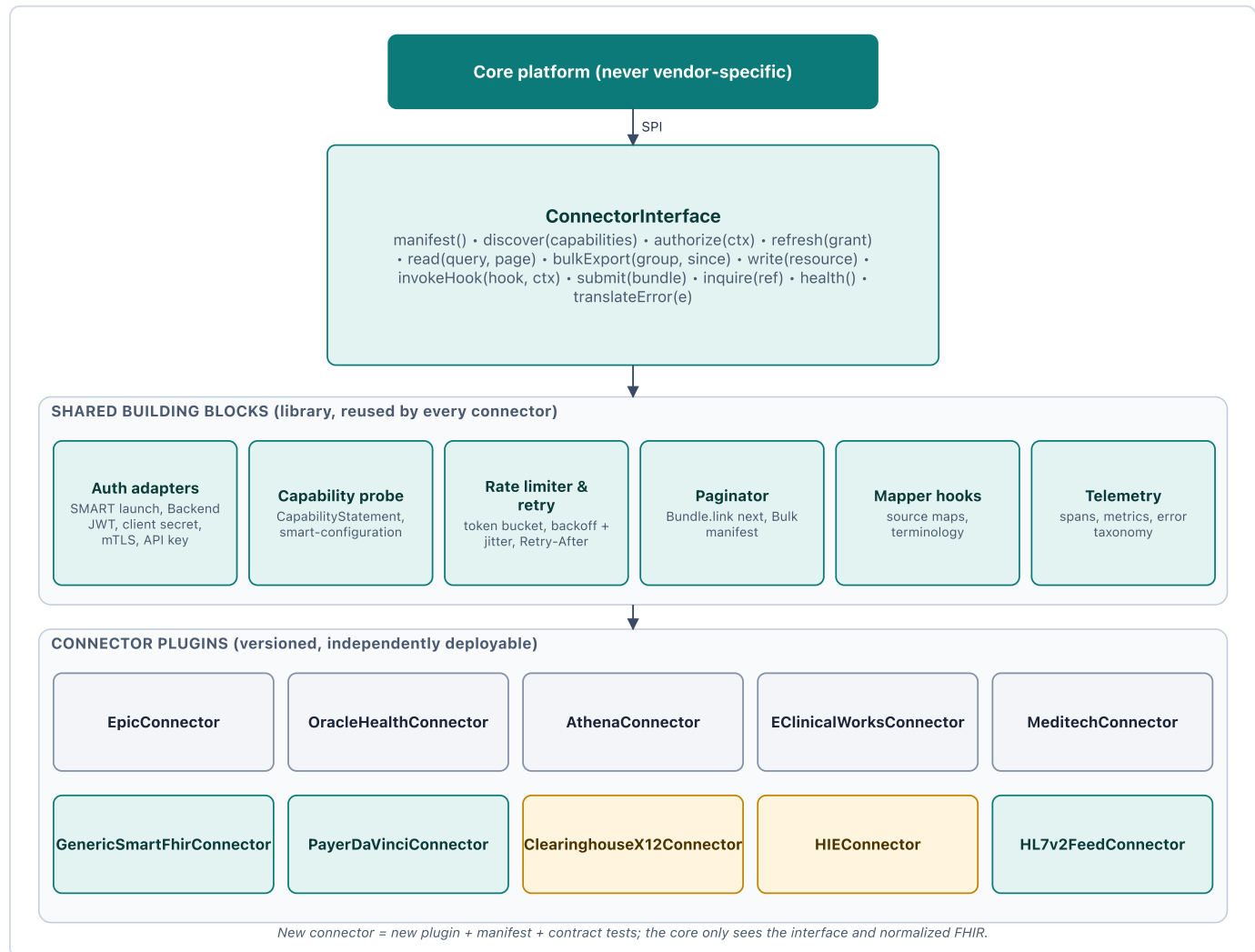


Figure 23. Connector framework: interface, shared building blocks and plugins

20.1 Interface design

```
interface Connector {
  manifest(): ConnectorManifest // id, version, kind (ehr|payer|clearinghouse|hie), supported IG versions,
                                // auth methods, rate-limit defaults, required config schema
  discover(cfg): Capabilities // reads CapabilityStatement, .well-known/smart-configuration, CDS
  authorize(ctx): Grant // launch / backend JWT / client secret / mTLS; returns token refs (vault)
  refresh(grant): Grant
  read(q: FhirQuery, page?): Page<Resource>
  bulkExport(group, since?): ExportJob // optional capability
  write(resource, mode): WriteResult // optional; EHR write-back
  invokeHook(hook, ctx): CdsResponse // optional; CRD
  questionnairePackage(params): Bundle // optional; DTR
  submit(bundle): SubmitResult // optional; PAS / X12 via partner
  inquire(ref): InquiryResult // optional
  subscribe(topic, endpoint): SubRef // optional
  health(): HealthReport // synthetic probe
  translateError(e): PlatformError // maps vendor errors to the platform error taxonomy
}
```

20.2 Cross-cutting behaviours

Table 40. Connector cross-cutting behaviours

Behaviour	Design Recommended
Authentication adapters	SMART EHR/standalone launch (PKCE), SMART Backend Services (private_key_jwt with RS384/ES384), client secret (only where mandated), mTLS client certs, API keys (partners), SFTP keys (legacy batch). Credentials are held as vault references per tenant.
Capability discovery	On connect and nightly: CapabilityStatement, SMART configuration, CDS Hooks discovery, supported IG versions. Stored as a versioned capability snapshot; routing uses the snapshot.
Rate limiting	Token bucket per (tenant, endpoint) plus a global cap per vendor endpoint. Priority lanes: interactive > PA background > bulk.
Retries & backoff	Exponential backoff with full jitter; honour Retry-After ; max attempts per error class; never retry non-idempotent calls without an idempotency guard (PAS: inquire first).
Pagination	Follow Bundle.link[next] ; cap page size; checkpoint cursors to resume after failure; Bulk manifest polling with backoff.
Token refresh	Refresh at 80% of lifetime; single-flight lock per grant; on failure set connection refresh_failed and emit an event.
Error translation	Map to a taxonomy: transient , auth , permission , not_found , validation , business_rule , partner_down , rate_limited , each with a retry policy and owner.
Source-specific mapping	Mapping packs versioned with the connector: identifier systems, extensions, local code maps. Golden-file tests per vendor.
Observability	OpenTelemetry spans with connector, tenant hash, endpoint and outcome. Metrics: latency, error rate by class, throttle rate, token refresh failures. Logs with redaction; no bodies at INFO.

20.3 Adding a new connector without core changes

1. Create the plugin from the template; declare the manifest (capabilities, auth methods, config schema).
2. Implement only the capabilities the source supports. Unsupported operations return **capability_not_supported**, and routing falls back.
3. Add a mapping pack and golden fixtures (recorded sandbox responses, scrubbed).
4. Pass the contract test suite (shared across all connectors) and the relevant Inferno kits.
5. Release behind a feature flag per tenant; promote through readiness levels: *lab* → *sandbox* → *pilot* → *production*.

21 Security & Compliance

How to read compliance statements in this document

No architecture is "HIPAA compliant" by itself. HIPAA obligations fall on **organizations** (covered entities and business associates). They are met through administrative, physical and technical safeguards, documented policies, workforce training, risk analysis and contracts. This section describes the **controls and organizational requirements** the Platform needs so that we, as a business associate, and our customers can meet their obligations. Legal interpretation must be confirmed by qualified counsel **Needs validation**.

21.1 Regulatory baseline

Table 41. Regulatory and assurance baseline

Requirement	What it means for us	Label
HIPAA Privacy Rule	We may use and disclose PHI only as our BAAs permit. PA is a payment activity: "utilization review activities, including precertification and preauthorization" ^[93] . The minimum necessary standard therefore applies to PA disclosures; its treatment exception covers disclosures to providers for treatment, not to payers for payment ^[94] .	Verified
HIPAA Security Rule	Administrative, physical and technical safeguards, including access control, audit controls, integrity, person/entity authentication and transmission security. Encryption is an "addressable" specification today ^[88] . Documentation retained 6 years ^[89] . NIST SP 800-66r2 maps the Rule to controls ^[98] .	Verified
Security Rule update	The NPRM (6 Jan 2025) would, among other things, remove the addressable/required distinction ^[95] . The Fall 2025 Unified Agenda lists it as a Long-Term Action with final action "07/2027" ^[96] . Not in effect. Recommended: design to the stricter proposed posture now (encryption everywhere, MFA, asset inventory, regular vulnerability scanning and pen testing).	Proposed rule / Recommended
Breach Notification Rule	Covered entities notify individuals without unreasonable delay and no later than 60 calendar days after discovery ^[90] . HHS: contemporaneously for 500+; annual log for fewer than 500 ^[91] . Business associates notify the covered entity no later than 60 days after discovery ^[92] . Our BAAs will likely require much shorter contractual windows Needs validation .	Verified
HITECH	Extended Security Rule obligations and breach notification to business associates, making them directly liable Industry-standard .	Industry-standard
42 CFR Part 2	SUD treatment records from Part 2 programs carry additional restrictions. The 2024 final rule aligns much of Part 2 with HIPAA; compliance date 16 Feb 2026 ^[97] . The Platform must tag and segment such data.	Verified
Business Associate Agreements	A BAA with each covered-entity customer. Sub-BAAs with every subcontractor that touches PHI: cloud (AWS BAA; HIPAA-eligible services only ^[101]), clearinghouse, observability vendor if PHI could reach it, support tooling.	Industry-standard
SOC 2 Type II	An AICPA attestation over the Trust Services Criteria ^[99] . Expected by most health-system buyers Inferred . Plan a Type I at pilot and a Type II at production.	Recommended
HITRUST	A framework and assessment/certification program ^[100] . Often requested by payers and large IDNs Inferred . Plan for enterprise stage.	Recommended
State privacy laws	State laws may be stricter than HIPAA for certain data (e.g., reproductive, mental health, HIV) Needs validation . They need data tagging and policy hooks.	Needs validation

21.2 Security architecture

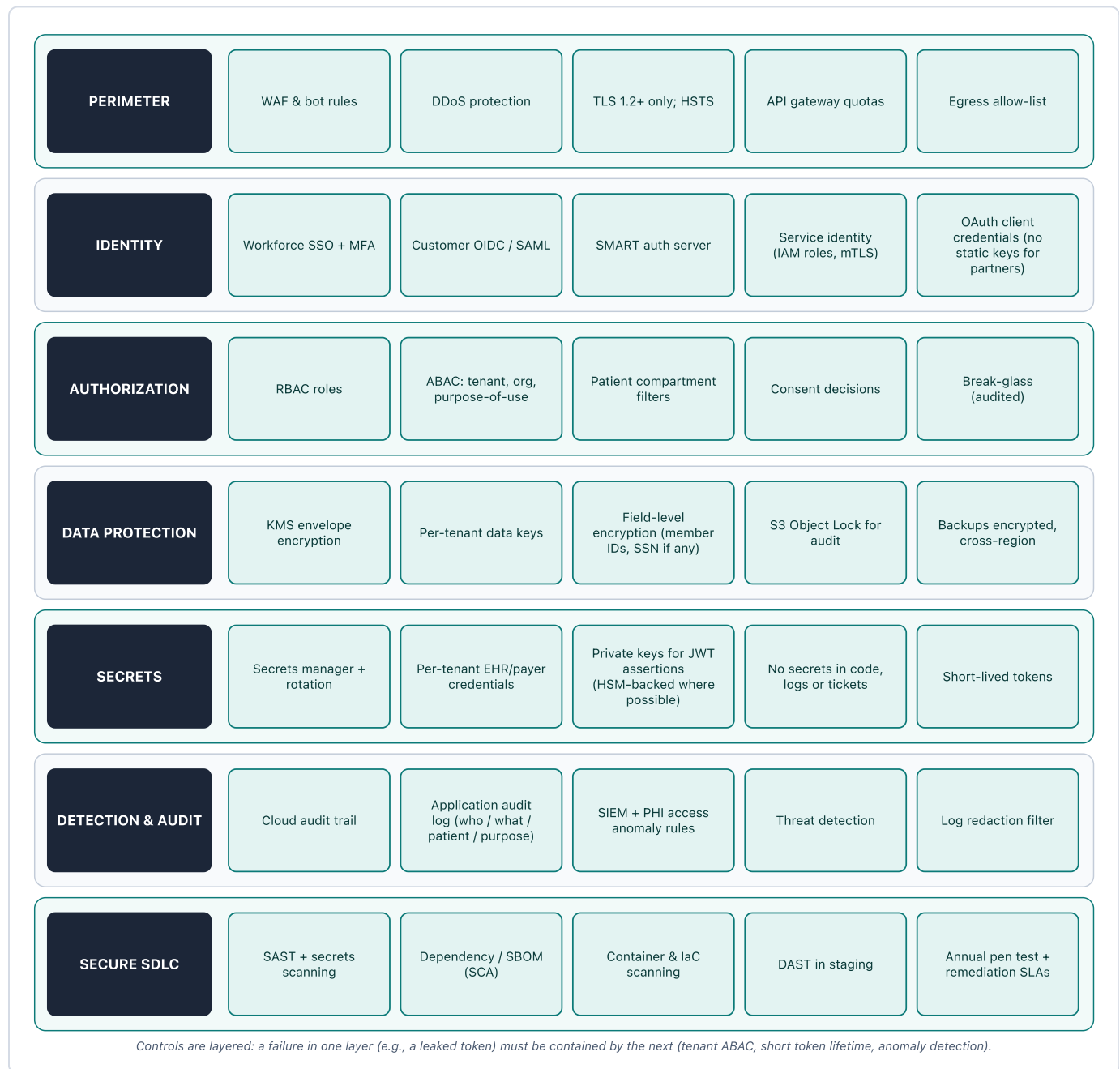


Figure 24. Diagram 11: Layered security architecture

Table 42. Security controls by domain

Domain	Controls Recommended	Maps to (examples)
IAM	Workforce SSO with phishing-resistant MFA; no shared accounts; just-in-time privileged access with approval; quarterly access reviews; separate identities for prod; break-glass accounts sealed and alarmed	164.312(a), (d)
RBAC	Roles: PA staff, clinician, org admin, tenant admin, developer, auditor, platform support (no default PHI access), platform SRE (infra only)	164.308(a)(4)

Domain	Controls Recommended	Maps to (examples)
ABAC	Attributes: tenant, organization, facility, patient compartment, purpose-of-use (PAYMENT, TREATMENT, OPERATIONS), data sensitivity tags, consent state. A central policy engine with policy-as-code, unit-tested	Minimum necessary ^[94]
OAuth / SMART	PKCE; private_key_jwt; short-lived access tokens; refresh-token rotation; sender-constraint where supported; exact redirect URIs; no password grant ^[71]	164.312(d)
Token security	Tokens in an encrypted vault (KMS envelope), never in logs or the browser; single-flight refresh; revocation on connection delete	164.312(a)(2)(iv)
Consent	Consent and restriction records drive evidence filters. Part 2 and state-sensitive data excluded from payer bundles unless permitted. Every exclusion is logged	Part 2 ^[97]
Tenant isolation	Tenant claim required on every request; row-level security; FHIR partitions; per-tenant KMS keys; isolation tests in CI (§23)	164.312(a)
Encryption	TLS 1.2+ everywhere (external and internal); at rest with KMS (RDS, S3, EBS, backups); field-level encryption for high-risk identifiers	164.312(a)(2)(iv), (e)
KMS & key rotation	Customer-managed keys; automatic annual rotation minimum; per-tenant data keys for pooled data; key-usage audit; BYOK option for dedicated tier	—
Secrets management	Secrets Manager with rotation; per-tenant secret paths for EHR/payer credentials; JWT signing keys non-exportable where supported; secret scanning in CI	—
Audit logging	Application audit (who, what, which patient, purpose, result), append-only and hash-chained; cloud control-plane audit (CloudTrail org trail) to a separate log-archive account with Object Lock	164.312(b)
PHI access controls	Support staff have no standing PHI access; ticket-bound, time-boxed elevation; session recording for console access; customer-visible access logs	164.308(a)(3)
Least privilege	Per-service IAM roles; deny-by-default security groups; no wildcard permissions; SCPs at the organization level	—
Network segmentation	Private subnets for compute and data; no public IPs on workloads; VPC endpoints for AWS services; egress allow-list via proxy; separate accounts per environment	—
WAF & API gateway	Managed rule sets, rate-based rules, bot control on login; schema validation; request size limits	—
Vulnerability management	SAST, SCA/SBOM, container and IaC scanning on every PR; DAST in staging weekly; runtime vulnerability scanning; patch SLAs (critical ≤ 7 days Estimate)	164.308(a)(1)
Penetration testing	Independent test before pilot and annually thereafter, plus after major changes; includes tenant-isolation and SMART flow abuse cases	—
Backup & DR	Automated backups, point-in-time recovery, cross-region copies, quarterly restore tests (§22, §24)	164.308(a)(7)
Incident response	Runbooks, on-call, severity matrix, forensic log retention, customer notification clauses, tabletop exercises twice a year	164.308(a)(6)
Breach handling	Four-factor risk assessment workflow; notify covered entity within contractual and regulatory timelines ^[92] ; evidence preservation	Subpart D
Data retention & deletion	Retention per data class (§14); deletion/return at contract end per BAA; crypto-shredding via tenant key deletion for pooled data; deletion certificates	BAA terms
Logging restrictions	No PHI in application logs, metrics or traces by default; structured logging with an allow-list of fields; PHI-in-logs detection in CI and in production sampling	Minimum necessary

21.3 PHI data flow and boundaries

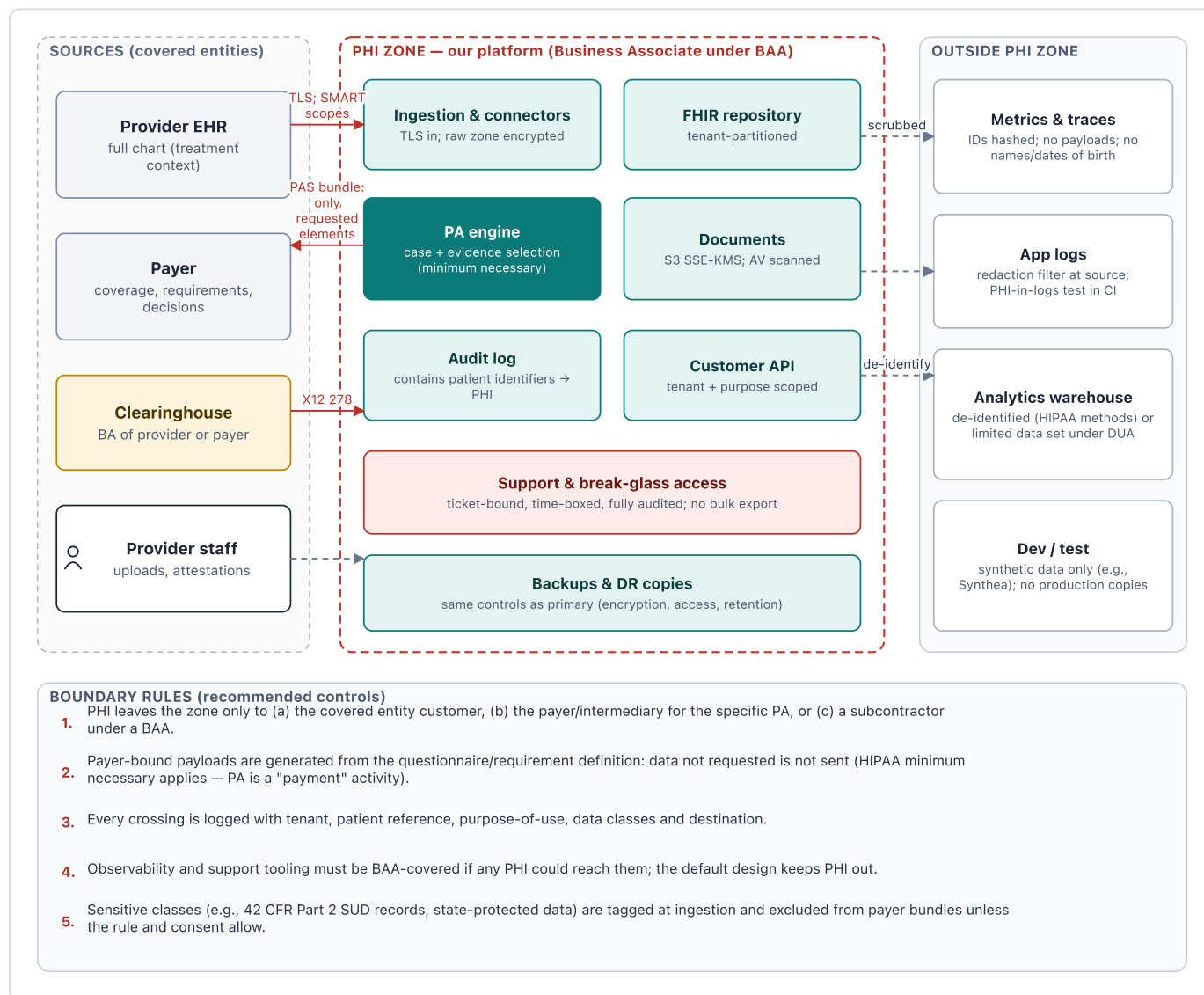


Figure 25. Diagram 14: PHI boundaries and permitted crossings

21.4 Compliance program roadmap Recommended

Table 43. Compliance milestones

Stage	Deliverables
Before any PHI	HIPAA risk analysis; policies (access, incident, retention, vendor management); workforce training; AWS BAA; security officer and privacy officer named; BAA template
Pilot	Pen test; SOC 2 Type I (or readiness assessment); customer security questionnaires; DR test; tabletop exercise
Production	SOC 2 Type II observation period; continuous control monitoring; annual risk analysis
Enterprise	HITRUST assessment if required by payers or IDNs; customer-managed keys; dedicated deployments

22 Cloud Architecture

AWS is the reference cloud. All PHI-processing services must be on AWS's HIPAA-eligible list and covered by an executed AWS BAA^[101]. The design is portable to other clouds with equivalent managed services.

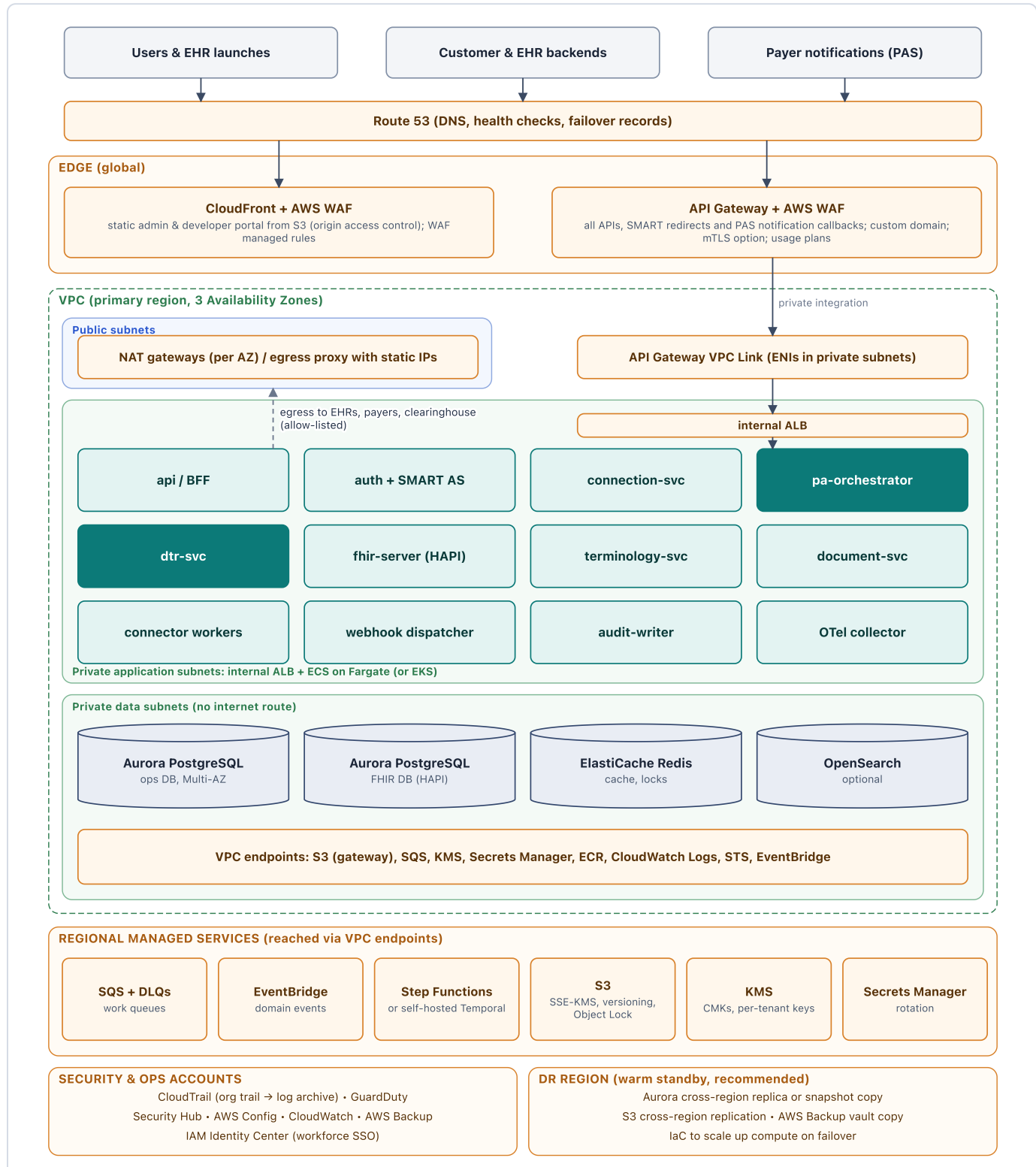


Figure 26. Diagram 13: Production AWS deployment (reference)

22.1 Why each service

Table 44. AWS services and rationale

Service	Why it is used	Alternatives
Route 53	DNS, health checks, DR failover records	—
CloudFront + WAF	Serve static admin/developer portals from S3; edge protection. Not used to cache API responses containing PHI	Direct S3 website (not recommended)
API Gateway + WAF	Single ingress for APIs, SMART redirects and payer callbacks; throttling, usage plans, mTLS option; private integration via VPC Link to an internal ALB	Public ALB + WAF (simpler, fewer features)
ECS on Fargate	Containers without node management; task-level IAM roles; good fit for a modular monolith plus workers	EKS when the team has Kubernetes depth or needs its ecosystem
Aurora PostgreSQL	Operational DB and HAPI FHIR DB; Multi-AZ; PITR; RLS support; encryption with KMS	RDS PostgreSQL (lower cost at small scale)
ElastiCache (Redis)	Rate-limit buckets, locks, short-lived caches	DynamoDB for some patterns
SQS (+ DLQs)	Durable work queues with at-least-once delivery ^[115] and dead-lettering	MSK/Kafka for event streaming at scale
EventBridge	Domain event bus fan-out to internal consumers and webhook dispatcher	SNS
Step Functions / Temporal	Durable case workflows with timers and human-task waits	Self-hosted Temporal on ECS/EKS, or Temporal Cloud Needs validation (BAA)
S3	Documents, raw payloads, exports, audit archive; SSE-KMS; versioning; Object Lock for audit	—
KMS	Envelope encryption; per-tenant keys; signing keys for JWT assertions where supported Needs validation	CloudHSM for stricter key custody
Secrets Manager	EHR/payer credentials, webhook secrets, DB credentials with rotation	—
CloudWatch + OpenTelemetry	Metrics, logs, traces via the OTel collector; alarms	BAA-covered third-party APM
CloudTrail, GuardDuty, Security Hub, Config	Control-plane audit, threat detection, posture management	—
VPC, subnets, security groups, NAT, VPC endpoints	Network isolation; private access to AWS APIs; controlled egress with static IPs (payers may allow-list IPs Needs validation)	Egress proxy appliance
IAM / IAM Identity Center / Organizations	Least-privilege roles; workforce SSO; account separation and SCPs	—
AWS Backup	Central backup policies, vault lock, cross-region copies	—

Deliberately excluded from the MVP: HealthLake (see §13), OpenSearch (until work-queue search needs it), Kinesis/MSK (until event volume needs it), Cognito (use a workforce/customer IdP with enterprise SSO features; Cognito is HIPAA-eligible^[101] and acceptable if chosen).

22.2 Environments

Table 45. Development, staging and production environments

Environment	Purpose	Data	Connectivity	Controls
Development	Feature work, ephemeral preview stacks	Synthetic only (Synthea, Da Vinci RI data)	Vendor sandboxes; Da Vinci reference payer/provider ^[62]	Separate AWS account; no production credentials
Staging	Integration, performance, DAST, release candidates	Synthetic; customer test patients from non-prod EHRs (under BAA if PHI-like) Needs validation	EHR customer test environments; payer test endpoints	Prod-like config; separate keys; change control
Production	Customer workloads	PHI	Production EHR and payer endpoints	Separate account(s); JIT access; full monitoring
DR (region 2)	Recovery	Replicated backups	Standby	Same controls as prod

22.3 Resilience targets Estimate

Table 46. Recovery objectives (initial targets)

Tier	Availability (API)	RPO	RTO	Approach
MVP / pilot	99.9% monthly	≤ 15 min	≤ 8 h	Multi-AZ; PITR; cross-region backups; rebuild via IaC
Production	99.9–99.95%	≤ 5 min	≤ 4 h	Warm standby DB replica in second region
Enterprise	99.95%+	≤ 1 min	≤ 1 h	Active-passive with automated failover runbooks

U.S.-only regions for data residency. A dedicated-tier customer may choose its region.

23 Multi-Tenancy

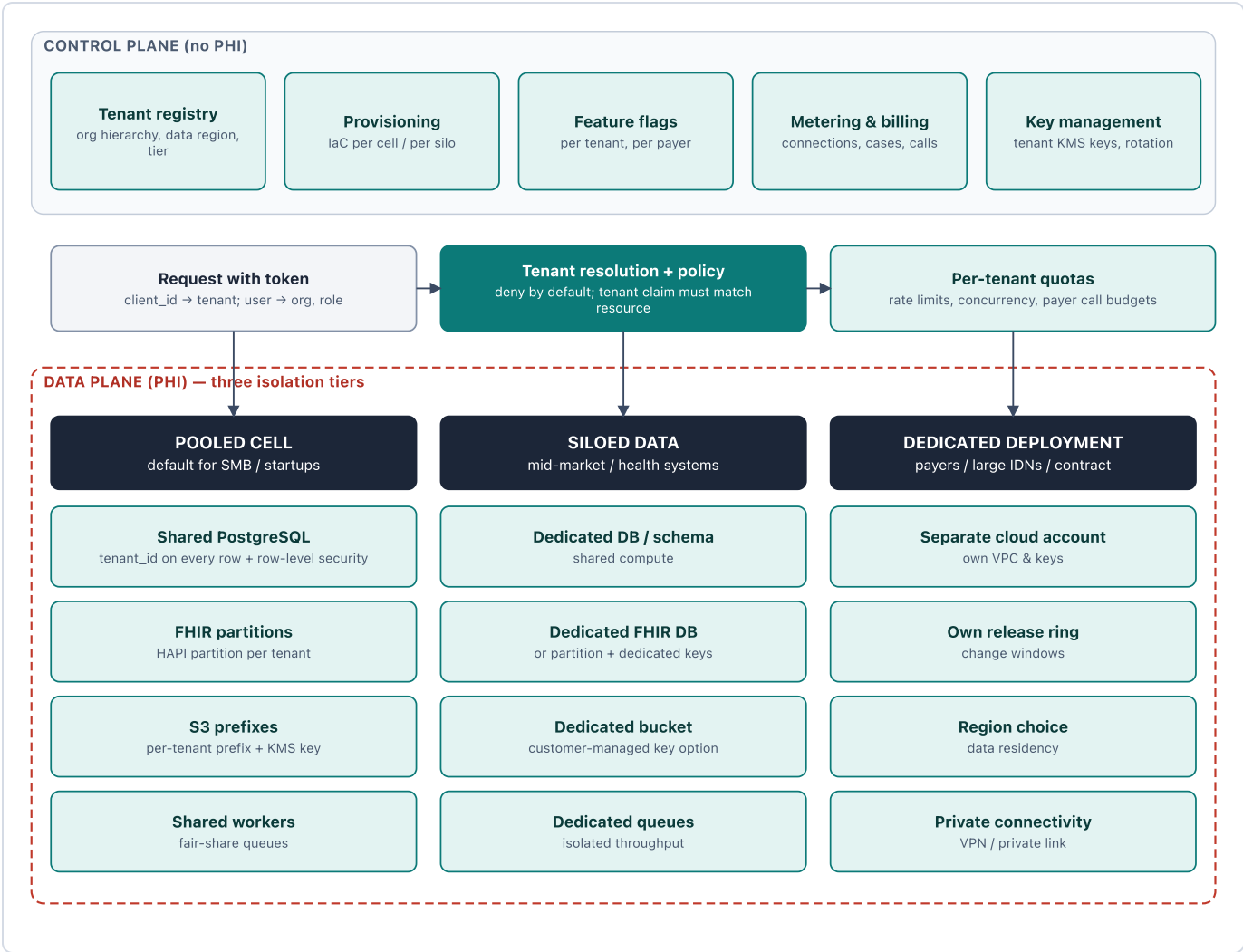


Figure 27. Diagram 12: Multi-tenant architecture with three isolation tiers

23.1 Isolation models compared

Table 47. Tenant isolation options

Model	Isolation strength	Cost / ops	Risks	Appropriate when Recommended
Shared database, tenant_id + RLS	Logical; depends on correct policy everywhere	Lowest	A missing filter leaks data. Mitigate with RLS enforced at the DB, mandatory tenant context and CI isolation tests	Default for SMB and startups; pilot
Separate schema per tenant	Stronger logical separation	Medium (migrations × N)	Schema sprawl beyond hundreds of tenants	Mid-size customers wanting separation without dedicated infrastructure
Separate database	Strong data isolation; independent backup and restore	Higher	Fleet management	Health systems; customers with contractual isolation terms

Model	Isolation strength	Cost / ops	Risks	Appropriate when Recommended
Separate infrastructure (account / VPC)	Strongest; blast-radius isolation; own keys and release ring	Highest	Operational overhead; version drift	Payers, large IDNs, residency or BYOK requirements

23.2 What is isolated per tenant

Table 48. Per-tenant isolation checklist

Asset	Mechanism Recommended
Data	RLS / schema / DB per tier; HAPI partition per tenant ^[109] ; S3 prefix + tenant KMS key
Connections	Connection records carry tenant_id; connectors never share grants across tenants
API clients / keys	OAuth clients bound to one tenant; environment-scoped key prefixes (as Medblocks does for sandbox/live ^[14])
Secrets	Secrets Manager paths <code>/tenants/{id}/...</code> with IAM conditions on tags
Audit	Audit partitioned by tenant; tenant admins see only their own; platform-wide audit restricted
Rate limits	Per-tenant buckets and payer call budgets; noisy-neighbour protection in queues (fair share)
Feature flags	Per tenant, per payer, per connector version
Payer / EHR credentials	Bring-your-own client IDs supported; otherwise platform credentials scoped per tenant registration
Billing / metering	Metered events (cases, submissions, connections, API calls) keyed by tenant; exported to billing

24 Reliability & Observability

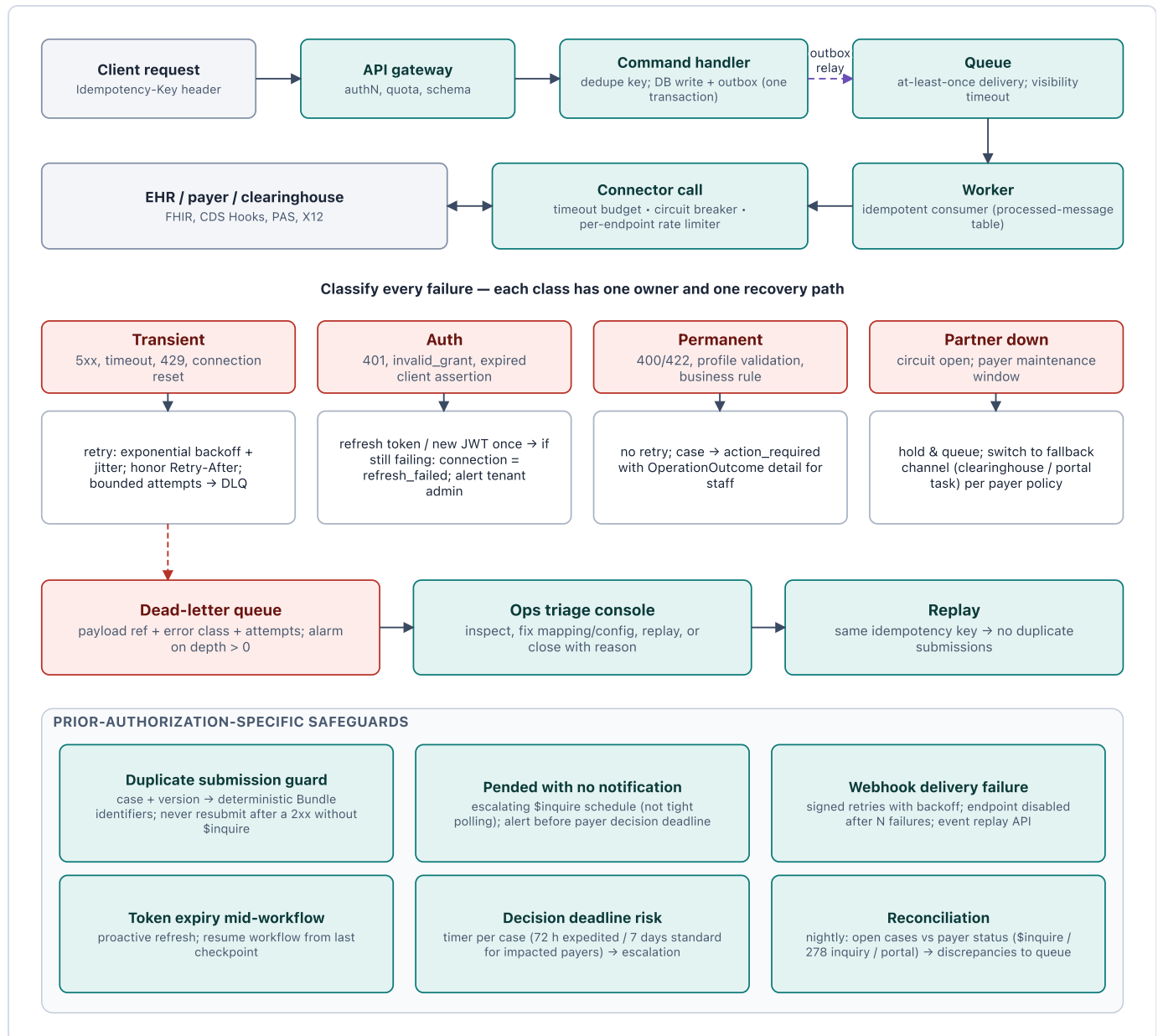


Figure 28. Diagram 10: Failure, retry and error architecture

24.1 Reliability mechanisms

Table 49. Reliability mechanisms

Mechanism	Design Recommended
Availability targets	See §22.3. SLOs are defined per journey: case creation, DTR launch, submission, write-back.
Retries	Per error class (Diagram 10); exponential backoff with jitter; bounded attempts; honour Retry-After.
Dead-letter queues	Every queue has a DLQ; alarm on depth > 0 for PA queues; triage console with replay.
Idempotency	API idempotency keys; idempotent consumers (processed-message table); deterministic PAS identifiers; inquire-before-resubmit.
Circuit breakers	Per endpoint; open on error-rate or latency thresholds; half-open probes; route to fallback channel.

Mechanism	Design Recommended
Connection health checks	Synthetic probes (metadata, token, minimal read) every 5–15 min per connection Estimate ; health score shown on cases.
Token expiration	Proactive refresh; <code>refresh_failed</code> state; admin notification with re-authorize link.
Webhook retry	Backoff schedule over 72 h; auto-disable plus notification; delivery log.
Event replay	Events retained 30–90 days; replay by cursor or time to a webhook or via <code>GET /events</code> .
Job recovery	Durable workflows resume after deploys and crashes; checkpointed pagination.
Data reconciliation	Nightly: open cases vs payer status; write-back verification; source record counts vs synced.
Source (EHR) outage	Queue reads; surface "EHR unavailable" on cases; allow manual evidence upload; resume automatically.
Payer outage	Circuit open → hold with deadline awareness → fallback channel if the deadline is at risk (per tenant policy) → staff notification.

24.2 Metrics and example alert thresholds Estimate

Table 50. Observability: key metrics and alerts

Signal	Metric	Example alert
Connector failures	Error rate by connector/endpoint/class	> 5% for 10 min, or any <code>auth</code> class spike
Authorization failures	401/403 from sources; SMART launch failures	> 3 consecutive launch failures per tenant
Token refresh failures	Count of <code>refresh_failed</code> transitions	Any, for backend connections; daily digest for patient connections
Payer failures	PAS 5xx/timeout rate; pending-without-notification age	5xx > 2% for 15 min; pending > payer SLA – 24 h
FHIR validation failures	Profile validation errors per source and payer	Sudden increase > 3× baseline (mapping regression)
Latency	P95 CRD round trip; DTR package load; \$submit round trip	CRD P90 > 5 s ^[50] ; \$submit P95 > 15 s ^[54]
Queue depth / age	Messages visible and age of oldest by queue	PA queue oldest > 5 min; DLQ > 0
Webhook failures	Delivery failure rate per endpoint	> 20% for 30 min → notify tenant
PHI access anomalies	Patients accessed per user per hour; off-hours access; bulk reads	> 3σ above user baseline; any break-glass use
Job failures	Workflow failures, stuck workflows	Any stuck > 1 h
Deadline risk	Cases within 24 h of internal SLA without progress	Any → staff queue escalation
Data quality	Unmapped codes %, pre-population fill rate	Fill rate drop > 20% week over week

25 Admin / Developer Platform

25.1 Admin console Recommended

Table 51. Admin console capabilities

Area	Capabilities	Stage
Tenants & orgs	Create tenants, org hierarchy, NPIs/TINs, isolation tier, feature flags	MVP
Users & roles	SSO configuration, role assignment, access reviews export	MVP
Connections	Catalog, create/authorize, health, capability snapshot, pull history (as Medblocks exposes for pulls ^[12])	MVP
Payers	Registry, per-product channel configuration, onboarding status, test results	MVP
Work queue	Filter by state, payer, due date, assignee; bulk assign; SLA indicators	MVP
Webhooks	Endpoints, secrets rotation, delivery log, replay	MVP
Audit viewer	Search by patient, user, case; export for customer compliance	MVP (basic)
Ops console (internal)	DLQ triage, replay, connector readiness levels, incident banners	MVP
Analytics	Turnaround, first-pass rate, denial reasons, payer scorecards	Production

25.2 Developer portal and SDKs Recommended

- **Documentation.** OpenAPI reference, guides per integration pattern (embedded PA, headless API, FHIR API), webhook verification examples, changelog and deprecation policy.
- **Sandbox.** Synthetic tenants seeded with Synthea patients and scenario cases. A connection to the Da Vinci reference payer^[62] for CRD/DTR/PAS flows. Like Medblocks, warn that sandbox data does not predict production coverage^[15].
- **Credentials.** Self-service sandbox clients. Production clients require contract, BAA and review.
- **SDKs.** TypeScript and Python: typed models, pagination helpers, retry with idempotency, webhook signature verification, and a DTR launch helper for partners embedding our app.
- **Tools.** Webhook tester, request inspector (redacted), scenario runner (pending → info requested → approved).

26 Testing Strategy

Healthcare interoperability fails in production for reasons unit tests never see: a different identifier system, an unexpected extension, a payer that pends everything, a token revoked on a Friday night. The strategy combines conformance testing, recorded-fixture contract tests and scenario-based end-to-end tests. All non-production testing uses synthetic data Recommended.

Table 52. Test types, scope and tooling

Test type	Scope	Tooling / assets Recommended	Gate
Unit	Domain logic: state machine, rules, mapping functions, policy decisions	Standard frameworks; property-based tests for mappers	Every PR
Integration	Service + DB + queue + HAPI FHIR in containers	Testcontainers; seeded synthetic data	Every PR
Contract	Our public API (consumer-driven); connector ↔ vendor recorded contracts	OpenAPI diff checks; Pact-style consumer contracts; golden fixtures from sandboxes	Every PR
FHIR conformance	Resources we produce (PAS Bundles, QRs, Tasks) validate against IG versions	HL7 FHIR validator / HAPI validation with IG packages	Every PR
Da Vinci actor conformance	Our CRD client, DTR client and PAS client behaviour	Inferno test kits for CRD, DTR, PAS ^[70] ; Da Vinci reference implementations ^[62]	Release
Connector	Auth, paging, rate limits, error translation per vendor	Vendor sandboxes; fault-injection proxies	Connector release
Sandbox	End-to-end in vendor sandboxes (Epic, Oracle Health, etc.)	Scripted scenarios; screenshots for audit	Readiness level promotion
End-to-end	Order → CRD → DTR → PAS → decision → write-back	Scenario runner in staging with RI payer and a mock payer that can pend or deny	Release
Payer testing	Per payer and product line in the payer's test environment	Payer test scripts; comparison with portal outcomes during pilot	Payer go-live
Negative	Invalid tokens, malformed bundles, missing coverage, revoked consent, oversized attachments	Negative suites per endpoint	Release
Security	SAST, SCA, secrets, IaC, containers, DAST, pen test, tenant-isolation tests	CI scanners; independent pen test	PR / release / annual
Performance	CRD path latency, DTR load, submission throughput, bulk sync	Load tests against mocks with realistic latency distributions	Release
Reliability / chaos	Payer outage, EHR outage, queue backlog, AZ failure, DB failover	Fault injection; game days quarterly	Quarterly
Audit	Every PHI access produces an audit record with required fields	Automated assertions on audit stream	Every PR
Data integrity	Round-trip fidelity; no loss of original codings; provenance present	Golden-file comparisons; checksum of stored bundles	Every PR
Terminology	Code validation, ConceptMap coverage, ValueSet membership for CQL	Terminology fixtures per payer package	Every PR / content release
Authorization workflow	SMART launch, backend JWT, refresh, revocation, scope downgrade	Automated OAuth test harness	Release
PA workflow	All state transitions, deadlines, idempotent submit, update/cancel	Model-based tests on the state machine	Every PR

Failure scenarios that must be tested

Table 53. Example failure scenarios and expected behaviour

Scenario	Expected behaviour Recommended
PAS \$submit times out after the payer actually received it	No duplicate. Engine runs \$inquire , finds the request, and continues with the correct state
Payer returns pended; no notification ever arrives	Reconciliation detects the gap; escalation before the deadline; staff alerted
Refresh token revoked mid-DTR session	User prompted to relaunch; in-progress QR saved; no data loss
CRD response arrives after 5 s	Order not blocked; result applied asynchronously to the case
Payer CRD says indeterminate	Case marked "requirement unknown"; routed to staff with payer policy link
Source sends Condition with a local code only	Kept with original coding; unmapped-code metric increments; CQL question left for manual answer
Attachment contains malware	Rejected at scan; user notified; nothing stored in the clean bucket
Webhook endpoint down for 12 hours	Retries continue; after recovery all events delivered in order per case; replay available
Tenant A token used against tenant B case id	403; security alert; audit entry
Part 2-tagged note selected as evidence	Blocked from payer bundle unless consent/permission recorded; reason shown
Payer changes IG version without notice	Validation failure rate alert; circuit opens; fallback path; connector hot-fix
EHR write-back fails	Retry; then DLQ and staff task; case shows "decision received, EHR not updated"

27 Build vs Buy

Table 54. Build vs buy decisions by subsystem

Subsystem	Decision Recommended	Reasoning	Candidates (examples, not endorsements)
PA case engine & workflow logic	BUILD	Core differentiation: states, deadlines, routing, fallbacks, work queues	—
DTR app	BUILD (on OSS)	Multi-payer UX is a differentiator; the renderer and CQL engine can be OSS	OSS questionnaire renderers; OSS CQL engines Needs validation
PAS / CRD client adapters	BUILD	Payer and version adapters are ongoing core work	Da Vinci RIs as reference only ^[62]
FHIR server	OPEN SOURCE	Mature OSS; avoids lock-in; revisit at scale (§13)	HAPI FHIR ^[108] ; Medplum ^[110]
Terminology server	HYBRID	OSS server plus licensed content; buy commercial if SNOMED-heavy workloads grow	HAPI terminology; Snowstorm; commercial servers Needs validation
Identity platform (workforce and customer login)	BUY	Security-critical; commodity; needs enterprise SSO	Managed IdPs with BAA Needs validation ; Cognito ^[101]
OAuth / SMART implementation	HYBRID	Certified OIDC library + our SMART launch and backend logic; SMART AS for our FHIR API	Certified OIDC libraries; SMART-capable servers Needs validation
API gateway	BUY (cloud)	Commodity	API Gateway + WAF
Queue / event bus	BUY (cloud)	Commodity; HIPAA-eligible	SQS, EventBridge ^[101]
Workflow engine	OPEN SOURCE / BUY	Durable timers and human tasks are hard to build correctly	Temporal; Step Functions
Observability	HYBRID	OpenTelemetry instrumentation (OSS) + BAA-covered backend	CloudWatch; third-party APM with BAA Needs validation
Document processing (storage, scanning, rendering)	BUILD on cloud primitives	Simple, security-sensitive	S3; AV scanning engine
OCR / extraction (if needed)	BUY (later)	Useful for faxed or scanned documents; must be human-verified; not in MVP	Textextract (HIPAA-eligible ^[101]); specialist vendors
Payer connectivity (FHIR PA APIs)	BUILD	Direct payer relationships and adapters are strategic	—
Clearinghouse connectivity (X12)	PARTNER	Established networks, enrollment and trading-partner agreements	Clearinghouses offering 278 and FHIR front ends (e.g., Availity claims support for CRD/DTR/PAS ^[86])
HIE / TEFCA connectivity	PARTNER	Participation agreements, QHIN relationships and purpose-of-use governance ^[66]	QHINs / HIE vendors Needs validation
Pharmacy ePA (NCPDP SCRIPT)	PARTNER	Network-based; certification with ePA networks	ePA networks ^[87]
Prior-auth rules engine / payer policy catalog	BUILD (content) + evaluate BUY	Where payers lack CRD, a curated policy catalog is needed. Licensing a commercial rules dataset may be faster Needs validation . We never author medical-necessity criteria	Commercial PA-requirement datasets Needs validation

Subsystem	Decision	Reasoning	Candidates (examples, not endorsements)
	Recommended		
EHR connectivity (aggregators)	BUILD + optional PARTNER	Direct connectors for major EHRs; an aggregator (Medblocks-like vendor, Redox-type network) can accelerate the long tail	Integration platforms Needs validation
Data warehouse	BUY (cloud)	Commodity	Redshift / Athena on S3

28 MVP

The MVP proves one thing end to end: **a real order in a real EHR becomes a standards-based PA submission to a real payer, and the decision comes back into the EHR, with every other payer handled as a tracked manual task.**

28.1 Scope

Table 55. MVP scope: MUST / SHOULD / LATER

Priority	Capability
MUST	Medical-benefit PA only · Epic via SMART EHR launch and US Core reads · FHIR R4 · Patient, Coverage, order, Condition, Observation, Procedure, MedicationRequest, DocumentReference reads · consume native CRD results where present; minimal CRD client for one payer · multi-payer-capable DTR SMART app (one payer live) · PAS client with subscriptions and inquire · case engine with state machine, SLA timers, work queue · document upload and scan · manual-task channel for unsupported payers · webhooks (signed) · audit log · admin console (tenants, users, connections, payers, queue, audit viewer) · pooled tenancy with RLS · AWS HIPAA-eligible services under BAA · basic terminology (RxNorm, LOINC, ICD-10-CM, CPT lookups with licensed content)
SHOULD	Second EHR (Oracle Health or athenahealth) · X12 278 via clearinghouse for one payer · CRD hook router for one EHR/payer pair · update/cancel flows · appeal tracking (manual channel) · analytics v1 (turnaround, outcomes) · developer sandbox with Synthea tenants
LATER	Pharmacy ePA · HIE/TEFCA evidence · payer Provider Access API data · OCR/extraction · siloed/dedicated tenancy · FHIR API for customers · patient-facing status · payer-side offering · multi-region active-passive · HITRUST

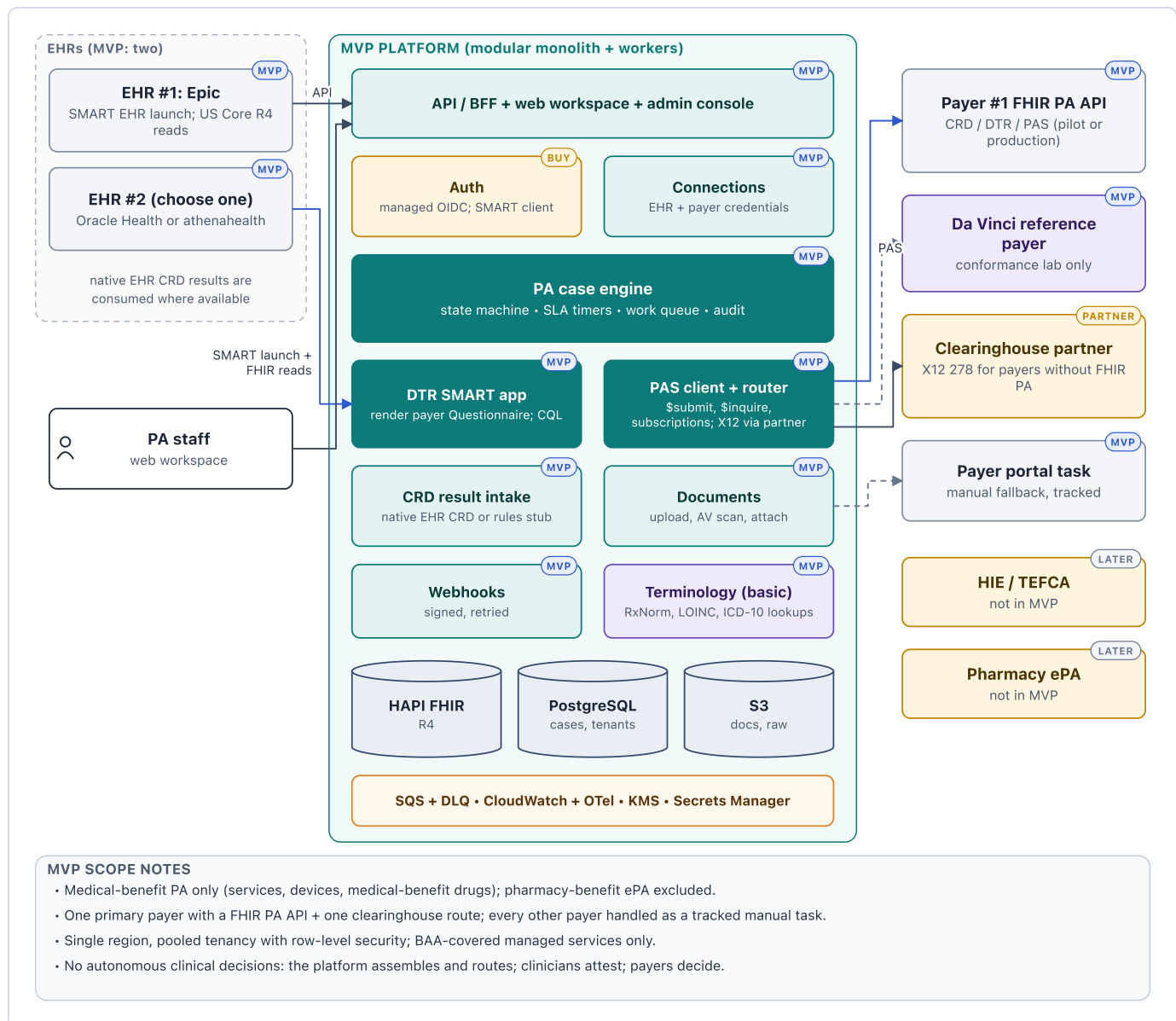


Figure 29. Diagram 15: MVP architecture

28.2 Design-partner criteria Recommended

- A specialty group or health system on Epic (or the chosen second EHR) with a named PA operations lead and executive sponsor.
- A meaningful share of volume with a payer that has a live or pilot FHIR PA API and will test with us.
- Willingness to share baseline metrics (touch time, turnaround, denial rates) and to sign a BAA.

28.3 MVP exit criteria

- ≥ 50 real cases submitted via PAS to the pilot payer with correct write-back. No duplicate submissions. No PHI incidents.
- Inferno CRD/DTR/PAS client tests passing for the implemented versions^[70].
- Pen test completed with no open high or critical findings; HIPAA risk analysis complete; SOC 2 readiness underway.
- Staff touch-time reduction measured against baseline (target in §3.4).

29 Implementation Roadmap

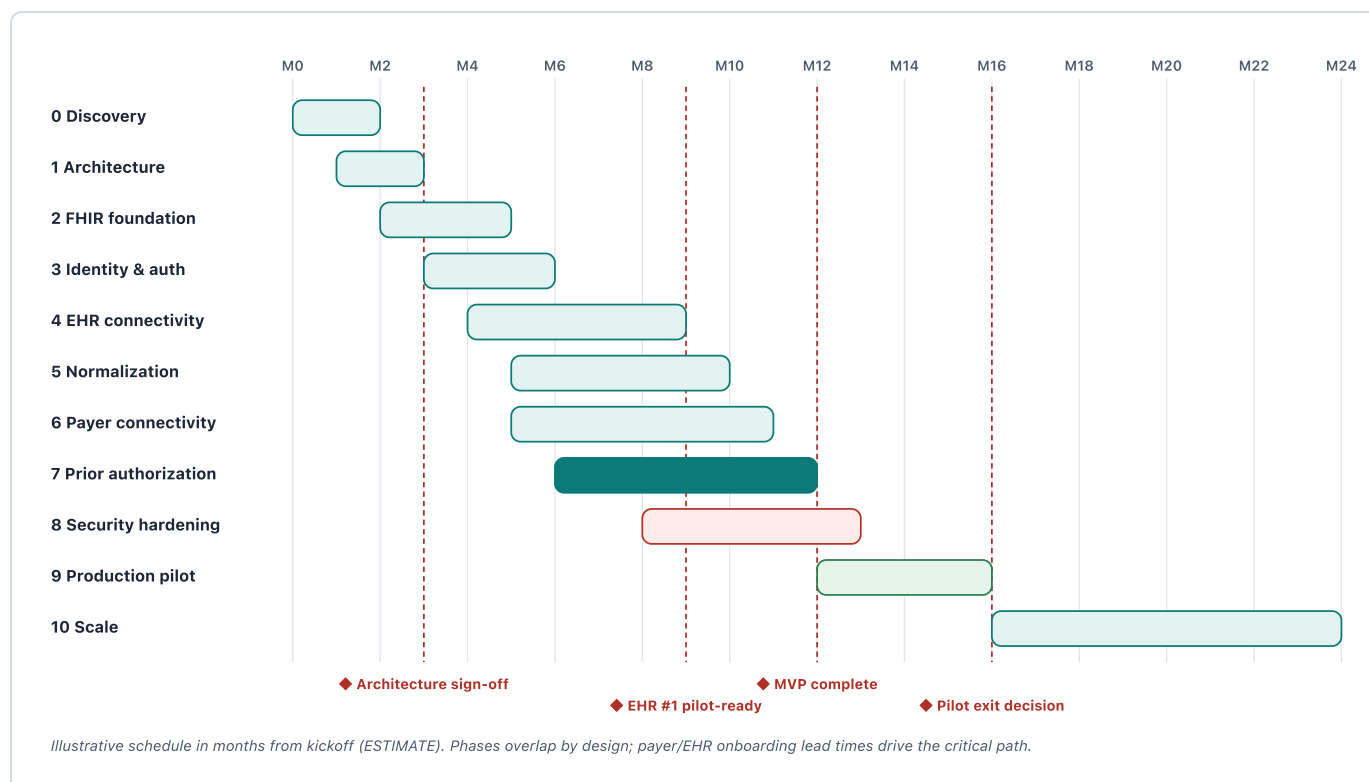


Figure 30. Illustrative roadmap (months from kickoff; ESTIMATE)

Table 56. Roadmap phases 0–5

Phase	Objective	Deliverables	Dependencies	Risks	Technical work	Business work	Exit criteria
0 Discovery (M0–2)	Validate problem, partners, payers	Design partner LOIs; payer shortlist with API status; EHR program enrollment; baseline metrics plan	Executive sponsor	No payer ready for pilot	Sandbox spikes (Epic, R1 payer); SMART launch prototype	Interviews; pricing hypotheses; BAA template	≥ 1 design partner + ≥ 1 payer committed
1 Architecture (M1–3)	Decide and document the target	ADRs; threat model; data model; API draft; compliance plan	Phase 0 findings	Over-design	IaC skeleton; CI/CD; accounts	Security officer; policies drafted	Architecture sign-off; risk analysis v1
2 FHIR foundation (M2–5)	Store and validate FHIR	HAPI on Aurora; IG packages; partitioning; audit v1	Phase 1	HAPI ops learning curve	Validation pipeline; provenance	—	PAS/QR fixtures validate; isolation tests pass
3 Identity & auth (M3–6)	Secure access	IdP; RBAC/ABAC PDP; SMART client; token vault	Phase 1	Policy complexity	PKCE, private_key_jwt, refresh	SSO for design partner	Pen-test-ready auth; OAuth harness green
4 EHR connectivity (M4–9)	Epic (+1) live in customer non-prod	Connector framework; Epic connector; second EHR connector	EHR program approvals; customer IT	Activation delays	Launch, reads, write-back, health probes	Customer app approval process	Customer non-prod end-to-end reads + write-back
5 Data normalization (M5–10)	Evidence usable for CQL	Mapping packs; terminology service; data-quality dashboards	Phase 4 data	Poor source coding	ConceptMaps; UCUM; identity matching	Terminology licences (CPT, UMLS)	Pre-population fill rate measured on pilot data

Table 57. Roadmap phases 6–10

Phase	Objective	Deliverables	Dependencies	Risks	Technical work	Business work	Exit criteria
6 Payer connectivity (M5–11)	One FHIR payer + one X12 route	Payer registry; CRD/DTR/PAS adapters; subscription receiver; clearinghouse integration	Payer test access; partner contract	Payer delays; version mismatch	Backend Services registration; Inferno	Payer agreements; partner BAA	Payer test-env end-to-end pass
7 Prior authorization (M6–12)	Complete PA product	Case engine; DTR app; work queue; SLA timers; webhooks; admin console	Phases 2–6	Scope creep	State machine; idempotent submit; write-back	Training materials; SOPs	MVP feature-complete; E2E in staging
8 Security hardening (M8–13, continuous)	Production-grade controls	Pen test; SOC 2 readiness; DR test; runbooks	Stable build	Findings delay pilot	Remediation; logging redaction; key rotation	Customer security reviews	No open high/critical; DR restore proven
9 Production pilot (M12–16)	Real cases, real payer	Go-live at design partner; metrics dashboards	BAAs; approvals	Low volume; payer pends everything	Hypercare; tuning	Weekly reviews; case studies	MVP exit criteria (§28.3) met
10 Scale (M16–24+)	More EHRs, payers and customers	Connector factory; payer onboarding playbook; SOC 2 Type II; siloed tier	Pilot success	Onboarding throughput	Automation of onboarding; performance	Sales; partnerships	Unit economics per case validated

30 Team Structure

Table 58. Team requirements (FTE estimates)

Role	Responsibilities	MVP FTE Estimate	Enterprise FTE Estimate	Essential for MVP?
Product Manager	Scope, design partners, roadmap, metrics	1	2–3	Yes
Healthcare Business Analyst	Workflow analysis, requirements, payer policy research	1	2–3	Yes
Prior Authorization SME	Real-world PA operations; UAT; SOPs	0.5 (advisor or partner staff)	1–2	Yes
Healthcare SME (clinical)	Clinical review of questionnaires and evidence logic; safety	0.25 (advisor)	1	Advisor
Healthcare Interoperability Architect	Standards, FHIR profiles, Da Vinci, vendor strategy; tech lead	1	1–2	Yes
Backend Engineers	Case engine, APIs, workflows, events	3	6–10	Yes
FHIR Engineers	HAPI, validation, mapping, terminology, DTR/CQL	1.5	3–4	Yes
Integration Engineers	EHR, payer and partner connectors; onboarding	1.5	4–8	Yes
Frontend Engineer	DTR app, workspace, admin console	1.5	3–4	Yes
DevOps / SRE	IaC, CI/CD, observability, DR, on-call	1	2–4	Yes
Security Engineer	Threat modeling, AppSec, cloud security, pen-test coordination	0.5–1	2	Yes (at least fractional)
QA Automation Engineer	Test harnesses, conformance, E2E scenarios	1	2–3	Yes
Compliance / Privacy	HIPAA program, BAAs, SOC 2 / HITRUST, policies	0.5 (fractional / counsel)	1–2	Yes (fractional)
Implementation / onboarding managers	Customer and payer onboarding project management	0.5	2–4	Pilot
Support / operations	Tier-1/2 support; DLQ triage; payer escalations	—	3–6	Pilot
Payer policy content analysts	Maintain policy catalog where CRD absent	—	1–3	Later
Total		~15–17 (≈ 12–13 dedicated FTE + fractional roles)	~35–60	

Governance Recommended

Hold a weekly architecture/standards review chaired by the interoperability architect. Hold a monthly risk and compliance review with the security and privacy officers. Run a clinical safety review for any change to evidence selection or questionnaire handling. Track payer and EHR onboarding on a single shared readiness board.

31 Risks

Risks are assessed for **this project and system only**. Probability and impact are H (high), M (medium) or L (low), assessed as of 30 September 2026 **Estimate**. No vendor, payer or regulator is scored.

Table 59. Risk register

#	Risk	P	I	Mitigation Recommended	Owner
1	EHR vendor differences (APIs, write-back, extensions)	H	H	Connector plugins; capability snapshots; per-vendor golden fixtures; start with 2 EHRs	Interop architect
2	Payer differences (versions, product lines, trust models)	H	H	Payer capability registry; multi-version adapters; fallback channels on every case	Integration lead
3	Payer API availability later than planned	H	H	Pilot with a payer confirmed in Phase 0; clearinghouse route; value from work queue even without FHIR	Product manager
4	Sandbox vs production differences	H	M	Readiness levels; customer non-prod testing; hypercare; do not infer coverage from synthetic data ^[15]	QA lead
5	Credentials / access delays (EHR activation, payer registration)	H	H	Start enrollment in Phase 0; parallel workstreams; named customer IT owner	Implementation manager
6	Certification / onboarding requirements (EHR programs, payer conformance)	M	M	Inferno conformance early ^[70] ; follow vendor program rules	Interop architect
7	Data quality (missing codes, free text)	H	M	Data-quality scoring; manual-answer UX; mapping packs; measure fill rate	FHIR lead
8	Terminology mismatch (local vs standard; version drift)	M	M	ConceptMaps with review; preserve originals; versioned content loads	FHIR lead
9	Patient identity matching errors	M	H	Deterministic matching first; confidence thresholds; human review; never merge across tenants	Backend lead
10	Consent problems (Part 2, state-sensitive data)	M	H	Sensitivity tagging; exclusion by default from payer bundles; counsel review ^[97]	Privacy officer
11	Authorization expiration (tokens; also payer auth validity periods lapsing)	H	M	Proactive refresh; <code>refresh_failed</code> alerts; auth-expiry reminders on approved cases	SRE lead
12	API rate limits (EHR / payer)	M	M	Per-endpoint buckets; priority lanes; case-scoped reads (minimum necessary)	Integration lead
13	Payer downtime at a deadline	M	H	Circuit breakers; deadline-aware fallback; staff escalation	SRE lead
14	Regulatory changes (CMS-0062-P final form; HIPAA Security Rule; IG versions)	H	M	Standards watch; version-agnostic adapters; quarterly regulatory review ^[26,96]	Product + compliance
15	PHI security incident	L–M	H	Layered controls (§21); pen tests; least privilege; incident response drills	Security officer
16	Data retention (over-retention of evidence copies; conflicting customer policies)	M	M	Retention by data class; case-scoped evidence; deletion jobs; BAA return/destroy	Privacy officer
17	Vendor lock-in (cloud, workflow engine, IdP)	M	M	Open standards; OSS FHIR server; IaC; abstraction at workflow boundaries	CTO
18	Interoperability gaps (hooks not routed to third parties; write-back unsupported)	H	M	Consume native EHR results; manual task channels; roadmap per EHR	Interop architect
19	Unexpected implementation differences (profile interpretations; extensions)	H	M	Tolerant readers, strict writers; per-payer profiles; fast connector release process	Integration lead

#	Risk	P	I	Mitigation Recommended	Owner
20	EHR-native ePA reduces demand in some segments	M	H	Position as complement; focus on multi-payer operations and on EHRs/payers lacking native support ^[116]	CEO / product
21	Clinical safety (wrong evidence, wrong "not required")	L-M	H	Never default to "not required"; clinician attestation; clinical review of logic changes	Clinical SME
22	Terminology licensing gaps (CPT distribution)	M	M	Obtain AMA licences early ^[106] ; UMLS licence for SNOMED ^[102]	Compliance

Major unknowns (need validation)

- Which payers, and which product lines, will have production CRD/DTR/PAS on 1 Jan 2027, and at which IG versions Needs validation.
- Whether target EHRs will route CDS Hooks to a third-party CRD router, or allow our DTR app to be launched from native CRD cards, at customer sites Needs validation.
- Write-back permissions (Task, Communication, QuestionnaireResponse, DocumentReference) per EHR and site Needs validation.
- Payer callback authentication and IP allow-listing requirements for PAS subscriptions Needs validation.
- The final content and timing of CMS-0062-P, including any HIPAA adoption of FHIR for PA transactions Proposed rule ^[26].
- Commercial terms for EHR programs, clearinghouse transactions and terminology licences Needs validation.

32 Cost / Effort Estimates

All figures in this section are estimates Estimate

They are order-of-magnitude planning ranges, not quotes. Assumptions:

- A U.S.-based or blended team at a fully loaded cost of **\$15k–\$22k per person-month**.
- The AWS reference architecture at pilot scale.
- One design partner and one pilot payer.
- No custom EHR development by vendors.

Vendor fees (EHR programs, clearinghouse, terminology licences) are excluded unless stated, because they are contract-specific Needs validation.

32.1 Engineering effort by stage

Table 60. Effort model by stage

Stage	Duration	Team	Person-months	Labor cost range	Main effort drivers
MVP	~12 months	~12–13 FTE + fractional	130–170	\$2.0M–\$3.7M	Case engine, DTR app, PAS client, Epic + 1 EHR connector, security baseline
Pilot	~4 months	~13–15 FTE	50–60	\$0.8M–\$1.3M	Hypercare, payer tuning, SOC 2 readiness, second payer route
Production (hardening + first scale)	~6–8 months	~18–25 FTE	110–200	\$1.7M–\$4.4M	More payers/EHRs, siloed tenancy, analytics, SOC 2 Type II
Enterprise scale (run-rate)	per year	~35–60 FTE	420–720 / yr	\$6.3M–\$15.8M / yr	Connector factory, onboarding teams, support, content, HITRUST, multi-region

32.2 Other cost categories

Table 61. Non-labor cost categories

Category	Planning range / note Estimate
Cloud infrastructure	MVP (dev + staging + prod, single region): roughly low tens of thousands of dollars per month or less. Production with DR, multi-AZ Aurora and observability: several times that. Size with the AWS Pricing Calculator once workloads are known Needs validation .
Security & compliance	Pen tests (per engagement), SOC 2 readiness + audits (annual), HITRUST (enterprise stage), tooling (scanners, SIEM). Budget as a recurring line from the pilot onwards.
Integration onboarding (effort)	New EHR vendor connector: ~2–4 months for 2 engineers. Per customer site activation: ~4–12 weeks elapsed (mostly approvals). Per payer onboarding: ~6–16 weeks elapsed. All Estimate .
Partner & programme fees	Clearinghouse per-transaction or subscription; EHR developer programme fees where applicable (e.g., Epic Vendor Services is optional and paid ^[76]); AMA CPT licences ^[106] . Needs validation
Ongoing maintenance	Plan 20–30% of engineering capacity for connector upkeep, IG version changes and vendor API changes. Add 1–3 FTE for payer policy content once the catalog is live.

33 Future-State Architecture



Figure 31. Diagram 16: Future enterprise architecture

Table 62. Future-state capabilities and triggers

Capability	Trigger to invest Recommended
Pharmacy-benefit ePA (NCPDP SCRIPT)	Customer demand; SCRIPT 2023011 Part D date of 1 Jan 2028 ^[36] ; CMS-0062-P finalization Proposed rule
Medical-benefit drug PA via FHIR PA API	CMS-0062-P final rule, if adopted Proposed rule ^[26]
HIE / TEFCA evidence retrieval	Outside-record evidence materially improves approval rates; QHIN partner selected ^[66]
Payer Provider Access API ingestion	Payers live on the Provider Access API (2027) ^[24] ; prior claims and PA history improve evidence
Document intelligence (OCR + extraction, human-verified)	High share of scanned or faxed evidence; accuracy validated; clinicians remain the attesting party
Payer-side services	A payer asks for CRD/DTR/PAS hosting or provider-adoption tooling. Requires separate tenancy, contracts and conflict-of-interest governance
Dedicated cells, BYOK, multi-region	Enterprise contracts, residency or uptime requirements

Capability	Trigger to invest Recommended
Event streaming to customers (FHIR Subscriptions)	Customer platforms need near-real-time feeds

34 Conclusion

34.1 Final recommended target architecture

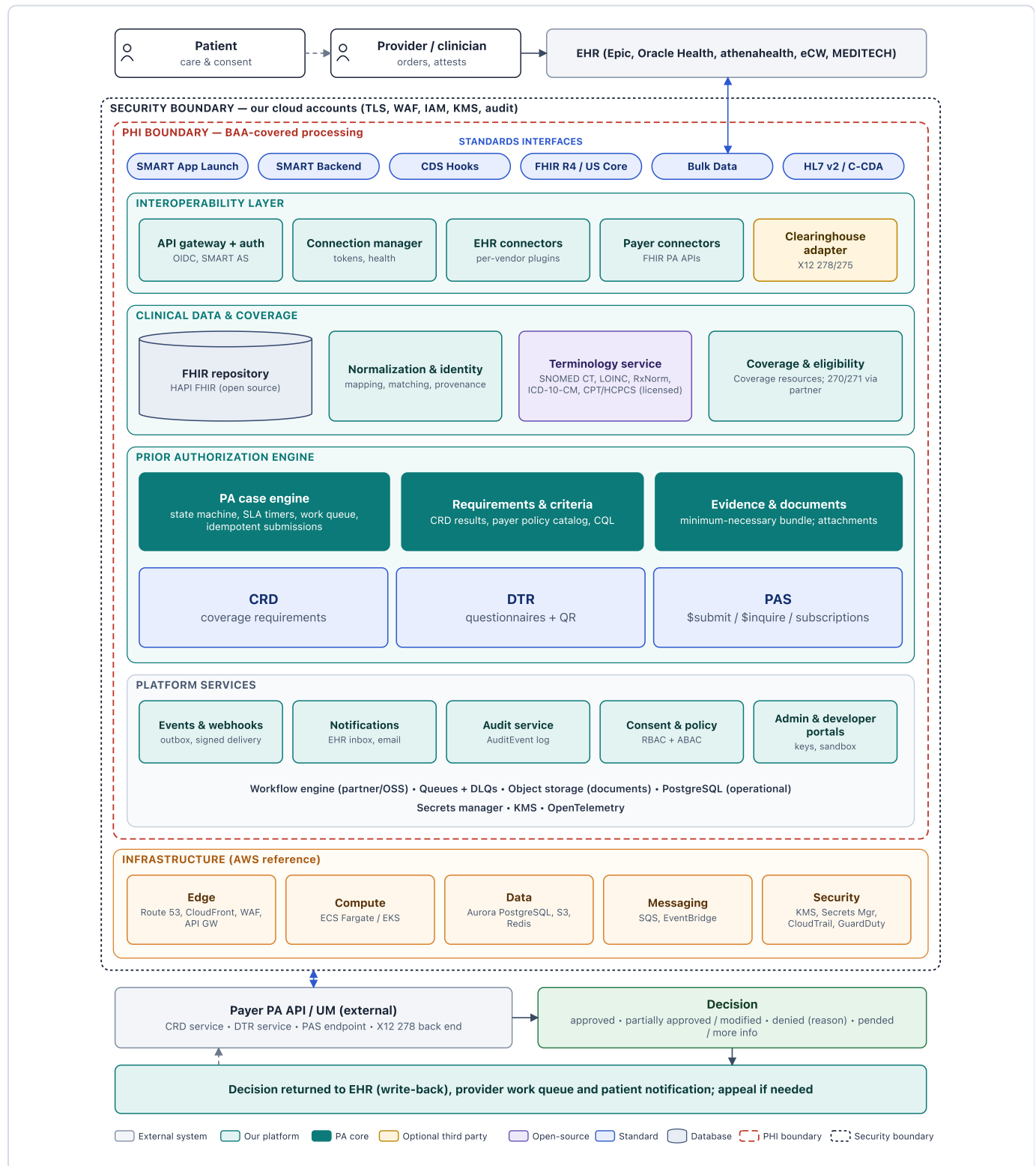


Figure 32. Final recommended target architecture: patient → provider → EHR → platform → CRD/DTR/PAS → payer → decision, with infrastructure, security and PHI boundaries

34.2 Summary

A Medblocks-like interoperability layer is necessary but not sufficient for prior authorization. Medblocks' public documentation shows a robust pattern for connecting to EHRs and payers, managing connection state, normalizing data with provenance, and delivering it through exports and signed webhooks. We should adopt that pattern^[2,3,13]. Prior authorization adds four things:

- a **stateful, deadline-driven case engine**;
- **payer counterparties** with their own trust and version constraints;
- **synchronous latency budgets** (CRD 5 s, PAS 15 s);
- **minimum-necessary disclosure** obligations^[50,54,94].

The regulatory timing (payer PA APIs from 1 Jan 2027^[24]), the certification criteria (HTI-4^[63]) and the voluntary industry commitments^[117] make this the right window. Early live deployments exist^[116]. Payer readiness is uneven^[83,84], and PA attachment standards remain unsettled^[31]. A product that **guarantees a path for every case** (FHIR where possible, partner X12 or tracked manual work where not) will be valuable throughout the transition.

34.3 Immediate next steps (next 90 days) Recommended

1. Secure one design partner (Epic site) and one pilot payer with a FHIR PA test environment. Confirm IG versions.
2. Enroll in EHR developer programs (open.epic; second EHR). Register sandbox clients. Build a SMART launch prototype.
3. Stand up the Da Vinci reference payer and Inferno kits in a lab environment. Prototype a DTR render and a PAS submit.
4. Complete the HIPAA risk analysis, policies, AWS BAA and a BAA template. Name the security and privacy officers.
5. Approve ADRs 001–008 and the MVP scope (§28). Staff the core team (§30).

34.4 Document quality review

Table 63. Internal quality-control checklist

Check	Result	Notes
Important claims sourced	Yes	Numbered citations to primary sources; secondary sources used only where primary pages were not retrievable and marked
Outdated requirements marked historical	Yes	2020 Part D ePA rule shown as baseline; CMS-recommended IG versions distinguished from current versions
2026 requirements verified	Yes	CMS pages modified Aug–Sep 2026; CMS-0062-P (Apr 2026); SVAP 2026; CMS-0053-F (Mar 2026); Unified Agenda (Fall 2025, latest found)
Medblocks facts separated from inference	Yes	§5–7 labels; dashed/inferred components in diagrams
Architecture choices identified as recommendations	Yes	Recommended labels; ADRs
FHIR resources used correctly	Yes, needs validation	Per IG summaries retrieved. Profile-level details must be checked against the payer-agreed IG version
CRD/DTR/PAS represented accurately	Yes	Operations, timing and extension codes from IG 2.2.x pages
Medical vs pharmacy PA distinguished	Yes	§16.5 and figure
HIPAA claims phrased correctly	Yes	No "HIPAA compliant" claims; controls and organizational duties described
Production vs MVP separated	Yes	§28 MUST/SHOULD/LATER; §33
Assumptions and unknowns listed	Yes	Front matter; §31 unknowns

Check	Result	Notes
Diagrams consistent	Yes	Shared legend conventions; component names align with §10 inventory
Terminology definitions correct	Yes	§15, §35
Limitations	—	No hands-on testing was performed. Several vendor pages blocked automated retrieval (marked). Estimates are not quotes

35 Glossary

Table 64. Glossary

Term	Definition
ABAC	Attribute-based access control: access decisions based on attributes of the user, resource, action and context (e.g., tenant, purpose-of-use, data sensitivity).
BAA	Business Associate Agreement: the HIPAA-required contract between a covered entity and a business associate (or between a business associate and its subcontractor) governing permitted uses of PHI and safeguards.
Bulk Data (Flat FHIR)	HL7 specification for asynchronous export of large FHIR datasets as NDJSON files (<code>\$export</code>).
CDS Hooks	HL7 specification for invoking remote decision-support services at points in the EHR workflow (hooks) and returning cards or actions. Used by CRD.
CDex	Da Vinci Clinical Data Exchange: exchange of clinical data and attachments between providers and payers; used by PAS for additional information.
Clearinghouse	An entity that processes or translates health information between non-standard and standard formats (e.g., X12) and routes transactions between providers and payers.
CMS-0057-F	CMS Interoperability and Prior Authorization Final Rule (published Jan 2024): payer APIs and PA process requirements, with dates in 2026 and 2027.
CMS-0062-P	CMS proposed rule (April 2026) extending PA requirements to drugs and proposing FHIR standards for PA-related HIPAA transactions. Not final.
CPT	Current Procedural Terminology: AMA-maintained codes for medical services and procedures (HCPCS Level I). Licensed.
CQL	Clinical Quality Language: HL7 expression language used in DTR to pre-populate questionnaires from FHIR data.
CRD	Da Vinci Coverage Requirements Discovery: IG by which a payer tells the provider, in workflow, whether a service is covered and whether PA and documentation are needed.
Da Vinci	HL7 accelerator project producing payer-provider FHIR implementation guides (CRD, DTR, PAS, CDex, PDex, etc.).
DLQ	Dead-letter queue: holds messages that could not be processed after retries, for triage and replay.
DTR	Da Vinci Documentation Templates and Rules: IG for retrieving payer questionnaires and rules, pre-populating them from EHR data, and producing a QuestionnaireResponse.
EHR	Electronic Health Record: an organization's system of record for patient clinical data, orders and documentation; typically interoperable beyond one practice.
EMR	Electronic Medical Record: often used interchangeably with EHR; historically a digital chart within one practice or organization.
FHIR	Fast Healthcare Interoperability Resources: HL7 standard for exchanging healthcare data as resources over RESTful APIs. R4 (4.0.1) is the version used by U.S. regulation and Da Vinci IGs.
FHIR Resource	A modular unit of healthcare data in FHIR (e.g., Patient, Coverage, Claim) with a defined structure, identity and references.
FHIR Server	Software that stores FHIR resources and serves them through the FHIR REST API (read, search, create, update, operations).
HCPCS	Healthcare Common Procedure Coding System. Level II codes (maintained by CMS) cover supplies, DME, drugs and services not in CPT.
HIE	Health Information Exchange: an organization or network enabling the electronic sharing of health information among providers and other participants.
HIPAA	Health Insurance Portability and Accountability Act of 1996, including the Privacy, Security and Breach Notification Rules and administrative simplification transaction standards.
HTI-4	ONC/ASTP final rule (effective 1 Oct 2025) adding certification criteria for e-prescribing, real-time benefit and electronic prior authorization (CRD, DTR, PAS).

Term	Definition
ICD-10 (ICD-10-CM)	International Classification of Diseases, 10th Revision, Clinical Modification: U.S. diagnosis code set.
Idempotency	The property that repeating the same request has the same effect as sending it once. Essential for safe retries of submissions.
LOINC	Logical Observation Identifiers Names and Codes: codes for lab tests, observations and document types (Regenstrief Institute).
Minimum necessary	HIPAA standard requiring reasonable efforts to limit PHI used, disclosed or requested to the minimum needed for the purpose (exceptions include treatment disclosures).
NDC	National Drug Code: FDA identifier for drug products (labeler, product, package). A 12-digit uniform format is effective 7 Mar 2033.
OAuth 2.0	Authorization framework for delegated access using tokens (IETF RFC 6749; security best practice RFC 9700).
OIDC	OpenID Connect: identity layer on OAuth 2.0 providing authenticated user identity via ID tokens.
PAS	Da Vinci Prior Authorization Support: IG for submitting PA requests as FHIR Claim bundles and receiving ClaimResponse decisions, compatible with X12 278 behind the endpoint.
Payer	An organization that pays for health care: health plan, insurer, government program (Medicare, Medicaid) or self-funded employer plan (via an administrator).
PBM	Pharmacy Benefit Manager: administers prescription drug benefits for payers, including formularies and pharmacy-benefit PA.
PHI	Protected Health Information: individually identifiable health information held or transmitted by a covered entity or business associate, in any form.
PKCE	Proof Key for Code Exchange: OAuth extension protecting authorization codes from interception; required for public clients and recommended for all.
Prior Authorization	A payer's requirement that a provider obtain approval before a service, item or drug is provided, for it to be covered.
Provider	A clinician or organization that delivers health care services (hospital, clinic, physician group).
QHIN	Qualified Health Information Network: a network designated under TEFCA to exchange data with other QHINs.
RBAC	Role-based access control: permissions granted through roles.
RLS	Row-level security: database-enforced filtering of rows (e.g., by tenant).
RxNorm	NLM normalized naming system for clinical drugs, linking to NDCs and other drug vocabularies.
SMART on FHIR	HL7 SMART App Launch framework: OAuth 2.0 / OIDC profiles for apps launched from EHRs or standalone, and Backend Services for system-to-system access to FHIR APIs.
SNOMED CT	Comprehensive clinical terminology for findings, disorders, procedures and more; free for U.S. use via the NLM UMLS license.
SVAP	Standards Version Advancement Process: ONC process allowing certified developers to adopt newer approved standard versions voluntarily.
TEFCA	Trusted Exchange Framework and Common Agreement: national framework for health information exchange among QHINs, governed via the Recognized Coordinating Entity.
UM	Utilization management: payer processes (including PA) to evaluate the medical necessity and appropriateness of services.
US Core	HL7 FHIR implementation guide defining U.S. baseline profiles aligned to USCDI.
USCDI	United States Core Data for Interoperability: standardized set of health data classes and elements for nationwide exchange (ONC).
Webhook	An HTTP callback: the platform POSTs an event notification to a customer-registered URL when something happens.
X12 278	HIPAA-adopted ASC X12N 005010X217 Health Care Services Review transaction: request for review and response (prior authorization / referral).

36 References

Research transparency. All sources were retrieved on 30 September 2026. Dates are publication or last-update dates as stated by each source; "Not stated" means the page showed none. Numbers match the bracketed citations in the text.

A. Key sources

Ref	Source	Key facts supported
[24]	CMS Interoperability and Prior Authorization Final Rule (CMS-0057-F) fact sheet, CMS	Impacted payers; 72-hour expedited / 7-calendar-day standard decisions; specific denial reason; 1 Jan 2026 operational and 1 Jan 2027 API dates; Patient Access, Provider Access, Payer-to-Payer and Prior Authorization APIs; ePA measure; X12 278 enforcement discretion; drugs excluded.
[25]	Electronic Prior Authorization: overview, CMS	Current CMS ePA landscape: CMS-0057-F, CMS-0062-P (released 10 Apr 2026), FY 2027 IPPS ePA measure (optional bonus CY2027; mandatory from CY2028), June 2025 industry pledge, WISeR.
[26]	Summary of Proposed Provisions: 2026 CMS Interoperability Standards and Prior Authorization for Drugs Proposed Rule (CMS-0062-P), CMS	Proposed: drug PA (medical benefit via PA API; pharmacy benefit via NCPDP standards); HIPAA adoption of FHIR + IGs in place of X12 278 and 270/271 for PA; endpoint reporting; QHP timeframes; FF-SHOP issuers; API usage metrics.
[28]	APIs and Relevant Standards and Implementation Guides, CMS	Required standards (FHIR 4.0.1, US Core, SMART, Bulk, OIDC) and recommended IGs per API incl. CRD/DTR/PAS; conditions for using updated versions.
[29]	Administrative Simplification enforcement FAQs (X12 278 enforcement discretion), CMS	Enforcement discretion for covered entities using a FHIR-based PA API per CMS-0057-F instead of X12 278; no terminal date; entities may elect, not be compelled.
[31]	Adoption of Standards for Health Care Claims Attachments Transactions and Electronic Signatures Final Rule (CMS-0053-F) fact sheet, CMS	X12N 275/277 v6020 and HL7 C-CDA + Attachments IG for claims attachments; effective 26 May 2026; compliance 26 May 2028; prior-authorization attachment standards not finalized.
[63]	HTI-4 Overview and Key Dates for the Certification Program, ASTP/ONC	Certification criteria 170.315(g)(31) CRD, (g)(32) DTR, (g)(33) PAS, (j)(20) CDS Hooks triggers, (j)(21) Subscriptions client; SCRIPT 2023011 transition to 1 Jan 2028; rule effective 1 Oct 2025.
[64]	Advancements in Health IT: ONC's 2026 Approved SVAP Standards, ASTP/ONC	2026 SVAP: USCDI v6, US Core 9.0.0, C-CDA R5.0.0, CRD 2.2.1, DTR 2.2.0, PAS 2.2.1; voluntary use from 29 Aug 2026.
[49]	CRD: Supported hooks and response types, HL7 International / Da Vinci	Hooks appointment-book, encounter-start, encounter-discharge, order-select, order-dispatch, order-sign; primary hooks SHALL return Coverage Information; response types.
[50]	CRD: Foundational requirements, HL7 International / Da Vinci	Response-time targets (5 s; 10 s for certain hooks) 90% of the time; narrow scopes and short token lifetime; prefetch; log retention for disputes.
[52]	DTR: Formal specification, HL7 International / Da Vinci	SMART DTR app vs Full EHR; \$questionnaire-package; CQL pre-population; adaptive forms/\$next-question timing; QuestionnaireResponse storage; SMART Backend Services to payer; multi-payer expectation.
[54]	PAS: Formal specification, HL7 International / Da Vinci	Claim/\$submit and Claim/\$inquire; Bundle rules; 15-second target else pended; subscriptions (rest-hook, full-resource); X12 278/275 black-box intermediary; updates/cancellation; HTTP error semantics; 6-month availability of pended PAs.
[55]	PAS: Additional information, HL7 International / Da Vinci	Task-based requests for additional information conveyed to CDex; \$submit-attachment; questionnaire TRNs as Task.input.
[3]	Sources and connections, Medblocks	Source catalog (Epic, Oracle Health, athenahealth, eClinicalWorks, Meditech, CMS Blue Button, payer APIs, networks); connection states active/failed/refresh_failed/expired/disconnected; OAuth/SMART/token refresh handled server-side; customer-supplied credentials.

Ref	Source	Key facts supported
[4]	Integration patterns, Medblocks	Patient access, clinician workflow (CDS Hooks + SMART App Launch), backend (SMART Backend Services + Bulk Data), network (TEFCA and other networks).
[13]	Webhooks, Medblocks	Events patient_session.completed, connection.token_refresh_failed, records.sync.completed, records.sync.failed; Medblocks-Signature over raw body; 2xx within 5 s; retries; idempotency by event.id.
[21]	FHIR prior authorization (technical article), Medblocks	Educational article on CRD/DTR/PAS and CMS-0057-F; no claim of a Medblocks PA product.
[93]	45 CFR 164.501 Definitions (Payment), U.S. CFR via Cornell LII	'Payment' includes utilization review activities including precertification and preauthorization.
[94]	45 CFR 164.502 Uses and disclosures (minimum necessary), U.S. CFR via Cornell LII	Minimum necessary standard; exception for disclosures to or requests by a provider for treatment.
[101]	AWS HIPAA Eligible Services Reference, Amazon Web Services	HIPAA-eligible services incl. API Gateway, ELB, ECS, EKS, Fargate, RDS, Aurora, ElastiCache, SQS, SNS, EventBridge, Step Functions, S3, KMS, Secrets Manager, CloudWatch, CloudTrail, WAF, CloudFront, Cognito, HealthLake, Textract, GuardDuty, Backup.

B. Official documentation links and source hierarchy

The source hierarchy followed the brief: CMS; HL7 / FHIR; Da Vinci IGs; ONC/ASTP; official payer and provider developer documentation; Medblocks documentation and engineering material; other standards bodies; reputable healthcare-technology organizations. Every entry in groups D–J below is an official publication of the named organization. Group K lists secondary sources, used only where a primary source was not retrievable; the text marks those facts accordingly. Several official pages blocked automated retrieval and are marked "retrieval blocked". The facts attributed to them are limited and labeled Needs validation.

D. Medblocks sources

- [1] **Medblocks documentation: Introduction.** Medblocks. <https://medblocks.com/docs>. Not stated. Retrieved 30 Sep 2026. Supports: Product surfaces (EHRs, networks, patient-mediated feeds, clinician workflows), TypeScript SDK, REST APIs, dashboard, webhooks; target users are product teams.
- [2] **How Medblocks works.** Medblocks. <https://medblocks.com/docs/how-medblocks-works>. Not stated. Retrieved 30 Sep 2026. Supports: Source / connection / pull / export concepts; four integration patterns; operational updates via webhooks and dashboard history.
- [3] **Sources and connections.** Medblocks. <https://medblocks.com/docs/sources-and-connections>. Not stated. Retrieved 30 Sep 2026. Supports: Source catalog (Epic, Oracle Health, athenahealth, eClinicalWorks, Meditech, CMS Blue Button, payer APIs, networks); connection states active/failed/refresh_failed/expired/disconnected; OAuth/SMART/token refresh handled server-side; customer-supplied credentials.
- [4] **Integration patterns.** Medblocks. <https://medblocks.com/docs/integration-patterns>. Not stated. Retrieved 30 Sep 2026. Supports: Patient access, clinician workflow (CDS Hooks + SMART App Launch), backend (SMART Backend Services + Bulk Data), network (TEFCA and other networks).
- [5] **Patient access.** Medblocks. <https://medblocks.com/docs/patient-access>. Not stated. Retrieved 30 Sep 2026. Supports: Patient-authorized access through provider portals; hosted flow.
- [6] **Patient session.** Medblocks. <https://medblocks.com/docs/patient-access/patient-session>. Not stated. Retrieved 30 Sep 2026. Supports: Server creates patient session returning redirect URL; hosted or custom hospital search; Medblocks completes OAuth; background pull; session states open/complete/expired.
- [7] **Backend (work in progress).** Medblocks. <https://medblocks.com/docs/backend>. Not stated. Retrieved 30 Sep 2026. Supports: Organization-authorized server-to-server access; Epic backend setup uses SMART Backend Services, organization selection and FHIR Group IDs; docs marked work in progress.
- [8] **Network (work in progress).** Medblocks. <https://medblocks.com/docs/network>. Not stated. Retrieved 30 Sep 2026. Supports: CommonWell, Carequality, TEFCA-aligned exchange; permitted-purpose constraints; setup is consultative; docs marked work in progress.
- [9] **Clinician workflow (work in progress).** Medblocks. <https://medblocks.com/docs/clinician-workflow>. Not stated. Retrieved 30 Sep 2026. Supports: SMART App Launch and CDS Hooks cards; Epic configuration referenced; no prior-authorization content on the page.

- [10] **Clinical domain models.** Medblocks. <https://medblocks.com/docs/clinical-data-models>. Not stated. Retrieved 30 Sep 2026.
Supports: Product-facing clinical shapes built on FHIR; unit/code normalization; provenance preserved to source records.
- [11] **Data out.** Medblocks. <https://medblocks.com/docs/data-out>. Not stated. Retrieved 30 Sep 2026.
Supports: GET /patients/{id}/records; exports to FHIR R4 server or NDJSON in S3/GCS/Azure Blob; exports configured in dashboard, not public REST API; triggers and watermarks.
- [12] **Pull monitoring.** Medblocks. <https://medblocks.com/docs/pull-monitoring>. Not stated. Retrieved 30 Sep 2026.
Supports: Pull triggers, token refresh before expiry, refresh_failed state, failure types, dashboard pull history.
- [13] **Webhooks.** Medblocks. <https://medblocks.com/docs/webhooks>. Not stated. Retrieved 30 Sep 2026.
Supports: Events patient_session.completed, connection.token_refresh_failed, records.sync.completed, records.sync.failed; Medblocks-Signature over raw body; 2xx within 5 s; retries; idempotency by event.id.
- [14] **Workspace setup.** Medblocks. <https://medblocks.com/docs/workspace>. Not stated. Retrieved 30 Sep 2026.
Supports: Sandbox (mb_sk_sb_x_) vs production (mb_sk_live_) workspaces; server-side API keys; key rotation.
- [15] **Test with sandboxes.** Medblocks. <https://medblocks.com/docs/sandboxes>. Not stated. Retrieved 30 Sep 2026.
Supports: Vendor sandboxes (Epic, Cerner, athenahealth, eClinicalWorks, Meditech, CMS Blue Button); Synthea cohort seeding; caution that synthetic data does not show production coverage.
- [16] **Platform API reference.** Medblocks. <https://medblocks.com/docs/reference/api>. Not stated. Retrieved 30 Sep 2026.
Supports: API resource groups: system, patients, connections, patient sessions, webhooks, errors.
- [17] **Security and compliance.** Medblocks. <https://medblocks.com/docs/security-and-compliance>. Not stated. Retrieved 30 Sep 2026.
Supports: Vendor-stated HIPAA, SOC 2 Type II, ISO 27001, GDPR; BAA on commercial plans; formal packet available on request.
- [18] **Billing and plans.** Medblocks. <https://medblocks.com/docs/billing>. Not stated. Retrieved 30 Sep 2026.
Supports: Free plan (1,000 active patients) and Enterprise plan (\$60,000/year); metering by active patient; HTTP 402 billing errors.
- [19] **Our approach.** Medblocks. <https://medblocks.com/docs/our-approach>. Not stated. Retrieved 30 Sep 2026.
Supports: Direct connection to regulated APIs; cross-source deduplication and normalization; openEHR-CKM-inspired clinical models.
- [20] **The Medblocks Stack (earlier Digital Health Platform material).** Medblocks. <https://medblocks.com/medblocks-ui-docs/the-medblocks-stack>. Not stated. Retrieved 30 Sep 2026.
Supports: FHIR REST, openEHR REST, SMART on FHIR/openEHR, S3-compatible storage; names HAPI FHIR, Aidbox, EHRbase, MinIO as example implementations.
- [21] **FHIR prior authorization (technical article).** Medblocks. <https://medblocks.com/blog/fhir-prior-authorization>. 24 Sep 2026.
Retrieved 30 Sep 2026.
Supports: Educational article on CRD/DTR/PAS and CMS-0057-F; no claim of a Medblocks PA product.
- [22] **medblocks/openFHIR repository (archived).** Medblocks / GitHub. <https://github.com/medblocks/openFHIR>. Archived; last push 5 Mar 2026. Retrieved 30 Sep 2026.
Supports: Original openFHIR repository archived; Apache-2.0.
- [23] **openFHIR/openfhir repository.** openFHIR project / GitHub. <https://github.com/openFHIR/openfhir>. Release 3.0.1, 9 Sep 2026. Retrieved 30 Sep 2026.
Supports: openEHR-FHIR bidirectional mapping engine (FHIRConnect); Apache-2.0; open-source version not intended for production use.

E. CMS and HHS regulatory sources

- [24] **CMS Interoperability and Prior Authorization Final Rule (CMS-0057-F) fact sheet.** CMS. <https://www.cms.gov/newsroom/fact-sheets/cms-interoperability-prior-authorization-final-rule-cms-0057-f>. 17 Jan 2024. Retrieved 30 Sep 2026.
Supports: Impacted payers; 72-hour expedited / 7-calendar-day standard decisions; specific denial reason; 1 Jan 2026 operational and 1 Jan 2027 API dates; Patient Access, Provider Access, Payer-to-Payer and Prior Authorization APIs; ePA measure; X12 278 enforcement discretion; drugs excluded.
- [25] **Electronic Prior Authorization: overview.** CMS. <https://www.cms.gov/priorities/electronic-prior-authorization/overview>. Last modified 14 Sep 2026. Retrieved 30 Sep 2026.
Supports: Current CMS ePA landscape: CMS-0057-F, CMS-0062-P (released 10 Apr 2026), FY 2027 IPPS ePA measure (optional bonus CY2027; mandatory from CY2028), June 2025 industry pledge, WISer.
- [26] **Summary of Proposed Provisions: 2026 CMS Interoperability Standards and Prior Authorization for Drugs Proposed Rule (CMS-0062-P).** CMS. <https://www.cms.gov/files/document/summary-changes-provisions-rule-10apr26-final-508-compliant.pdf>. 10 Apr 2026. Retrieved 30 Sep 2026.
Supports: Proposed: drug PA (medical benefit via PA API; pharmacy benefit via NCPDP standards); HIPAA adoption of FHIR + IGs in place of X12 278 and 270/271 for PA; endpoint reporting; QHP timeframes; FF-SHOP issuers; API usage metrics.
- [27] **Federal Register: Interoperability Standards and Prior Authorization for Drugs (proposed rule).** HHS/CMS, Federal Register. <https://www.federalregister.gov/documents/2026/04/14/2026-07205/medicare-and-medicaid-programs-patient-protection-and-affordable-care-act-interoperability-standards>. 14 Apr 2026. Retrieved 30 Sep 2026.
Supports: Official publication of CMS-0062-P (proposed; not final as of 30 Sep 2026).

- [28] **APIs and Relevant Standards and Implementation Guides.** CMS. <https://www.cms.gov/priorities/burden-reduction/overview/interoperability/implementation-guides-standards/application-programming-interfaces-apis-relevant-standards-implementation-guides-igs>. Last modified 31 Aug 2026. Retrieved 30 Sep 2026.
Supports: Required standards (FHIR 4.0.1, US Core, SMART, Bulk, OIDC) and recommended IGs per API incl. CRD/DTR/PAS; conditions for using updated versions.
- [29] **Administrative Simplification enforcement FAQs (X12 278 enforcement discretion).** CMS. <https://www.cms.gov/priorities/key-initiatives/burden-reduction/administrative-simplification/enforcement/faqs>. Not stated. Retrieved 30 Sep 2026.
Supports: Enforcement discretion for covered entities using a FHIR-based PA API per CMS-0057-F instead of X12 278; no terminal date; entities may elect, not be compelled.
- [30] **Prior Authorization API FAQs.** CMS. <https://www.cms.gov/initiatives/burden-reduction/overview/interoperability/frequently-asked-questions/prior-authorization-api>. Last modified 21 Sep 2026. Retrieved 30 Sep 2026.
Supports: PA responses must approve (with end date/circumstance), deny (specific reason) or request more information.
- [31] **Adoption of Standards for Health Care Claims Attachments Transactions and Electronic Signatures Final Rule (CMS-0053-F) fact sheet.** CMS. <https://www.cms.gov/files/document/nsg-attachments-final-rule-fact-sheet.pdf>. Final rule published 24 Mar 2026. Retrieved 30 Sep 2026.
Supports: X12N 275/277 v6020 and HL7 C-CDA + Attachments IG for claims attachments; effective 26 May 2026; compliance 26 May 2028; prior-authorization attachment standards not finalized.
- [32] **WISer (Wasteful and Inappropriate Service Reduction) Model.** CMS Innovation Center. <https://www.cms.gov/priorities/innovation/innovation-models/wiser>. Last modified 10 Sep 2026. Retrieved 30 Sep 2026.
Supports: Original Medicare PA model, 1 Jan 2026 to 31 Dec 2031, six states, selected services; requests to model participant or via MAC.
- [33] **Electronic Submission of Medical Documentation (esMD).** CMS. <https://www.cms.gov/data-research/computer-data-systems/esmd>. Not stated. Retrieved 30 Sep 2026.
Supports: Medicare FFS providers can send PA requests and documentation electronically via esMD.
- [34] **Documentation Requirement Lookup Service (DRLS) initiative.** CMS. <https://www.cms.gov/data-research/monitoring-programs/medicare-fee-service-compliance-programs/documentation-requirement-lookup-service-initiative>. Not stated. Retrieved 30 Sep 2026.
Supports: Medicare FFS prototype for discovering PA/documentation requirements in the EHR; linked to Da Vinci work.
- [35] **Blue Button 2.0 API documentation.** CMS. <https://bluebutton.cms.gov/api-documentation/>. Not stated. Retrieved 30 Sep 2026.
Supports: Patient-authorized Medicare claims data; FHIR R4 with CARIN Blue Button IG; OAuth 2.0; synthetic sandbox; production approval.
- [36] **Federal Register: Medicare Part D Health IT Standards (NCPDP SCRIPT 2023011).** HHS/CMS, Federal Register. <https://www.federalregister.gov/documents/2024/06/17/2024-12842/medicare-program-medicare-prescription-drug-benefit-program-health-information-technology-standards>. 17 Jun 2024. Retrieved 30 Sep 2026.
Supports: NCPDP SCRIPT 2023011 (including ePA transactions) required for Part D e-prescribing from 1 Jan 2028; transition period.
- [37] **Federal Register: Secure Electronic Prior Authorization for Medicare Part D.** HHS/CMS, Federal Register. <https://www.federalregister.gov/documents/2020/12/31/2020-28877/medicare-program-secure-electronic-prior-authorization-for-medicare-part-d>. 31 Dec 2020. Retrieved 30 Sep 2026.
Supports: Adoption of NCPDP SCRIPT ePA transactions for Part D (historical baseline).
- [38] **CMS Interoperability Framework (Health Technology Ecosystem).** CMS. <https://www.cms.gov/initiatives/health-technology-ecosystem/overview/interoperability-framework>. Not stated. Retrieved 30 Sep 2026.
Supports: Voluntary CMS Interoperability Framework; CMS Aligned Networks; participant categories.
- [39] **Healthcare Common Procedure Coding System (HCPCS).** CMS. <https://www.cms.gov/medicare/coding-billing/healthcare-common-procedure-system>. Not stated. Retrieved 30 Sep 2026.
Supports: HCPCS Level II code set maintained by CMS.

F. HL7 / Da Vinci standards

- [40] **FHIR publication history (package list).** HL7 International. <https://hl7.org/fhir/directory.html>. R5 5.0.0: 26 Mar 2023; R6 ballot/snapshot: 17 Jul 2026. Retrieved 30 Sep 2026.
Supports: R4 (4.0.1) and R4B/R5 published; R6 still in ballot/draft status.
- [41] **FHIR Release 4 (4.0.1).** HL7 International. <https://hl7.org/fhir/R4/>. Not stated. Retrieved 30 Sep 2026.
Supports: Base resource definitions used by US Core and Da Vinci IGs.
- [42] **US Core Implementation Guide (v9.0.0, STU 9).** HL7 International. <https://hl7.org/fhir/us/core/>. Current published version as of 30 Sep 2026. Retrieved 30 Sep 2026.
Supports: US Core current published version is 9.0.0 based on FHIR R4.
- [43] **SMART App Launch (v2.2.0).** HL7 International. <https://hl7.org/fhir/smart-app-launch/>. Current published STU 2.2. Retrieved 30 Sep 2026.
Supports: EHR and standalone launch, v2 scopes, asymmetric client auth preferred, backend services, token introspection, user-access brands.

- [44] **SMART Backend Services.** HL7 International. <https://hl7.org/fhir/smart-app-launch/backend-services.html>. SMART 2.2.0. Retrieved 30 Sep 2026.
Supports: Client-credentials with signed JWT assertion for system-to-system access.
- [45] **FHIR Bulk Data Access (v3.0.0, STU 3).** HL7 International. <https://hl7.org/fhir/uv/bulkdata/>. Current published version as of 30 Sep 2026. Retrieved 30 Sep 2026.
Supports: Asynchronous \$export, NDJSON output (CMS rule text references v1.0.0 for Provider Access / Payer-to-Payer).
- [46] **Subscriptions R5 Backport (v1.1.0).** HL7 International. <https://hl7.org/fhir/uv/subscriptions-backport/>. STU 1.1. Retrieved 30 Sep 2026.
Supports: Topic-based subscriptions for R4; used by PAS for pended responses.
- [47] **CDS Hooks (v2.0.1, STU 2).** HL7 International. <https://cde-hooks.hl7.org/>. STU 2. Retrieved 30 Sep 2026.
Supports: Hook invocation, prefetch, cards and system actions used by CRD.
- [48] **Da Vinci Coverage Requirements Discovery (CRD) IG v2.2.1.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-crd/>. Current published STU 2.2. Retrieved 30 Sep 2026.
Supports: CRD current version 2.2.1 on FHIR R4.
- [49] **CRD: Supported hooks and response types.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-crd/2.2.1/en/hooks.html>. v2.2.1. Retrieved 30 Sep 2026.
Supports: Hooks appointment-book, encounter-start, encounter-discharge, order-select, order-dispatch, order-sign; primary hooks SHALL return Coverage Information; response types.
- [50] **CRD: Foundational requirements.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-crd/2.2.1/en/foundation.html>. v2.2.1. Retrieved 30 Sep 2026.
Supports: Response-time targets (5 s; 10 s for certain hooks) 90% of the time; narrow scopes and short token lifetime; prefetch; log retention for disputes.
- [51] **Da Vinci Documentation Templates and Rules (DTR) IG v2.2.0.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-dtr/>. Current published STU 2.2. Retrieved 30 Sep 2026.
Supports: DTR current version 2.2.0 on FHIR R4.
- [52] **DTR: Formal specification.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-dtr/2.2.0/en/specification.html>. v2.2.0. Retrieved 30 Sep 2026.
Supports: SMART DTR app vs Full EHR; \$questionnaire-package; CQL pre-population; adaptive forms/\$next-question timing; QuestionnaireResponse storage; SMART Backend Services to payer; multi-payer expectation.
- [53] **Da Vinci Prior Authorization Support (PAS) IG v2.2.1.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-pas/>. Current published STU 2. Retrieved 30 Sep 2026.
Supports: PAS current version 2.2.1 on FHIR R4.
- [54] **PAS: Formal specification.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-pas/2.2.1/en/specification.html>. v2.2.1. Retrieved 30 Sep 2026.
Supports: Claim/\$submit and Claim/\$inquire; Bundle rules; 15-second target else pended; subscriptions (rest-hook, full-resource); X12 278/275 black-box intermediary; updates/cancellation; HTTP error semantics; 6-month availability of pended PAs.
- [55] **PAS: Additional information.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-pas/2.2.1/en/additionalinfo.html>. v2.2.1. Retrieved 30 Sep 2026.
Supports: Task-based requests for additional information conveyed to CDex; \$submit-attachment; questionnaire TRNs as Task.input.
- [56] **Da Vinci Clinical Data Exchange (CDex) IG v2.1.0.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-cdex/>. Current published STU 2. Retrieved 30 Sep 2026.
Supports: Attachments and solicited/unsolicited clinical data exchange used by PAS.
- [57] **Da Vinci Health Record Exchange (HREx) IG v1.2.0.** HL7 International / Da Vinci. <https://hl7.org/fhir/us/davinci-hrex/>. Current published STU 1.2. Retrieved 30 Sep 2026.
Supports: Shared Da Vinci security/privacy and exchange conventions referenced by PAS.
- [58] **FHIR R4 DocumentReference.** HL7 International. <https://hl7.org/fhir/R4/documentreference.html>. FHIR 4.0.1. Retrieved 30 Sep 2026.
Supports: Document metadata and attachment references.
- [59] **FHIR R4 Terminology Service.** HL7 International. <https://hl7.org/fhir/R4/terminology-service.html>. FHIR 4.0.1. Retrieved 30 Sep 2026.
Supports: CodeSystem/ValueSet/ConceptMap operations (\$expand, \$validate-code, \$translate, \$lookup).
- [60] **HL7 Version 2 to FHIR mapping IG.** HL7 International. <https://hl7.org/fhir/uv/v2mappings/>. Not stated. Retrieved 30 Sep 2026.
Supports: Informative mappings from HL7 v2 messages to FHIR.
- [61] **HL7 C-CDA (US Realm).** HL7 International. <https://hl7.org/cda/us/ccda/>. Not stated. Retrieved 30 Sep 2026.
Supports: Clinical document standard; C-CDA R5.0.0 approved in 2026 SVAP.
- [62] **HL7 Da Vinci reference implementations (prior-auth, CRD, DTR).** HL7 Da Vinci / GitHub. <https://github.com/HL7-DaVinci>. Repos updated Jul 2026. Retrieved 30 Sep 2026.
Supports: Apache-2.0 reference implementations useful for lab testing; not production systems.

C. Other standards, ONC/ASTP and exchange frameworks

- [63] **HTI-4 Overview and Key Dates for the Certification Program.** ASTP/ONC. <https://healthit.gov/resources/hti-4-overview-and-key-dates-for-certification-program/>. Oct 2025. Retrieved 30 Sep 2026.
Supports: Certification criteria 170.315(g)(31) CRD, (g)(32) DTR, (g)(33) PAS, (j)(20) CDS Hooks triggers, (j)(21) Subscriptions client; SCRIPT 2023011 transition to 1 Jan 2028; rule effective 1 Oct 2025.
- [64] **Advancements in Health IT: ONC's 2026 Approved SVAP Standards.** ASTP/ONC. <https://healthit.gov/blog/standards/advancements-in-health-it-oncs-2026-approved-svap-standards/>. 30 Jun 2026. Retrieved 30 Sep 2026.
Supports: 2026 SVAP: USCDI v6, US Core 9.0.0, C-CDA R5.0.0, CRD 2.2.1, DTR 2.2.0, PAS 2.2.1; voluntary use from 29 Aug 2026.
- [65] **United States Core Data for Interoperability (USCDI).** ASTP/ONC. <https://isp.healthit.gov/united-states-core-data-interoperability-uscdi>. Not stated. Retrieved 30 Sep 2026.
Supports: USCDI data classes and versions.
- [66] **Trusted Exchange Framework and Common Agreement (TEFCA).** ASTP/ONC. <https://healthit.gov/policy/tefca/>. Not stated. Retrieved 30 Sep 2026.
Supports: RCE (The Sequoia Project); QHINs; exchange purposes incl. treatment, payment, operations, public health, government benefits determination, individual access services; Common Agreement v2.1.
- [67] **Designated QHINs.** TEFCA RCE (The Sequoia Project). <https://rce.sequoiaproject.org/designated-qhins/>. Not stated. Retrieved 30 Sep 2026.
Supports: List of designated QHINs (rolling).
- [68] **Carequality: What we do.** Carequality (The Sequoia Project). <https://carequality.org/what-we-do/>. Not stated (automated retrieval blocked). Retrieved 30 Sep 2026.
Supports: Interoperability framework (legal/policy/technical) connecting networks; details need validation with implementer.
- [69] **CommonWell: Connect to the network.** CommonWell Health Alliance. <https://www.commonwellalliance.org/connect-to-the-network>. Not stated (automated retrieval blocked). Retrieved 30 Sep 2026.
Supports: Network services incl. record location; onboarding via service adopters; details need validation.
- [70] **Inferno test kits (Da Vinci CRD, DTR, PAS, PDex).** ASTP/ONC. <https://inferno.healthit.gov/test-kits/>. Kits updated 3-8 Sep 2026. Retrieved 30 Sep 2026.
Supports: CRD (2.0.1, 2.2.1), DTR (2.0.1, 2.2.0), PAS (2.0.1, 2.2.1) test kits; low maturity labels.
- [71] **RFC 9700: Best Current Practice for OAuth 2.0 Security.** IETF. <https://www.rfc-editor.org/rfc/rfc9700.html>. Jan 2025. Retrieved 30 Sep 2026.
Supports: PKCE, exact redirect matching, sender-constrained tokens, no resource-owner password grant.
- [72] **OpenID Connect Core 1.0.** OpenID Foundation. https://openid.net/specs/openid-connect-core-1_0.html. Errata set 2. Retrieved 30 Sep 2026.
Supports: Identity layer on OAuth 2.0; ID tokens.

G. EHR vendor sources

- [73] **Epic on FHIR (developer site).** Epic Systems. <https://fhir.epic.com/>. Sandbox notice dated 31 Aug 2026. Retrieved 30 Sep 2026.
Supports: R4/STU3/DSTU2 APIs; patient, clinician and backend apps; free sandbox; CDS Hooks and Bulk FHIR documentation.
- [74] **Epic on FHIR: OAuth 2.0 documentation.** Epic Systems. <https://fhir.epic.com/Documentation?docId=oauth2>. Not stated. Retrieved 30 Sep 2026.
Supports: EHR/standalone launch, backend OAuth, refresh tokens for confidential clients, JWKS; client records sync to customer environments over time.
- [75] **open.epic.** Epic Systems. <https://open.epic.com/>. Not stated. Retrieved 30 Sep 2026.
Supports: Self-service standards-based APIs, app registration and customer connection; Connection Hub listing optional.
- [76] **Epic Vendor Services.** Epic Systems. <https://vendorservices.epic.com/>. Not stated. Retrieved 30 Sep 2026.
Supports: Optional paid program: additional technologies, documentation, expanded sandbox, Epic support.
- [77] **Oracle Health Millennium Platform APIs.** Oracle Health. <https://docs.oracle.com/en/industries/health/millennium-platform-apis/>. Not stated. Retrieved 30 Sep 2026.
Supports: FHIR R4 APIs, bulk data, SMART and system-account authorization, open and secure sandboxes; DSTU2 no longer supported.
- [78] **athenahealth Developer Portal (athenaPractice/athenaFlow) and FHIR R4 documentation.** athenahealth. <https://mydata.athenahealth.com/>. IG v25-v27 pages indexed 2026. Retrieved 30 Sep 2026.
Supports: FHIR R4 (4.0.1); SMART v2 with v1 backward compatibility; client-credentials for service apps; sandbox. athenaOne and athenaPractice/athenaFlow are distinct products; details need validation per product.
- [79] **athenahealth Document Portal: FHIR APIs (athenaOne).** athenahealth. <https://docs.athenahealth.com/api/docs/fhir-apis>. Not stated (automated retrieval blocked). Retrieved 30 Sep 2026.
Supports: athenaOne FHIR and proprietary API documentation entry point; needs validation.

- [80] **eClinicalWorks Interoperability.** eClinicalWorks. <https://www.eclinicalworks.com/products-services/interoperability/>. Not stated. Retrieved 30 Sep 2026.
Supports: Provider-facing FHIR developer portal and healow patient-facing portal; SMART and bulk/backend apps; TEFCA participation; PRISMA.
- [81] **MEDITECH Greenfield Workspace.** MEDITECH. <https://ehr.meditech.com/ehr-solutions/greenfield-workspace>. Not stated. Retrieved 30 Sep 2026.
Supports: Developer testing environment for Expanse; US Core FHIR R4 patient-facing APIs; scheduling APIs; contact for other use cases.

H. Payer, clearinghouse and pharmacy-network sources

- [82] **UnitedHealthcare: Prior authorization and notification.** UnitedHealthcare. <https://www.uhcprovider.com/en/prior-auth-advance-notification.html>. Not stated. Retrieved 30 Sep 2026.
Supports: Provider Portal real-time submission, API status checks, EDI batch, phone/fax; National Gold Card program.
- [83] **UnitedHealthcare interoperability APIs.** UnitedHealthcare. <https://www.uhc.com/legal/interoperability-apis>. Not stated (retrieved 30 Sep 2026). Retrieved 30 Sep 2026.
Supports: Prior Authorization API using CRD, DTR and PAS described and labeled 'Coming soon'.
- [84] **Blue Cross NC: Interoperability API access.** Blue Cross and Blue Shield of North Carolina. <https://www.bcbsnc.com/policies-best-practices/api-access>. Not stated. Retrieved 30 Sep 2026.
Supports: Patient Access, Provider Directory, Payer-to-Payer available; Provider Access and Prior Authorization 'Coming 2027'; 10-business-day access review.
- [85] **Aetna Developer Portal.** Aetna (CVS Health). <https://developerportal.aetna.com/>. Not stated. Retrieved 30 Sep 2026.
Supports: Payer developer portal entry point; API catalog content not machine-readable at retrieval; needs validation.
- [86] **Availity: End-to-end authorizations.** Availity. <https://www.availity.com/end-to-end-authorizations/>. Not stated. Retrieved 30 Sep 2026.
Supports: Vendor-stated support for CRD, DTR, PAS; submission via portal, trading partners, direct X12 or API.
- [87] **Surescripts: Electronic Prior Authorization.** Surescripts. <https://surescripts.com/what-we-do/electronic-prior-authorization>. Not stated. Retrieved 30 Sep 2026.
Supports: Pharmacy-benefit ePA in the prescriber EHR workflow using NCPDP SCRIPT ePA transactions (vendor-stated reach).

I. Security, privacy and compliance sources

- [88] **45 CFR 164.312 Technical safeguards.** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.312>. Current CFR text. Retrieved 30 Sep 2026.
Supports: Access control, audit controls, integrity, person/entity authentication, transmission security; encryption is an addressable specification.
- [89] **45 CFR 164.316 Policies, procedures and documentation.** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.316>. Current CFR text. Retrieved 30 Sep 2026.
Supports: Retain Security Rule documentation 6 years from creation or last effective date.
- [90] **45 CFR 164.404 Notification to individuals.** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.404>. Current CFR text. Retrieved 30 Sep 2026.
Supports: Without unreasonable delay and no later than 60 calendar days after discovery.
- [91] **45 CFR 164.408 Notification to the Secretary.** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.408>. Current CFR text. Retrieved 30 Sep 2026.
Supports: 500+ individuals: contemporaneous; fewer than 500: log and notify within 60 days after calendar-year end.
- [92] **45 CFR 164.410 Notification by a business associate.** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.410>. Current CFR text. Retrieved 30 Sep 2026.
Supports: Business associate notifies covered entity no later than 60 calendar days after discovery.
- [93] **45 CFR 164.501 Definitions (Payment).** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.501>. Current CFR text. Retrieved 30 Sep 2026.
Supports: 'Payment' includes utilization review activities including precertification and preauthorization.
- [94] **45 CFR 164.502 Uses and disclosures (minimum necessary).** U.S. CFR via Cornell LII. <https://www.law.cornell.edu/cfr/text/45/164.502>. Current CFR text. Retrieved 30 Sep 2026.
Supports: Minimum necessary standard; exception for disclosures to or requests by a provider for treatment.
- [95] **Federal Register: HIPAA Security Rule To Strengthen the Cybersecurity of ePHI (NPRM).** HHS OCR, Federal Register. <https://www.federalregister.gov/documents/2025/01/06/2024-30983/hipaa-security-rule-to-strengthen-the-cybersecurity-of-electronic-protected-health-information>. 6 Jan 2025. Retrieved 30 Sep 2026.
Supports: Proposed Security Rule changes (not final).
- [96] **Unified Agenda: RIN 0945-AA22 (HIPAA Security Rule).** OMB/OIRA reginfo.gov. <https://www.reginfo.gov/public/do/eAgendaViewRule?pubId=202510&RIN=0945-AA22>. Fall 2025 agenda. Retrieved 30 Sep 2026.
Supports: Stage: Long-Term Actions; NPRM 01/06/2025; final action listed 07/2027.

- [97] **Federal Register: Confidentiality of Substance Use Disorder Patient Records (42 CFR Part 2) final rule.** HHS/SAMHSA, Federal Register. <https://www.federalregister.gov/documents/2024/02/16/2024-02544/confidentiality-of-substance-use-disorder-sud-patient-records>. 16 Feb 2024. Retrieved 30 Sep 2026.
Supports: Part 2 alignment with HIPAA; compliance date 16 Feb 2026; breach notification applies to Part 2 records.
- [98] **NIST SP 800-66 Rev. 2: Implementing the HIPAA Security Rule.** NIST. <https://csrc.nist.gov/pubs/sp/800/66/r2/final>. Feb 2024. Retrieved 30 Sep 2026.
Supports: Cybersecurity resource guide mapping Security Rule to controls.
- [99] **SOC 2 (System and Organization Controls).** AICPA & CIMA. <https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>. Not stated. Retrieved 30 Sep 2026.
Supports: SOC 2 attestation over Trust Services Criteria.
- [100] **HITRUST.** HITRUST Alliance. <https://hitrustalliance.net/>. Not stated. Retrieved 30 Sep 2026.
Supports: HITRUST framework and assessments/certification.
- [101] **AWS HIPAA Eligible Services Reference.** Amazon Web Services. <https://aws.amazon.com/compliance/hipaa-eligible-services-reference/>. Last updated 3 Sep 2026. Retrieved 30 Sep 2026.
Supports: HIPAA-eligible services incl. API Gateway, ELB, ECS, EKS, Fargate, RDS, Aurora, ElastiCache, SQS, SNS, EventBridge, Step Functions, S3, KMS, Secrets Manager, CloudWatch, CloudTrail, WAF, CloudFront, Cognito, HealthLake, Textract, GuardDuty, Backup.

T. Terminology sources

- [102] **SNOMED CT licensing (U.S.).** National Library of Medicine. https://www.nlm.nih.gov/healthit/snomedct/snomed_licensing.html. Not stated. Retrieved 30 Sep 2026.
Supports: Free U.S. use via UMLS Metathesaurus license; redistribution restrictions.
- [103] **LOINC license.** Regenstrief Institute. <https://loinc.org/kb/license/>. Not stated (automated retrieval blocked). Retrieved 30 Sep 2026.
Supports: LOINC terms of use (free with license terms).
- [104] **RxNorm overview.** National Library of Medicine. <https://www.nlm.nih.gov/research/umls/rxnorm/overview.html>. Not stated. Retrieved 30 Sep 2026.
Supports: Normalized clinical drug names linked to source vocabularies incl. NDC.
- [105] **ICD-10-CM.** CDC National Center for Health Statistics. <https://www.cdc.gov/nchs/icd/icd-10-cm/index.html>. Not stated (automated retrieval blocked). Retrieved 30 Sep 2026.
Supports: U.S. diagnosis classification (HIPAA code set).
- [106] **CPT licensing FAQs.** American Medical Association. <https://www.ama-assn.org/practice-management/cpt/cpt-licensing-frequently-asked-questions-faqs>. Not stated. Retrieved 30 Sep 2026.
Supports: CPT use in products requires AMA license; development and distribution licenses.
- [107] **National Drug Code Format.** U.S. FDA. <https://www.fda.gov/drugs/electronic-drug-registration-and-listing-system-edrls/national-drug-code-format>. Content current as of 8 Jul 2026. Retrieved 30 Sep 2026.
Supports: Current 10-digit NDC in several formats; final rule adopts uniform 12-digit NDC effective 7 Mar 2023.

J. FHIR server, cloud and open-source sources

- [108] **HAPI FHIR (repository and releases).** HAPI FHIR / Smile Digital Health / GitHub. <https://github.com/hapifhir/hapi-fhir>. Latest release v8.8.2, 25 Sep 2026. Retrieved 30 Sep 2026.
Supports: Open-source Java FHIR library and JPA server; Apache-2.0; active releases.
- [109] **HAPI FHIR JPA: Partitioning and multitenancy.** HAPI FHIR. https://hapifhir.io/hapi-fhir/docs/server_jpa_partitioning/partitioning.html. Not stated. Retrieved 30 Sep 2026.
Supports: URL-based tenant partitions; conformance resources not partitionable; authorization required for real isolation.
- [110] **Medplum (repository).** Medplum / GitHub. <https://github.com/medplum/medplum>. Release v5.1.43, 30 Sep 2026. Retrieved 30 Sep 2026.
Supports: Apache-2.0 TypeScript healthcare platform: FHIR server, auth (OAuth/OIDC/SMART), bots, subscriptions.
- [111] **What is AWS HealthLake?.** Amazon Web Services. <https://docs.aws.amazon.com/healthlake/latest/devguide/what-is.html>. Not stated. Retrieved 30 Sep 2026.
Supports: HIPAA-eligible managed FHIR R4 data store; SMART on FHIR authorization; Bulk export; US Core; NLP; duplicate linking (preview).
- [112] **FHIR service in Azure Health Data Services.** Microsoft. <https://learn.microsoft.com/en-us/azure/healthcare-apis/fhir/overview>. Updated 4 May 2026. Retrieved 30 Sep 2026.
Supports: Managed FHIR PaaS; SMART on FHIR; Entra RBAC; audit logs; open-source FHIR Server for Azure alternative.
- [113] **Cloud Healthcare API: FHIR concepts.** Google Cloud. <https://docs.cloud.google.com/healthcare-api/docs/concepts/fhir>. Not stated. Retrieved 30 Sep 2026.
Supports: FHIR stores supporting DSTU2, STU3, R4, R5; SMART; Pub/Sub notifications.
- [114] **FHIR Server for Azure (open source).** Microsoft / GitHub. <https://github.com/microsoft/fhir-server>. Not stated. Retrieved 30 Sep 2026.
Supports: Open-source FHIR server deployable in own subscription.

- [115] **Amazon SQS standard queues: at-least-once delivery.** Amazon Web Services. <https://docs.aws.amazon.com/AWSSimpleQueueService/latest/SQSDeveloperGuide/standard-queues-at-least-once-delivery.html>. Not stated. Retrieved 30 Sep 2026.
Supports: Messages may be delivered more than once; consumers must be idempotent.

K. Secondary / trade-press sources (used only where no primary source was retrievable)

- [116] **Epic Launches Coverage Requirements Discovery API with Ochsner, Froedtert, Denver Health, and Summit Health.** HIT Consultant. <https://hitconsultant.net/2026/08/17/epic-deploys-real-time-crd-prior-authorization-apis-ochsner-froedtert/>. 17 Aug 2026. Retrieved 30 Sep 2026.
Supports: Trade-press report: Epic CRD API live at four health systems with UnitedHealthcare, Aetna and Network Health; 16 payers in sandbox testing.
- [117] **Inside payers' latest plans to streamline prior authorization.** American Medical Association. <https://www.ama-assn.org/practice-management/prior-authorization/inside-payers-latest-plans-streamline-prior-authorization>. 14 Jul 2025. Retrieved 30 Sep 2026.
Supports: AHIP/BCBSA voluntary commitments: standardized FHIR ePA and 80% real-time approvals (goal 1 Jan 2027), volume reduction, 90-day continuity (goal 1 Jan 2026); AMA critique (excludes pharmacy benefit).